Bank AI governance: legal study pack

Priority reading, application dates and a complete selected-provision appendix. Full official instruments and judgments accompany this pack in the legal compendium.

Prepared for 5DA06 · Reviewed 1 November 2026

Online reader: https://pqhhust.github.io/ai-ethics-atlas/

How to use this pack

- First read the priority guide and connect each rule to one bank application.
- For oral preparation, explain the decision, legal reason, safeguard and trade-off.
- Use the appendix for the exact wording of every selected provision. The companion compendium contains the complete official PDFs.
- This is a dated study aid for the supplied project. It does not replace checking the facts and all applicable sector-specific rules for a real deployment.

Reading priorities

EU AI Act + 2026 amendment · Essential

Read: 3, 4, 4a, 5, 6 + Annex III, 9–17, 25–27, 43, 50, 53, 55, 86, 111, 113

- Classify the application by its intended purpose; distinguish model and system.
- Map provider/deployer responsibilities, including internal development and repurposing.
- Connect each safeguard to evidence and the provision’s application date.

AI Act · 3 · Definitions
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_3

AI Act · 6 · Classification rules for high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_6

AI Act · 25 · Responsibilities along the AI value chain
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_25

AI Act · 26 · Obligations of deployers of high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_26

AI Act · 27 · Fundamental rights impact assessment for high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_27

AI Act · 113 · Entry into force and application
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_113

GDPR · Essential

Read: 4–6, 9, 12–15, 22, 24–25, 28, 32–36, 44–49

- A lawful basis does not replace the processing principles.
- Nominal human involvement may not prevent solely automated decision-making.
- Assess contracts, security and transfers as well as data-centre location.

GDPR · 5 · Principles relating to processing of personal data
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_5

GDPR · 6 · Lawfulness of processing
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_6

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

GDPR · 28 · Processor
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_28

GDPR · 35 · Data protection impact assessment
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_35

GDPR · 44 · General principle for transfers
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_44

CCD2 + French transposition · Essential for credit

Read: CCD2 2, 18, 19, 47–48; Ordonnance 2025-880 Articles 19 and 99

- Check consumer-credit scope and transitional rules.
- Article 18(8) concerns automated processing and is not limited to GDPR's solely automated trigger.
- From 20 November 2026, relevant new French borrower protections apply; sensitive data and social networks are restricted as creditworthiness inputs.

Consumer credit · 2 · Scope
https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_2

Consumer credit · 18 · Obligation to assess the creditworthiness of the consumer
https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_18

Consumer credit · 48 · Transposition
https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_48

French consumer credit · Ordonnance Art. 19 · Replacement of Consumer Code Article L312-16
https://www.legifrance.gouv.fr/jorf/id/JORFTEXT000052184230

French consumer credit · Ordonnance Art. 99 · Entry into force and transitional rules
https://www.legifrance.gouv.fr/jorf/id/JORFTEXT000052184230

DORA · Important for external services

Read: 2–6, 17, 19, 24, 28–30, 64

- The bank remains responsible when using ICT third parties.
- Contractual and risk requirements depend partly on the supported function.
- Plan concentration risk, service continuity, incidents and exit; DORA is not a blanket foreign-cloud ban.

DORA · 5 · Governance and organisation
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_5

DORA · 6 · ICT risk management framework
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_6

DORA · 28 · General principles
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_28

DORA · 29 · Preliminary assessment of ICT concentration risk at entity level
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_29

DORA · 30 · Key contractual provisions
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_30

French Labour Code · Important for employee rollout

Read: L2312-8, L2312-14, L2312-38

- Assess the applicable CSE regime and workplace changes.
- Consultation precedes relevant employer decisions.
- Distinguish employee information, consultation and a veto.

French labour law · L2312-8 · CSE: consultation / workplace technology
https://code.travail.gouv.fr/code-du-travail/l2312-8

French labour law · L2312-14 · CSE: consultation / workplace technology
https://code.travail.gouv.fr/code-du-travail/l2312-14

French labour law · L2312-38 · CSE: consultation / workplace technology
https://code.travail.gouv.fr/code-du-travail/l2312-38

Copyright Directive 2019/790 · Secondary unless training/licensing is disputed

Read: 2–4, 7; connect AI Act 53

- Separate research TDM from the general TDM exception.
- Check lawful access and rights reservations rather than treating public data as unrestricted.
- Open weights do not establish copyright clearance or remove every GPAI duty.

Copyright · 3 · Text and data mining for the purposes of scientific research
https://publications.europa.eu/resource/cellar/214471fe-786e-11e9-9f05-01aa75ed71a1.0006.03/DOC_1#art_3

Copyright · 4 · Exception or limitation for text and data mining
https://publications.europa.eu/resource/cellar/214471fe-786e-11e9-9f05-01aa75ed71a1.0006.03/DOC_1#art_4

AI Act · 53 · Obligations for providers of general-purpose AI models
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_53

CJEU: SCHUFA and Dun & Bradstreet · Essential oral examples

Read: Operative rulings, then facts and reasoning in the full judgments

- SCHUFA: C-634/21, 7 December 2023, German credit scoring and decisive automated influence.
- Dun & Bradstreet Austria: C-203/22, 27 February 2025, meaningful information about automated decision logic and protected interests.
- Use the first for decision-making and the second for understandable information; do not merge their names, facts or dates.

CJEU judgments · C-634/21 • 7 December 2023 · SCHUFA
https://publications.europa.eu/resource/cellar/acd82fb9-94e3-11ee-b164-01aa75ed71a1.0010.05/DOC_1

CJEU judgments · C-203/22 • 27 February 2025 · Dun Bradstreet
https://publications.europa.eu/resource/cellar/44fa73b1-f4ef-11ef-b7db-01aa75ed71a1.0010.05/DOC_1

Application dates

25 May 2018 · GDPR applies

Personal-data safeguards already matter.

GDPR · 5 · Principles relating to processing of personal data
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_5

17 January 2025 · DORA applies

ICT risk and third-party governance are already relevant.

DORA · 64 · Entry into force and application
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_64

2 February 2025 · Original AI Act Chapters I and II begin applying

Read the amended Article 113 for exceptions added in 2026.

AI Act · 113 · Entry into force and application
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_113

2 August 2025 · GPAI and specified governance provisions begin applying

Existing-model transition in Article 111(3) may matter.

AI Act · 111 · AI systems already placed on the market or put into service and general-purpose AI models already placed on the marked
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_111

27 July 2026 · AI amendment enters into force

Use the consolidated text, not only the 2024 original.

AI Act · 113 · Entry into force and application
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_113

2 August 2026 · AI Act general application date

Includes Article 50, subject to specific exceptions/transitions.

AI Act · 50 · Transparency obligations for providers and deployers of certain AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_50

20 November 2026 · CCD2 national measures and relevant French changes apply

Scope and existing-credit transitional provisions matter.

French consumer credit · Ordonnance Art. 99 · Entry into force and transitional rules
https://www.legifrance.gouv.fr/jorf/id/JORFTEXT000052184230

2 December 2026 · Specific new AI Act prohibitions and synthetic-output transition

See Article 113(a) and Article 111(4); this is not the main chatbot-interaction date.

AI Act · 111 · AI systems already placed on the market or put into service and general-purpose AI models already placed on the marked
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_111

2 December 2027 · Annex III core high-risk provisions

Chapter III Sections 1–3, except Article 6(5); do not call this a delay of every AI Act provision.

AI Act · 113 · Entry into force and application
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_113

2 August 2028 · Annex I product-route core high-risk provisions

The corresponding Article 6(1) route has its own date.

AI Act · 113 · Entry into force and application
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_113

The bank project

The supplied banking LLM-as-a-service brief and your pasted legal discussion. Recommendations below are proposed positions for the exercise, not claims about controls already implemented.

Internal drafting / search · Conditional pilot

No automatic high-risk classification from using an LLM alone. Check whether the actual purpose falls into a regulated category.

- Approved data and access controls
- No unrestricted customer-data prompts or hidden employment monitoring
- AI-literacy support, source verification and escalation

AI Act · 3 · Definitions
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_3

AI Act · 4 · AI literacy
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_4

GDPR · 5 · Principles relating to processing of personal data
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_5

GDPR · 25 · Data protection by design and by default
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_25

Customer chatbot · Conditional release

AI interaction transparency plus privacy and consumer-facing reliability. Reclassify if the bot becomes part of a consequential assessment.

- Clear AI disclosure and bounded authority
- Verified knowledge sources and human escalation
- Logs, complaints and update testing

AI Act · 50 · Transparency obligations for providers and deployers of certain AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_50

GDPR · 13 · Information to be provided where personal data are collected from the data subject
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_13

GDPR · 32 · Security of processing
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_32

Consumer credit assessment · Hold production pending evidence

Annex III(5)(b), GDPR automated-decision safeguards and consumer-credit rights. The proposed hold is a governance decision, not a blanket legal ban on LLMs.

- Application-specific validation and discrimination assessment
- Lawful inputs, meaningful review and faithful explanations
- DPIA/FRIA planning, documented provider/deployer roles

AI Act · Annex III · High-risk AI systems referred to in Article 6(2)
https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3

AI Act · 25 · Responsibilities along the AI value chain
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_25

AI Act · 27 · Fundamental rights impact assessment for high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_27

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

Consumer credit · 18 · Obligation to assess the creditworthiness of the consumer
https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_18

Financial-fraud detection · Bounded pilot with safeguards

Excluded from Annex III(5)(b) specifically; assess the actual decision effects and any other relevant rule.

- Separate alerts from restrictions and final decisions
- Urgency-sensitive escalation, correction and review
- Monitor false positives and disproportionate effects

AI Act · Annex III · High-risk AI systems referred to in Article 6(2)
https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

DORA · 6 · ICT risk management framework
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_6

Workplace emotion inference · Exclude from the proposal

Article 5 prohibition has narrow medical/safety exceptions. Productivity or general monitoring is not a substitute for those conditions.

- Reject prohibited purpose
- Consider less intrusive employee support
- Consult employee representatives where required

AI Act · 5 · Prohibited AI practices
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_5

French labour law · L2312-8 · CSE: consultation / workplace technology
https://code.travail.gouv.fr/code-du-travail/l2312-8

Corrections when using lecture material

SCHUFA versus Dun & Bradstreet

Users slides p. 9 and transcript passages appear to conflate country, year or facts.

SCHUFA is the German 2023 scoring case. Dun & Bradstreet Austria is the 2025 explanation case. Preserve the lecture's human-review lesson while using the correct authorities.

CJEU judgments · C-634/21 • 7 December 2023 · SCHUFA
https://publications.europa.eu/resource/cellar/acd82fb9-94e3-11ee-b164-01aa75ed71a1.0010.05/DOC_1

CJEU judgments · C-203/22 • 27 February 2025 · Dun Bradstreet
https://publications.europa.eu/resource/cellar/44fa73b1-f4ef-11ef-b7db-01aa75ed71a1.0010.05/DOC_1

AI Act dates

The 2025 slides predate the 2026 amendment, and the introductory deck also contains shorthand dates.

Use the amended Article 113 and Article 111. Distinguish entry into force from application, and avoid saying all high-risk provisions are postponed together.

AI Act · 113 · Entry into force and application
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_113

AI Act · 111 · AI systems already placed on the market or put into service and general-purpose AI models already placed on the marked
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_111

Provider and deployer duties

High-risk requirements are compressed together in the regulation slides.

Articles 9–17 mainly concern system/provider requirements. Article 26 addresses deployers; Article 27 specifies FRIA triggers. Assign responsibility explicitly.

AI Act · 16 · Obligations of providers of high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_16

AI Act · 26 · Obligations of deployers of high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_26

AI Act · 27 · Fundamental rights impact assessment for high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_27

Open-source shorthand

The slide's GPAI exemption graphic can be read too broadly.

Read the precise conditions of Article 53(2). Do not treat every open-weight release as exempt or omit copyright/training-summary obligations.

AI Act · 53 · Obligations for providers of general-purpose AI models
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_53

Conformity assessment

Certification and CE marking can sound like universal external approval.

Credit scoring follows the Article 43(2) internal-control route. Independent assurance may be a recommended safeguard without being the prescribed notified-body route.

AI Act · 43 · Conformity assessment
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_43

Copyright jurisdictions

The slides compare US fair use and EU TDM.

Keep the frameworks separate. EU TDM exceptions have their own conditions, and an exam answer should not import an unconditional US-style slogan.

Copyright · 3 · Text and data mining for the purposes of scientific research
https://publications.europa.eu/resource/cellar/214471fe-786e-11e9-9f05-01aa75ed71a1.0006.03/DOC_1#art_3

Copyright · 4 · Exception or limitation for text and data mining
https://publications.europa.eu/resource/cellar/214471fe-786e-11e9-9f05-01aa75ed71a1.0006.03/DOC_1#art_4

Transcript reliability and exam scheduling

Recordings contain transcription uncertainty, informal discussion and conflicting administrative dates.

Use transcripts to understand explanations, slide pages for course concepts and official legal texts for rules. Confirm exam logistics from current course announcements rather than this study site.

Appendix: complete selected legal provisions

- The following entries reproduce complete selected articles, Annex III and the operative parts of the two judgments. They are not the complete text of every instrument.
- The companion official-law-compendium.pdf includes the complete instruments and full judgments.
- Article numbering, text and language are retained. Layout, line wrapping and consolidation markers can be normalised. Check the official PDFs for footnotes and formatting.
- French Labour Code provisions and the French transposition ordinance remain in official French.

Appendix index

AI Act · 2 · Scope

AI Act · 3 · Definitions

AI Act · 4 · AI literacy

AI Act · 4a · Processing of special categories of personal data for bias detection and correction

AI Act · 5 · Prohibited AI practices

AI Act · 6 · Classification rules for high-risk AI systems

AI Act · 9 · Risk management system

AI Act · 10 · Data and data governance

AI Act · 11 · Technical documentation

AI Act · 12 · Record-keeping

AI Act · 13 · Transparency and provision of information to deployers

AI Act · 14 · Human oversight

AI Act · 15 · Accuracy, robustness and cybersecurity

AI Act · 16 · Obligations of providers of high-risk AI systems

AI Act · 17 · Quality management system

AI Act · 25 · Responsibilities along the AI value chain

AI Act · 26 · Obligations of deployers of high-risk AI systems

AI Act · 27 · Fundamental rights impact assessment for high-risk AI systems

AI Act · 40 · Harmonised standards and standardisation deliverables

AI Act · 43 · Conformity assessment

AI Act · 47 · EU declaration of conformity

AI Act · 48 · CE marking

AI Act · 49 · Registration

AI Act · 50 · Transparency obligations for providers and deployers of certain AI systems

AI Act · 51 · Classification of general-purpose AI models as general-purpose AI models with systemic risk

AI Act · 53 · Obligations for providers of general-purpose AI models

AI Act · 55 · Obligations of providers of general-purpose AI models with systemic risk

AI Act · 72 · Post-market monitoring by providers and post-market monitoring plan for high-risk AI systems

AI Act · 73 · Reporting of serious incidents

AI Act · 85 · Right to lodge a complaint with a market surveillance authority

AI Act · 86 · Right to explanation of individual decision-making

AI Act · 99 · Penalties

AI Act · 111 · AI systems already placed on the market or put into service and general-purpose AI models already placed on the marked

AI Act · 113 · Entry into force and application

GDPR · 2 · Material scope

GDPR · 3 · Territorial scope

GDPR · 4 · Definitions

GDPR · 5 · Principles relating to processing of personal data

GDPR · 6 · Lawfulness of processing

GDPR · 7 · Conditions for consent

GDPR · 9 · Processing of special categories of personal data

GDPR · 12 · Transparent information, communication and modalities for the exercise of the rights of the data subject

GDPR · 13 · Information to be provided where personal data are collected from the data subject

GDPR · 14 · Information to be provided where personal data have not been obtained from the data subject

GDPR · 15 · Right of access by the data subject

GDPR · 16 · Right to rectification

GDPR · 17 · Right to erasure (‘right to be forgotten’)

GDPR · 18 · Right to restriction of processing

GDPR · 21 · Right to object

GDPR · 22 · Automated individual decision-making, including profiling

GDPR · 24 · Responsibility of the controller

GDPR · 25 · Data protection by design and by default

GDPR · 28 · Processor

GDPR · 30 · Records of processing activities

GDPR · 32 · Security of processing

GDPR · 33 · Notification of a personal data breach to the supervisory authority

GDPR · 34 · Communication of a personal data breach to the data subject

GDPR · 35 · Data protection impact assessment

GDPR · 36 · Prior consultation

GDPR · 37 · Designation of the data protection officer

GDPR · 38 · Position of the data protection officer

GDPR · 39 · Tasks of the data protection officer

GDPR · 44 · General principle for transfers

GDPR · 45 · Transfers on the basis of an adequacy decision

GDPR · 46 · Transfers subject to appropriate safeguards

GDPR · 48 · Transfers or disclosures not authorised by Union law

GDPR · 49 · Derogations for specific situations

GDPR · 77 · Right to lodge a complaint with a supervisory authority

GDPR · 79 · Right to an effective judicial remedy against a controller or processor

GDPR · 82 · Right to compensation and liability

GDPR · 83 · General conditions for imposing administrative fines

Consumer credit · 2 · Scope

Consumer credit · 3 · Definitions

Consumer credit · 6 · Non-discrimination

Consumer credit · 18 · Obligation to assess the creditworthiness of the consumer

Consumer credit · 19 · Databases

Consumer credit · 47 · Repeal and transitional provisions

Consumer credit · 48 · Transposition

DORA · 2 · Scope

DORA · 3 · Definitions

DORA · 4 · Proportionality principle

DORA · 5 · Governance and organisation

DORA · 6 · ICT risk management framework

DORA · 17 · ICT-related incident management process

DORA · 19 · Reporting of major ICT-related incidents and voluntary notification of significant cyber threats

DORA · 24 · General requirements for the performance of digital operational resilience testing

DORA · 28 · General principles

DORA · 29 · Preliminary assessment of ICT concentration risk at entity level

DORA · 30 · Key contractual provisions

DORA · 64 · Entry into force and application

Copyright · 2 · Definitions

Copyright · 3 · Text and data mining for the purposes of scientific research

Copyright · 4 · Exception or limitation for text and data mining

Copyright · 7 · Common provisions

AI Act · Annex III · High-risk AI systems referred to in Article 6(2)

French labour law · L2312-8 · CSE: consultation / workplace technology

French labour law · L2312-14 · CSE: consultation / workplace technology

French labour law · L2312-38 · CSE: consultation / workplace technology

French consumer credit · Ordonnance Art. 19 · Replacement of Consumer Code Article L312-16

French consumer credit · Ordonnance Art. 99 · Entry into force and transitional rules

CJEU judgments · C-634/21 • 7 December 2023 · SCHUFA

CJEU judgments · C-203/22 • 27 February 2025 · Dun Bradstreet

AI Act · 2

Scope

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_2

Article 2

Scope

1.

This Regulation applies to:

(a)

providers placing on the market or putting into service AI systems or placing on the market general-purpose AI models in the Union, irrespective of whether those providers are established or located within the Union or in a third country;

(b)

deployers of AI systems that have their place of establishment or are located within the Union;

(c)

providers and deployers of AI systems that have their place of establishment or are located in a third country, where the output produced by the AI system is used in the Union;

(d)

importers and distributors of AI systems;

(e)

product manufacturers placing on the market or putting into service an AI system together with their product and under their own name or trademark;

(f)

authorised representatives of providers, which are not established in the Union;

(g)

affected persons that are located in the Union.

2.

For AI systems classified as high-risk AI systems in accordance with Article 6(1) related to products covered by the Union harmonisation legislation listed in Section B of Annex I, only Article 6(1), Article 60a and Articles 102 to 112 shall apply. Articles 57, 58 and 59 shall apply only in so far as the requirements for high-risk AI systems under this Regulation have been integrated in that Union harmonisation legislation.

3.

This Regulation does not apply to areas outside the scope of Union law, and shall not, in any event, affect the competences of the Member States concerning national security, regardless of the type of entity entrusted by the Member States with carrying out tasks in relation to those competences.

This Regulation does not apply to AI systems where and in so far they are placed on the market, put into service, or used with or without modification exclusively for military, defence or national security purposes, regardless of the type of entity carrying out those activities.

This Regulation does not apply to AI systems which are not placed on the market or put into service in the Union, where the output is used in the Union exclusively for military, defence or national security purposes, regardless of the type of entity carrying out those activities.

4.

This Regulation applies neither to public authorities in a third country nor to international organisations falling within the scope of this Regulation pursuant to paragraph 1, where those authorities or organisations use AI systems in the framework of international cooperation or agreements for law enforcement and judicial cooperation with the Union or with one or more Member States, provided that such a third country or international organisation provides adequate

safeguards with respect to the protection of fundamental rights and freedoms of individuals.

5.

This Regulation shall not affect the application of the provisions on the liability of providers of intermediary services as set out in Chapter II of Regulation (EU) 2022/2065.

6.

This Regulation does not apply to AI systems or AI models, including their output, specifically developed and put into service for the sole purpose of scientific research and development.

7.

Union law on the protection of personal data, privacy and the confidentiality of communications applies to personal data processed in connection with the rights and obligations laid down in this Regulation. Without prejudice to Articles 4a and 59 of this Regulation, this Regulation shall not affect Regulation (EU) 2016/679 or (EU) 2018/1725, or Directive 2002/58/EC or (EU) 2016/680.

8.

This Regulation does not apply to any research, testing or development activity regarding AI systems or AI models prior to their being placed on the market or put into service. Such activities shall be conducted in accordance with applicable Union law. Testing in real world conditions shall not be covered by that exclusion.

9.

This Regulation is without prejudice to the rules laid down by other Union legal acts related to consumer protection and product safety.

10.

This Regulation does not apply to obligations of deployers who are natural persons using AI systems in the course of a purely personal non-professional activity.

11.

This Regulation does not preclude the Union or Member States from maintaining or introducing laws, regulations or administrative provisions which are more favourable to workers in terms of protecting their rights in respect of the use of AI systems by employers, or from encouraging or allowing the application of collective agreements which are more favourable to workers.

12.

This Regulation does not apply to AI systems released under free and open-source licences, unless they are placed on the market or put into service as high-risk AI systems or as an AI system that falls under Article 5 or 50.

13.

For high-risk AI systems referred to in Article 6(1), the application of specific requirements or obligations laid down in Articles 9 to 15 and 17 to 25 may be limited, where and to the extent that:

(a)

Union harmonisation legislation listed in Section A of Annex I lays down requirements or obligations providing an equivalent or higher level of protection of health, safety or fundamental rights as the requirement or obligation concerned; and

(b)

such limitation does not reduce the overall level of protection provided for by this Regulation.

By 2 August 2027, the Commission shall adopt delegated acts in accordance with Article 97 in order to supplement this Regulation by specifying the high-risk AI systems concerned, the requirements or obligations that may be limited, the conditions under which such limitation applies, and the scope of the limitation.

AI Act · 3

Definitions

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_3

Article 3

Definitions

For the purposes of this Regulation, the following definitions apply:

(1)

‘AI system’ means a machine-based system that is designed to operate with varying levels of autonomy and that may exhibit adaptiveness after deployment, and that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments;

(2)

‘risk’ means the combination of the probability of an occurrence of harm and the severity of that harm;

(3)

‘provider’ means a natural or legal person, public authority, agency or other body that develops an AI system or a general-purpose AI model or that has an AI system or a general-purpose AI model developed and places it on the market or puts the AI system into service under its own name or trademark, whether for payment or free of charge;

(4)

‘deployer’ means a natural or legal person, public authority, agency or other body using an AI system under its authority except where the AI system is used in the course of a personal non-professional activity;

(5)

‘authorised representative’ means a natural or legal person located or established in the Union who has received and accepted a written mandate from a provider of an AI system or a general-purpose AI model to, respectively, perform and carry out on its behalf the obligations and procedures established by this Regulation;

(6)

‘importer’ means a natural or legal person located or established in the Union that places on the market an AI system that bears the name or trademark of a natural or legal person established in a third country;

(7)

‘distributor’ means a natural or legal person in the supply chain, other than the provider or the importer, that makes an AI system available on the Union market;

(8)

‘operator’ means a provider, product manufacturer, deployer, authorised representative, importer or distributor;

(9)

‘placing on the market’ means the first making available of an AI system or a general-purpose AI model on the Union market;

(10)

‘making available on the market’ means the supply of an AI system or a general-purpose AI model for distribution or use on the Union market in the course of a commercial activity, whether in return for payment or free of charge;

(11)

‘putting into service’ means the supply of an AI system for first use directly to the deployer or for own use in the Union for its intended purpose;

(12)

‘intended purpose’ means the use for which an AI system is intended by the provider, including the specific context and conditions of use, as specified in the information supplied by the provider in the instructions for use, promotional or sales materials and statements, as well as in the technical documentation;

(13)

‘reasonably foreseeable misuse’ means the use of an AI system in a way that is not in accordance with its intended purpose, but which may result from reasonably foreseeable human behaviour or interaction with other systems, including other AI systems;

(14)

‘safety component’ means a component of a product or of an AI system which fulfils a safety function for that product or AI system, or the failure or malfunctioning of which endangers the health and safety of persons or property; for the purposes of this definition, a component fulfils a safety function where its intended purpose is to prevent or mitigate risks to health and safety of persons or property;

(14a)

‘micro, small and medium-sized enterprise’ or ‘SME’ means a micro, small or medium-sized enterprise as defined in Article 2 of the Annex to Recommendation 2003/361/EC;

(14b)

‘small mid-cap enterprise’ or ‘SMC’ means a small mid-cap enterprise as defined in point (2) of the Annex to Recommendation (EU) 2025/1099;

(15)

‘instructions for use’ means the information provided by the provider to inform the deployer of, in particular, an AI system’s intended purpose and proper use;

(16)

‘recall of an AI system’ means any measure aiming to achieve the return to the provider or taking out of service or disabling the use of an AI system made available to deployers;

(17)

‘withdrawal of an AI system’ means any measure aiming to prevent an AI system in the supply chain being made available on the market;

(18)

‘performance of an AI system’ means the ability of an AI system to achieve its intended purpose;

(19)

‘notifying authority’ means the national authority responsible for setting up and carrying out the necessary procedures for the assessment, designation and notification of conformity assessment bodies and for their monitoring;

(20)

‘conformity assessment’ means the process of demonstrating whether the requirements set out in Chapter III, Section 2 relating to a high-risk AI system have been fulfilled;

(21)

‘conformity assessment body’ means a body that performs third-party conformity assessment activities, including testing, certification and inspection;

(22)

‘notified body’ means a conformity assessment body notified in accordance with this Regulation and other relevant Union harmonisation legislation;

(23)

‘substantial modification’ means a change to an AI system after its placing on the market or putting into service which is not foreseen or planned in the initial conformity assessment carried out by the provider and as a result of which the compliance of the AI system with the requirements set out in Chapter III, Section 2 is affected or results in a modification to the intended purpose for which the AI system has been assessed;

(24)

‘CE marking’ means a marking by which a provider indicates that an AI system is in conformity with the requirements set out in Chapter III, Section 2 and other applicable Union harmonisation legislation providing for its affixing;

(25)

‘post-market monitoring system’ means all activities carried out by providers of AI systems to collect and review experience gained from the use of AI systems they place on the market or put into service for the purpose of identifying any need to immediately apply any necessary corrective or preventive actions;

(26)

‘market surveillance authority’ means the national authority carrying out the activities and taking the measures pursuant to Regulation (EU) 2019/1020;

(27)

‘harmonised standard’ means a harmonised standard as defined in Article 2(1), point (c), of Regulation (EU) No 1025/2012;

(28)

‘common specification’ means a set of technical specifications as defined in Article 2, point (4) of Regulation (EU) No 1025/2012, providing means to comply with certain requirements established under this Regulation;

(29)

‘training data’ means data used for training an AI system through fitting its learnable parameters;

(30)

‘validation data’ means data used for providing an evaluation of the trained AI system and for tuning its non-learnable parameters and its learning process in order, inter alia, to prevent underfitting or overfitting;

(31)

‘validation data set’ means a separate data set or part of the training data set, either as a fixed or variable split;

(32)

‘testing data’ means data used for providing an independent evaluation of the AI system in order to confirm the expected performance of that system before its placing on the market or putting into service;

(33)

‘input data’ means data provided to or directly acquired by an AI system on the basis of which the system produces an output;

(34)

‘biometric data’ means personal data resulting from specific technical processing relating to the physical, physiological or behavioural characteristics of a natural person, such as facial images or dactyloscopic data;

(35)

‘biometric identification’ means the automated recognition of physical, physiological, behavioural, or psychological human features for the purpose of establishing the identity of a natural person by comparing biometric data of that individual to biometric data of individuals stored in a database;

(36)

‘biometric verification’ means the automated, one-to-one verification, including authentication, of the identity of natural persons by comparing their biometric data to previously provided biometric data;

(37)

‘special categories of personal data’ means the categories of personal data referred to in Article 9(1) of Regulation (EU) 2016/679, Article 10 of Directive (EU) 2016/680 and Article 10(1) of Regulation (EU) 2018/1725;

(38)

‘sensitive operational data’ means operational data related to activities of prevention, detection, investigation or prosecution of criminal offences, the disclosure of which could jeopardise the integrity of criminal proceedings;

(39)

‘emotion recognition system’ means an AI system for the purpose of identifying or inferring emotions or intentions of natural persons on the basis of their biometric data;

(40)

‘biometric categorisation system’ means an AI system for the purpose of assigning natural persons to specific categories on the basis of their biometric data, unless it is ancillary to another commercial service and strictly necessary for objective technical reasons;

(41)

‘remote biometric identification system’ means an AI system for the purpose of identifying natural persons, without their active involvement, typically at a distance through the comparison of a person’s biometric data with the biometric data contained in a reference database;

(42)

‘real-time remote biometric identification system’ means a remote biometric identification system, whereby the capturing of biometric data, the comparison and the identification all occur without a significant delay, comprising not only instant identification, but also limited short delays in order to avoid circumvention;

(43)

‘post-remote biometric identification system’ means a remote biometric identification system other than a real-time remote biometric identification system;

(44)

‘publicly accessible space’ means any publicly or privately owned physical place accessible to an undetermined number of natural persons, regardless of whether certain conditions for access may apply, and regardless of the potential capacity restrictions;

(45)

‘law enforcement authority’ means:

(a)

any public authority competent for the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security; or

(b)

any other body or entity entrusted by Member State law to exercise public authority and public powers for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security;

(46)

‘law enforcement’ means activities carried out by law enforcement authorities or on their behalf for the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including safeguarding against and preventing threats to public security;

(47)

‘AI Office’ means the Commission’s function of contributing to the implementation, monitoring and supervision of AI systems and general-purpose AI models, and AI governance, provided for in Commission Decision of 24 January 2024; references in this Regulation to the AI Office shall be construed as references to the Commission;

(48)

‘national competent authority’ means a notifying authority or a market surveillance authority; as regards AI systems put into service or used by Union institutions, agencies, offices and bodies, references to national competent authorities or market surveillance authorities in this Regulation shall be construed as references to the European Data Protection Supervisor;

(49)

‘serious incident’ means an incident or malfunctioning of an AI system that directly or indirectly leads to any of the following:

(a)

the death of a person, or serious harm to a person’s health;

(b)

a serious and irreversible disruption of the management or operation of critical infrastructure;

(c)

the infringement of obligations under Union law intended to protect fundamental rights;

(d)

serious harm to property or the environment;

(50)

‘personal data’ means personal data as defined in Article 4, point (1), of Regulation (EU) 2016/679;

(51)

‘non-personal data’ means data other than personal data as defined in Article 4, point (1), of Regulation (EU) 2016/679;

(52)

‘profiling’ means profiling as defined in Article 4, point (4), of Regulation (EU) 2016/679;

(53)

‘real-world testing plan’ means a document that describes the objectives, methodology, geographical, population and temporal scope, monitoring, organisation and conduct of testing in real-world conditions;

(54)

‘sandbox plan’ means a document agreed between the participating provider and the competent authority describing the objectives, conditions, timeframe, methodology and requirements for the activities carried out within the sandbox;

(55)

‘AI regulatory sandbox’ means a controlled framework set up by a competent authority which offers providers or prospective providers of AI systems the possibility to develop, train, validate and test, where appropriate in real-world conditions, an innovative AI system, pursuant to a sandbox plan for a limited time under regulatory supervision;

(56)

‘AI literacy’ means skills, knowledge and understanding that allow providers, deployers and affected persons, taking into account their respective rights and obligations in the context of this Regulation, to make an informed deployment of AI systems, as well as to gain awareness about the opportunities and risks of AI and possible harm it can cause;

(57)

‘testing in real-world conditions’ means the temporary testing of an AI system for its intended purpose in real-world conditions outside a laboratory or otherwise simulated environment, with a view to gathering reliable and robust data and to assessing and verifying the conformity of the AI system with the requirements of this Regulation and it does not qualify as placing the AI system on the market or putting it into service within the meaning of this Regulation, provided that all the conditions laid down in Article 57 or 60 are fulfilled;

(58)

‘subject’, for the purpose of real-world testing, means a natural person who participates in testing in real-world conditions;

(59)

‘informed consent’ means a subject’s freely given, specific, unambiguous and voluntary expression of his or her willingness to participate in a particular testing in real-world conditions, after having been informed of all aspects of the testing that are relevant to the subject’s decision to participate;

(60)

‘deep fake’ means AI-generated or manipulated image, audio or video content that resembles existing persons, objects, places, entities or events and would falsely appear to a person to be authentic or truthful;

(61)

‘widespread infringement’ means any act or omission contrary to Union law protecting the interest of individuals, which:

(a)

has harmed or is likely to harm the collective interests of individuals residing in at least two Member States other than the Member State in which:

(i)

the act or omission originated or took place;

(ii)

the provider concerned, or, where applicable, its authorised representative is located or established; or

(iii)

the deployer is established, when the infringement is committed by the deployer;

(b)

has caused, causes or is likely to cause harm to the collective interests of individuals and has common features, including the same unlawful practice or the same interest being infringed, and is occurring concurrently, committed by the same operator, in at least three Member States;

(62)

'critical infrastructure' means critical infrastructure as defined in Article 2, point (4), of Directive (EU) 2022/2557;

(63)

'general-purpose AI model' means an AI model, including where such an AI model is trained with a large amount of data using self-supervision at scale, that displays significant generality and is capable of competently performing a wide range of distinct tasks regardless of the way the model is placed on the market and that can be integrated into a variety of downstream systems or applications, except AI models that are used for research, development or prototyping activities before they are placed on the market;

(64)

'high-impact capabilities' means capabilities that match or exceed the capabilities recorded in the most advanced general-purpose AI models;

(65)

'systemic risk' means a risk that is specific to the high-impact capabilities of general-purpose AI models, having a significant impact on the Union market due to their reach, or due to actual or reasonably foreseeable negative effects on public health, safety, public security, fundamental rights, or the society as a whole, that can be propagated at scale across the value chain;

(66)

'general-purpose AI system' means an AI system which is based on a general-purpose AI model and which has the capability to serve a variety of purposes, both for direct use as well as for integration in other AI systems;

(67)

'floating-point operation' means any mathematical operation or assignment involving floating-point numbers, which are a subset of the real numbers typically represented on computers by an integer of fixed precision scaled by an integer exponent of a fixed base;

(68)

'downstream provider' means a provider of an AI system, including a general-purpose AI system, which integrates an AI model, regardless of whether the AI model is provided by themselves and vertically integrated or provided by another entity based on contractual relations.

AI Act · 4

AI literacy

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_4

Article 4

AI literacy

1.

Providers and deployers of AI systems shall take measures to support the development of AI literacy of their staff and other persons dealing with the operation and use of AI systems on their behalf, taking into account their technical knowledge, experience, education and training and the context the AI systems are to be used in, and considering the persons or groups of persons on whom the AI systems are to be used. This obligation does not require providers or deployers to guarantee any specific level of AI literacy of any individual.

2.

The Commission and the Member States shall support and facilitate the efforts of providers and deployers of AI systems, in particular SMEs, in fulfilling their obligation under paragraph 1 of this Article. For that purpose, the Commission shall publish practical examples of how to comply with that obligation on the single information platform referred to in Article 62(3), point (b).

3.

The Board shall adopt recommendations, taking into account European competence frameworks, to support the Commission and Member States in the promotion of AI literacy required under paragraph 1, including by setting out common objectives.

AI Act · 4a

Processing of special categories of personal data for bias detection and correction

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_4a

Article 4a

Processing of special categories of personal data for bias detection and correction

1.

To the extent strictly necessary to ensure bias detection and correction in relation to high-risk AI systems in accordance with Article 10(2), points (f) and (g), of this Regulation, providers of such systems may exceptionally process special categories of personal data, subject to appropriate safeguards for the fundamental rights and freedoms of natural persons. In addition to the provisions set out in Regulations (EU) 2016/679 and (EU) 2018/1725 and Directive (EU) 2016/680, as applicable, all the following conditions shall be met in order for such processing to occur:

(a)

the bias detection and correction cannot be effectively fulfilled by processing other data, including synthetic or anonymised data;

(b)

the special categories of personal data are subject to technical limitations on the re-use of personal data, and state-of-the-art security and privacy-preserving measures, including pseudonymisation;

(c)

the special categories of personal data are subject to measures to ensure that the personal data processed are secured and protected, subject to suitable safeguards, including strict controls and documentation of the access, to avoid misuse and to ensure that only authorised persons have access to those personal data with appropriate confidentiality obligations;

(d)

the special categories of personal data are not transmitted, transferred or otherwise accessed by other parties;

(e)

the special categories of personal data are deleted once the bias has been corrected or the personal data has reached the end of its retention period, whichever comes first; and

(f)

the records of processing activities pursuant to Regulations (EU) 2016/679 and (EU) 2018/1725 and Directive (EU) 2016/680 include the reasons why the processing of special categories of personal data was strictly necessary to detect and correct biases, and why that objective could not be achieved by processing other data.

2.

Providers and deployers of other AI systems and models and deployers of high-risk AI systems may exceptionally process special categories of personal data to the extent that:

(a)

such processing is strictly necessary to ensure bias detection and correction in view of possible biases that are likely to affect the health and safety of persons, have a negative impact on fundamental rights or lead to discrimination prohibited pursuant to Union law, especially where data outputs influence inputs for future operations; and

(b)

all of the conditions and safeguards set out in paragraph 1 are applied.

This paragraph does not create any obligation to conduct such bias detection and correction.

AI Act · 5

Prohibited AI practices

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_5

Article 5

Prohibited AI practices

1.

The following AI practices shall be prohibited:

(a)

the placing on the market, the putting into service or the use of an AI system that deploys subliminal techniques beyond a person's consciousness or purposefully manipulative or deceptive techniques, with the objective, or the effect of materially distorting the behaviour of a person or a group of persons by appreciably impairing their ability to make an informed decision, thereby causing them to take a decision that they would not have otherwise taken in a manner that causes or is reasonably likely to cause that person, another person or group of persons significant harm;

(b)

the placing on the market, the putting into service or the use of an AI system that exploits any of the vulnerabilities of a natural person or a specific group of persons due to their age, disability or a specific social or economic situation, with the objective, or the effect, of materially distorting the behaviour of that person or a person belonging to that group in a manner that causes or is reasonably likely to cause that person or another person significant harm;

(ba)

the placing on the market, the putting into service or the use of an AI system that generates or manipulates realistic images, videos, audio or similar material of an identifiable natural person's intimate parts, or of an identifiable natural person engaged in sexually explicit activities, without that person's freely-given, specific, informed, unambiguous and explicit consent for that generation or manipulation;

(bb)

the placing on the market, the putting into service or the use of an AI system that generates or manipulates material or performance within the meaning of Article 2, points (c) and (e), of Directive 2011/93/EU, except where a 'without right' defence applies under national law;

(c)

the placing on the market, the putting into service or the use of AI systems for the evaluation or classification of natural persons or groups of persons over a certain period of time based on their social behaviour or known, inferred or predicted personal or personality characteristics, with the social score leading to either or both of the following:

(i)

detrimental or unfavourable treatment of certain natural persons or groups of persons in social contexts that are unrelated to the contexts in which the data was originally generated or collected;

(ii)

detrimental or unfavourable treatment of certain natural persons or groups of persons that is unjustified or disproportionate to their social behaviour or its gravity;

(d)

the placing on the market, the putting into service for this specific purpose, or the use of an AI system for making risk assessments of natural persons in order to assess or predict the risk of a natural person committing a criminal offence, based solely on the profiling of a natural person or on assessing their personality traits and characteristics; this prohibition shall not apply to AI systems used to support the human assessment of the involvement of a person in a criminal activity, which is already based on objective and verifiable facts directly linked to a criminal activity;

(e)

the placing on the market, the putting into service for this specific purpose, or the use of AI systems that create or expand facial recognition databases through the untargeted scraping of facial images from the internet or CCTV footage;

(f)

the placing on the market, the putting into service for this specific purpose, or the use of AI systems to infer emotions of a natural person in the areas of workplace and education institutions, except where the use of the AI system is intended to be put in place or into the market for medical or safety reasons;

(g)

the placing on the market, the putting into service for this specific purpose, or the use of biometric categorisation systems that categorise individually natural persons based on their biometric data to deduce or infer their race, political opinions, trade union membership, religious or philosophical beliefs, sex life or sexual orientation; this prohibition does not cover any labelling or filtering of lawfully acquired biometric datasets, such as images, based on biometric data or categorizing of biometric data in the area of law enforcement;

(h)

the use of 'real-time' remote biometric identification systems in publicly accessible spaces for the purposes of law enforcement, unless and in so far as such use is strictly necessary for one of the following objectives:

(i)

the targeted search for specific victims of abduction, trafficking in human beings or sexual exploitation of human beings, as well as the search for missing persons;

(ii)

the prevention of a specific, substantial and imminent threat to the life or physical safety of natural persons or a genuine and present or genuine and foreseeable threat of a terrorist attack;

(iii)

the localisation or identification of a person suspected of having committed a criminal offence, for the purpose of conducting a criminal investigation or prosecution or executing a criminal penalty for offences referred to in Annex II and punishable in the Member State concerned by a custodial sentence or a detention order for a maximum period of at least four years.

Point (h) of the first subparagraph is without prejudice to Article 9 of Regulation (EU) 2016/679 for the processing of biometric data for purposes other than law enforcement.

1a.

For the purposes of paragraph 1, first subparagraph, points (ba) and (bb):

(a)

the placing on the market or putting into service of an AI system that generates or manipulates the material or performance referred to in paragraph 1, first subparagraph, point (ba) or (bb) is only prohibited where:

(i)

that generation or manipulation is the intended purpose of the AI system; or

(ii)

the system's design, training, architecture, capabilities or user-facing functionalities make that generation or manipulation a reasonably foreseeable and reproducible outcome, without requiring significant technical modification, and the system does not have reasonable and adequate technical safety measures and other safeguards to reliably prevent that generation or manipulation, taking into account reasonably foreseeable misuse, and to correct observed or reported misuse;

(b)

the use of an AI system that generates or manipulates the material or performance referred to in paragraph 1, first subparagraph, points (ba) and (bb) is only prohibited where the deployer uses the system for the purpose of generating or manipulating such material or performance.

1b.

For the purposes of paragraph 1, first subparagraph, point (ba), an AI system that manipulates material in a way that does not increase the exposure of any depicted intimate parts or alter the nature of any depicted sexually explicit activities shall not constitute manipulation.

2.

The use of ‘real-time’ remote biometric identification systems in publicly accessible spaces for the purposes of law enforcement for any of the objectives referred to in paragraph 1, first subparagraph, point (h), shall be deployed for the purposes set out in that point only to confirm the identity of the specifically targeted individual, and it shall take into account the following elements:

(a)

the nature of the situation giving rise to the possible use, in particular the seriousness, probability and scale of the harm that would be caused if the system were not used;

(b)

the consequences of the use of the system for the rights and freedoms of all persons concerned, in particular the seriousness, probability and scale of those consequences.

In addition, the use of ‘real-time’ remote biometric identification systems in publicly accessible spaces for the purposes of law enforcement for any of the objectives referred to in paragraph 1, first subparagraph, point (h), of this Article shall comply with necessary and proportionate safeguards and conditions in relation to the use in accordance with the national law authorising the use thereof, in particular as regards the temporal, geographic and personal limitations. The use of the ‘real-time’ remote biometric identification system in publicly accessible spaces shall be authorised only if the law enforcement authority has completed a fundamental rights impact assessment as provided for in Article 27 and has registered the system in the EU database according to Article 49. However, in duly justified cases of urgency, the use of such systems may be commenced without the registration in the EU database, provided that such registration is completed without undue delay.

3.

For the purposes of paragraph 1, first subparagraph, point (h) and paragraph 2, each use for the purposes of law enforcement of a ‘real-time’ remote biometric identification system in publicly accessible spaces shall be subject to a prior authorisation granted by a judicial authority or an independent administrative authority whose decision is binding of the Member State in which the use is to take place, issued upon a reasoned request and in accordance with the detailed rules of national law referred to in paragraph 5. However, in a duly justified situation of urgency, the use of such system may be commenced without an authorisation provided that such authorisation is requested without undue delay, at the latest within 24 hours. If such authorisation is rejected, the use shall be stopped with immediate effect and all the data, as well as the results and outputs of that use shall be immediately discarded and deleted.

The competent judicial authority or an independent administrative authority whose decision is binding shall grant the authorisation only where it is satisfied, on the basis of objective evidence or clear indications presented to it, that the use of the ‘real-time’ remote biometric identification system concerned is necessary for, and proportionate to, achieving one of the objectives specified in paragraph 1, first subparagraph, point (h), as identified in the request and, in particular, remains limited to what is strictly necessary concerning the period of time as well as the geographic and personal scope. In deciding on the request, that authority shall take into account the elements referred to in paragraph 2. No decision that produces an adverse legal effect on a person may be taken based solely on the output of the ‘real-time’ remote biometric identification system.

4.

Without prejudice to paragraph 3, each use of a ‘real-time’ remote biometric identification system in publicly accessible spaces for law enforcement purposes shall be notified to the relevant market surveillance authority and the national data protection authority in accordance with the national rules referred to in paragraph 5. The notification shall, as a minimum, contain the information specified under paragraph 6 and shall not include sensitive operational data.

5.

A Member State may decide to provide for the possibility to fully or partially authorise the use of ‘real-time’ remote biometric identification systems in publicly accessible spaces for the purposes of law enforcement within the limits and under the conditions listed in paragraph 1, first subparagraph, point (h), and paragraphs 2 and 3. Member States concerned shall lay down in their national law the necessary detailed rules for the request, issuance and exercise of, as well as supervision and reporting relating to, the authorisations referred to in paragraph 3. Those rules shall also specify in respect of which of the objectives listed in paragraph 1, first subparagraph, point (h), including which of the criminal offences referred to in point (h)(iii) thereof, the competent authorities may be authorised to use those systems for the purposes of law enforcement. Member States shall notify those rules to the Commission at the latest 30 days following the adoption thereof. Member States may introduce, in accordance with Union law, more restrictive laws on the use of remote biometric identification systems.

6.

National market surveillance authorities and the national data protection authorities of Member States that have been notified of the use of 'real-time' remote biometric identification systems in publicly accessible spaces for law enforcement purposes pursuant to paragraph 4 shall submit to the Commission annual reports on such use. For that purpose, the Commission shall provide Member States and national market surveillance and data protection authorities with a template, including information on the number of the decisions taken by competent judicial authorities or an independent administrative authority whose decision is binding upon requests for authorisations in accordance with paragraph 3 and their result.

7.

The Commission shall publish annual reports on the use of real-time remote biometric identification systems in publicly accessible spaces for law enforcement purposes, based on aggregated data in Member States on the basis of the annual reports referred to in paragraph 6. Those annual reports shall not include sensitive operational data of the related law enforcement activities.

8.

This Article shall not affect the prohibitions that apply where an AI practice infringes other Union law.

AI Act · 6

Classification rules for high-risk AI systems

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_6

Article 6

Classification rules for high-risk AI systems

1.

Irrespective of whether an AI system is placed on the market or put into service independently of the products referred to in points (a) and (b), that AI system shall be considered to be high-risk where both of the following conditions are fulfilled:

(a)

the AI system is intended to be used as a safety component of a product, or the AI system is itself a product, covered by the Union harmonisation legislation listed in Annex I;

(b)

the product whose safety component pursuant to point (a) is the AI system, or the AI system itself as a product, is required to undergo a third-party conformity assessment, with a view to the placing on the market or the putting into service of that product pursuant to the Union harmonisation legislation listed in Annex I.

1a.

For the purposes of this Regulation, including paragraph 1 of this Article, AI systems that are solely used for non-safety related aspects of user assistance, performance optimisation, service efficiency, automation or convenience or quality control shall not qualify as safety components.

1b.

Notwithstanding paragraph 1a, AI systems the failure or malfunctioning of which would endanger health and safety shall qualify as safety components.

1c.

A product that is required to undergo a third-party conformity assessment solely due to risks other than risks to health and safety, in particular risks relating to the distribution of radio spectrum or electromagnetic interference that do not affect health and safety, shall not be considered as fulfilling the condition in paragraph 1, point (b).

2.

In addition to the high-risk AI systems referred to in paragraph 1, AI systems referred to in Annex III shall be considered to be high-risk.

3.

By derogation from paragraph 2, an AI system referred to in Annex III shall not be considered to be high-risk where it does not pose a significant risk of harm to the health, safety or fundamental rights of natural persons, including by not materially influencing the outcome of decision making.

The first subparagraph shall apply where any of the following conditions is fulfilled:

(a)

the AI system is intended to perform a narrow procedural task;

(b)

the AI system is intended to improve the result of a previously completed human activity;

(c)

the AI system is intended to detect decision-making patterns or deviations from prior decision-making patterns and is not meant to replace or influence the previously completed human assessment, without proper human review; or

(d)

the AI system is intended to perform a preparatory task to an assessment relevant for the purposes of the use cases listed in Annex III.

Notwithstanding the first subparagraph, an AI system referred to in Annex III shall always be considered to be high-risk where the AI system performs profiling of natural persons.

4.

A provider who considers that an AI system referred to in Annex III is not high-risk shall document its assessment before that system is placed on the market or put into service. Such provider shall be subject to the registration obligation set out in Article 49(2). Upon request of national competent authorities, the provider shall provide the documentation of the assessment.

5.

The Commission shall, after consulting the European Artificial Intelligence Board (the 'Board'), and no later than 2 February 2026, provide guidelines specifying the practical implementation of this Article in line with Article 96 together with a comprehensive list of practical examples of use cases of AI systems that are high-risk and not high-risk.

6.

The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend paragraph 3, second subparagraph, of this Article by adding new conditions to those laid down therein, or by modifying them, where there is concrete and reliable evidence of the existence of AI systems that fall under the scope of Annex III, but do not pose a significant risk of harm to the health, safety or fundamental rights of natural persons.

7.

The Commission shall adopt delegated acts in accordance with Article 97 in order to amend paragraph 3, second subparagraph, of this Article by deleting any of the conditions laid down therein, where there is concrete and reliable evidence that this is necessary to maintain the level of protection of health, safety and fundamental rights provided for by this Regulation.

8.

Any amendment to the conditions laid down in paragraph 3, second subparagraph, adopted in accordance with paragraphs 6 and 7 of this Article shall not decrease the overall level of protection of health, safety and fundamental rights provided for by this Regulation and shall ensure consistency with the delegated acts adopted pursuant to Article 7(1), and take account of market and technological developments.

AI Act · 9

Risk management system

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_9

Article 9

Risk management system

1.

A risk management system shall be established, implemented, documented and maintained in relation to high-risk AI systems.

2.

The risk management system shall be understood as a continuous iterative process planned and run throughout the entire lifecycle of a high-risk AI system, requiring regular systematic review and updating. It shall comprise the following steps:

(a)

the identification and analysis of the known and the reasonably foreseeable risks that the high-risk AI system can pose to health, safety or fundamental rights when the high-risk AI system is used in accordance with its intended purpose;

(b)

the estimation and evaluation of the risks that may emerge when the high-risk AI system is used in accordance with its intended purpose, and under conditions of reasonably foreseeable misuse;

(c)

the evaluation of other risks possibly arising, based on the analysis of data gathered from the post-market monitoring system referred to in Article 72;

(d)

the adoption of appropriate and targeted risk management measures designed to address the risks identified pursuant to point (a).

3.

The risks referred to in this Article shall concern only those which may be reasonably mitigated or eliminated through the development or design of the high-risk AI system, or the provision of adequate technical information.

4.

The risk management measures referred to in paragraph 2, point (d), shall give due consideration to the effects and possible interaction resulting from the combined application of the requirements set out in this Section, with a view to minimising risks more effectively while achieving an appropriate balance in implementing the measures to fulfil those requirements.

5.

The risk management measures referred to in paragraph 2, point (d), shall be such that the relevant residual risk associated with each hazard, as well as the overall residual risk of the high-risk AI systems is judged to be acceptable.

In identifying the most appropriate risk management measures, the following shall be ensured:

(a)

elimination or reduction of risks identified and evaluated pursuant to paragraph 2 in as far as technically feasible through adequate design and development of the high-risk AI system;

(b)

where appropriate, implementation of adequate mitigation and control measures addressing risks that cannot be eliminated;

(c)

provision of information required pursuant to Article 13 and, where appropriate, training to deployers.

With a view to eliminating or reducing risks related to the use of the high-risk AI system, due consideration shall be given to the technical knowledge, experience, education, the training to be expected by the deployer, and the presumable context in which the system is intended to be used.

6.

High-risk AI systems shall be tested for the purpose of identifying the most appropriate and targeted risk management measures. Testing shall ensure that high-risk AI systems perform consistently for their intended purpose and that they are in compliance with the requirements set out in this Section.

7.

Testing procedures may include testing in real-world conditions in accordance with Article 60.

8.

The testing of high-risk AI systems shall be performed, as appropriate, at any time throughout the development process, and, in any event, prior to their being placed on the market or put into service. Testing shall be carried out against prior defined metrics and probabilistic thresholds that are appropriate to the intended purpose of the high-risk AI system.

9.

When implementing the risk management system as provided for in paragraphs 1 to 7, providers shall give consideration to whether in view of its intended purpose the high-risk AI system is likely to have an adverse impact on persons under the age of 18 and, as appropriate, other vulnerable groups.

10.

For providers of high-risk AI systems that are subject to requirements regarding internal risk management processes under other relevant provisions of Union law, the aspects provided in paragraphs 1 to 9 may be part of, or combined with, the risk management procedures established pursuant to that law.

AI Act · 10

Data and data governance

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_10

Article 10

Data and data governance

1.

High-risk AI systems which make use of techniques involving the training of AI models with data shall be developed on the basis of training, validation and testing data sets that meet the quality criteria referred to in paragraphs 2, 3 and 4 of this Article and in Article 4a(1) whenever such data sets are used.

2.

Training, validation and testing data sets shall be subject to data governance and management practices appropriate for the intended purpose of the high-risk AI system. Those practices shall concern in particular:

(a)

the relevant design choices;

(b)

data collection processes and the origin of data, and in the case of personal data, the original purpose of the data collection;

(c)

relevant data-preparation processing operations, such as annotation, labelling, cleaning, updating, enrichment and aggregation;

(d)

the formulation of assumptions, in particular with respect to the information that the data are supposed to measure and represent;

(e)

an assessment of the availability, quantity and suitability of the data sets that are needed;

(f)

examination in view of possible biases that are likely to affect the health and safety of persons, have a negative impact on fundamental rights or lead to discrimination prohibited under Union law, especially where data outputs influence inputs for future operations;

(g)

appropriate measures to detect, prevent and mitigate possible biases identified according to point (f);

(h)

the identification of relevant data gaps or shortcomings that prevent compliance with this Regulation, and how those gaps and shortcomings can be addressed.

3.

Training, validation and testing data sets shall be relevant, sufficiently representative, and to the best extent possible, free of errors and complete in view of the intended purpose. They shall have the appropriate statistical properties, including, where applicable, as regards the persons or groups of persons in relation to whom the high-risk AI system is intended to be used. Those characteristics of the data sets may be met at the level of individual data sets or at the level of a combination thereof.

4.

Data sets shall take into account, to the extent required by the intended purpose, the characteristics or elements that are particular to the specific geographical, contextual, behavioural or functional setting within which the high-risk AI system is intended to be used.

———————

6.

For the development of high-risk AI systems not using techniques involving the training of AI models, paragraphs 2, 3 and 4 of this Article and Article 4a(1) shall apply only to the testing data sets.

AI Act · 11

Technical documentation

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_11

Article 11

Technical documentation

1.

The technical documentation of a high-risk AI system shall be drawn up before that system is placed on the market or put into service and shall be kept up-to date.

That technical documentation shall be drawn up in such a way as to demonstrate that the high-risk AI system complies with the requirements set out in this Section and to provide national competent authorities and notified bodies with the necessary information in a clear and comprehensive form to assess the compliance of the AI system with those requirements. It shall contain, at a minimum, the elements set out in Annex IV. SMEs, including start-ups, and SMCs, may provide the elements of the technical documentation specified in Annex IV in a simplified manner. To that end, the Commission shall establish a simplified technical documentation form targeted at the needs of SMEs, including start-ups, and SMCs. Where an SME, including a start-up, or an SMC, opts to provide the information required in Annex IV in a simplified manner, it shall use the form referred to in this paragraph. Notified bodies shall accept the form for the purposes of the conformity assessment.

2.

Where a high-risk AI system related to a product covered by the Union harmonisation legislation listed in Section A of Annex I is placed on the market or put into service, a single set of technical documentation shall be drawn up containing all the information set out in paragraph 1, as well as the information required under those legal acts.

3.

The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend Annex IV, where necessary, to ensure that, in light of technical progress, the technical documentation provides all the information necessary to assess the compliance of the system with the requirements set out in this Section.

AI Act · 12

Record-keeping

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_12

Article 12

Record-keeping

1.

High-risk AI systems shall technically allow for the automatic recording of events (logs) over the lifetime of the system.

2.

In order to ensure a level of traceability of the functioning of a high-risk AI system that is appropriate to the intended purpose of the system, logging capabilities shall enable the recording of events relevant for:

(a)

identifying situations that may result in the high-risk AI system presenting a risk within the meaning of Article 79(1) or in a substantial modification;

(b)

facilitating the post-market monitoring referred to in Article 72; and

(c)

monitoring the operation of high-risk AI systems referred to in Article 26(5).

3.

For high-risk AI systems referred to in point 1 (a), of Annex III, the logging capabilities shall provide, at a minimum:

(a)

recording of the period of each use of the system (start date and time and end date and time of each use);

(b)

the reference database against which input data has been checked by the system;

(c)

the input data for which the search has led to a match;

(d)

the identification of the natural persons involved in the verification of the results, as referred to in Article 14(5).

AI Act · 13

Transparency and provision of information to deployers

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_13

Article 13

Transparency and provision of information to deployers

1.

High-risk AI systems shall be designed and developed in such a way as to ensure that their operation is sufficiently transparent to enable deployers to interpret a system's output and use it appropriately. An appropriate type and degree of transparency shall be ensured with a view to achieving compliance with the relevant obligations of the provider and deployer set out in Section 3.

2.

High-risk AI systems shall be accompanied by instructions for use in an appropriate digital format or otherwise that include concise, complete, correct and clear information that is relevant, accessible and comprehensible to deployers.

3.

The instructions for use shall contain at least the following information:

(a)

the identity and the contact details of the provider and, where applicable, of its authorised representative;

(b)

the characteristics, capabilities and limitations of performance of the high-risk AI system, including:

(i)

its intended purpose;

(ii)

the level of accuracy, including its metrics, robustness and cybersecurity referred to in Article 15 against which the high-risk AI system has been tested and validated and which can be expected, and any known and foreseeable circumstances that may have an impact on that expected level of accuracy, robustness and cybersecurity;

(iii)

any known or foreseeable circumstance, related to the use of the high-risk AI system in accordance with its intended purpose or under conditions of reasonably foreseeable misuse, which may lead to risks to the health and safety or fundamental rights referred to in Article 9(2);

(iv)

where applicable, the technical capabilities and characteristics of the high-risk AI system to provide information that is relevant to explain its output;

(v)

when appropriate, its performance regarding specific persons or groups of persons on which the system is intended to be used;

(vi)

when appropriate, specifications for the input data, or any other relevant information in terms of the training, validation and testing data sets used, taking into account the intended purpose of the high-risk AI system;

(vii)

where applicable, information to enable deployers to interpret the output of the high-risk AI system and use it appropriately;

(c)

the changes to the high-risk AI system and its performance which have been pre-determined by the provider at the moment of the initial conformity assessment, if any;

(d)

the human oversight measures referred to in Article 14, including the technical measures put in place to facilitate the interpretation of the outputs of the high-risk AI systems by the deployers;

(e)

the computational and hardware resources needed, the expected lifetime of the high-risk AI system and any necessary maintenance and care measures, including their frequency, to ensure the proper functioning of that AI system, including as regards software updates;

(f)

where relevant, a description of the mechanisms included within the high-risk AI system that allows deployers to properly collect, store and interpret the logs in accordance with Article 12.

AI Act · 14

Human oversight

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_14

Article 14

Human oversight

1.

High-risk AI systems shall be designed and developed in such a way, including with appropriate human-machine interface tools, that they can be effectively overseen by natural persons during the period in which they are in use.

2.

Human oversight shall aim to prevent or minimise the risks to health, safety or fundamental rights that may emerge when a high-risk AI system is used in accordance with its intended purpose or under conditions of reasonably foreseeable misuse, in particular where such risks persist despite the application of other requirements set out in this Section.

3.

The oversight measures shall be commensurate with the risks, level of autonomy and context of use of the high-risk AI system, and shall be ensured through either one or both of the following types of measures:

(a)

measures identified and built, when technically feasible, into the high-risk AI system by the provider before it is placed on the market or put into service;

(b)

measures identified by the provider before placing the high-risk AI system on the market or putting it into service and that are appropriate to be implemented by the deployer.

4.

For the purpose of implementing paragraphs 1, 2 and 3, the high-risk AI system shall be provided to the deployer in such a way that natural persons to whom human oversight is assigned are enabled, as appropriate and proportionate:

(a)

to properly understand the relevant capacities and limitations of the high-risk AI system and be able to duly monitor its operation, including in view of detecting and addressing anomalies, dysfunctions and unexpected performance;

(b)

to remain aware of the possible tendency of automatically relying or over-relying on the output produced by a high-risk AI system (automation bias), in particular for high-risk AI systems used to provide information or recommendations for decisions to be taken by natural persons;

(c)

to correctly interpret the high-risk AI system’s output, taking into account, for example, the interpretation tools and methods available;

(d)

to decide, in any particular situation, not to use the high-risk AI system or to otherwise disregard, override or reverse the output of the high-risk AI system;

(e)

to intervene in the operation of the high-risk AI system or interrupt the system through a ‘stop’ button or a similar procedure that allows the system to come to a halt in a safe state.

5.

For high-risk AI systems referred to in point 1(a) of Annex III, the measures referred to in paragraph 3 of this Article shall be such as to ensure that, in addition, no action or decision is taken by the deployer on the basis of the identification resulting from the system unless that identification has been separately verified and confirmed by at least two natural

persons with the necessary competence, training and authority.

The requirement for a separate verification by at least two natural persons shall not apply to high-risk AI systems used for the purposes of law enforcement, migration, border control or asylum, where Union or national law considers the application of this requirement to be disproportionate.

AI Act · 15

Accuracy, robustness and cybersecurity

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_15

Article 15

Accuracy, robustness and cybersecurity

1.

High-risk AI systems shall be designed and developed in such a way that they achieve an appropriate level of accuracy, robustness, and cybersecurity, and that they perform consistently in those respects throughout their lifecycle.

2.

To address the technical aspects of how to measure the appropriate levels of accuracy and robustness set out in paragraph 1 and any other relevant performance metrics, the Commission shall, in cooperation with relevant stakeholders and organisations such as metrology and benchmarking authorities, encourage, as appropriate, the development of benchmarks and measurement methodologies.

3.

The levels of accuracy and the relevant accuracy metrics of high-risk AI systems shall be declared in the accompanying instructions of use.

4.

High-risk AI systems shall be as resilient as possible regarding errors, faults or inconsistencies that may occur within the system or the environment in which the system operates, in particular due to their interaction with natural persons or other systems. Technical and organisational measures shall be taken in this regard.

The robustness of high-risk AI systems may be achieved through technical redundancy solutions, which may include backup or fail-safe plans.

High-risk AI systems that continue to learn after being placed on the market or put into service shall be developed in such a way as to eliminate or reduce as far as possible the risk of possibly biased outputs influencing input for future operations (feedback loops), and as to ensure that any such feedback loops are duly addressed with appropriate mitigation measures.

5.

High-risk AI systems shall be resilient against attempts by unauthorised third parties to alter their use, outputs or performance by exploiting system vulnerabilities.

The technical solutions aiming to ensure the cybersecurity of high-risk AI systems shall be appropriate to the relevant circumstances and the risks.

The technical solutions to address AI specific vulnerabilities shall include, where appropriate, measures to prevent, detect, respond to, resolve and control for attacks trying to manipulate the training data set (data poisoning), or pre-trained components used in training (model poisoning), inputs designed to cause the AI model to make a mistake (adversarial examples or model evasion), confidentiality attacks or model flaws.

AI Act · 16

Obligations of providers of high-risk AI systems

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_16

Article 16

Obligations of providers of high-risk AI systems

Providers of high-risk AI systems shall:

(a)

ensure that their high-risk AI systems are compliant with the requirements set out in Section 2;

(b)

indicate on the high-risk AI system or, where that is not possible, on its packaging or its accompanying documentation, as applicable, their name, registered trade name or registered trade mark, the address at which they can be contacted;

(c)

have a quality management system in place which complies with Article 17;

(d)

keep the documentation referred to in Article 18;

(e)

when under their control, keep the logs automatically generated by their high-risk AI systems as referred to in Article 19;

(f)

ensure that the high-risk AI system undergoes the relevant conformity assessment procedure as referred to in Article 43, prior to its being placed on the market or put into service;

(g)

draw up an EU declaration of conformity in accordance with Article 47;

(h)

affix the CE marking to the high-risk AI system or, where that is not possible, on its packaging or its accompanying documentation, to indicate conformity with this Regulation, in accordance with Article 48;

(i)

comply with the registration obligations referred to in Article 49(1);

(j)

take the necessary corrective actions and provide information as required in Article 20;

(k)

upon a reasoned request of a national competent authority, demonstrate the conformity of the high-risk AI system with the requirements set out in Section 2;

(l)

ensure that the high-risk AI system complies with accessibility requirements in accordance with Directives (EU) 2016/2102 and (EU) 2019/882.

AI Act · 17

Quality management system

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_17

Article 17

Quality management system

1.

Providers of high-risk AI systems shall put a quality management system in place that ensures compliance with this Regulation. That system shall be documented in a systematic and orderly manner in the form of written policies, procedures and instructions, and shall include at least the following aspects:

(a)

a strategy for regulatory compliance, including compliance with conformity assessment procedures and procedures for the management of modifications to the high-risk AI system;

(b)

techniques, procedures and systematic actions to be used for the design, design control and design verification of the high-risk AI system;

(c)

techniques, procedures and systematic actions to be used for the development, quality control and quality assurance of the high-risk AI system;

(d)

examination, test and validation procedures to be carried out before, during and after the development of the high-risk AI system, and the frequency with which they have to be carried out;

(e)

technical specifications, including standards, to be applied and, where the relevant harmonised standards are not applied in full or do not cover all of the relevant requirements set out in Section 2, the means to be used to ensure that the high-risk AI system complies with those requirements;

(f)

systems and procedures for data management, including data acquisition, data collection, data analysis, data labelling, data storage, data filtration, data mining, data aggregation, data retention and any other operation regarding the data that is performed before and for the purpose of the placing on the market or the putting into service of high-risk AI systems;

(g)

the risk management system referred to in Article 9;

(h)

the setting-up, implementation and maintenance of a post-market monitoring system, in accordance with Article 72;

(i)

procedures related to the reporting of a serious incident in accordance with Article 73;

(j)

the handling of communication with national competent authorities, other relevant authorities, including those providing or supporting the access to data, notified bodies, other operators, customers or other interested parties;

(k)

systems and procedures for record-keeping of all relevant documentation and information;

(l)

resource management, including security-of-supply related measures;

(m)

an accountability framework setting out the responsibilities of the management and other staff with regard to all the aspects listed in this paragraph.

2.

The implementation of the aspects referred to in paragraph 1 shall be proportionate to the size of the provider's organisation, in particular, if the provider is an SME, including a start-up, or an SMC. Providers shall, in any event, respect the degree of rigour and the level of protection required to ensure the compliance of their high-risk AI systems with this Regulation.

3.

Providers of high-risk AI systems that are subject to obligations regarding quality management systems or an equivalent function under relevant sectoral Union law may include the aspects listed in paragraph 1 as part of the quality management systems pursuant to that law.

4.

For providers that are financial institutions subject to requirements regarding their internal governance, arrangements or processes under Union financial services law, the obligation to put in place a quality management system, with the exception of paragraph 1, points (g), (h) and (i) of this Article, shall be deemed to be fulfilled by complying with the rules on internal governance arrangements or processes pursuant to the relevant Union financial services law. To that end, any harmonised standards referred to in Article 40 shall be taken into account.

AI Act · 25

Responsibilities along the AI value chain

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_25

Article 25

Responsibilities along the AI value chain

1.

Any distributor, importer, deployer or other third-party shall be considered to be a provider of a high-risk AI system for the purposes of this Regulation and shall be subject to the obligations of the provider under Article 16, in any of the following circumstances:

(a)

they put their name or trademark on a high-risk AI system already placed on the market or put into service, without prejudice to contractual arrangements stipulating that the obligations are otherwise allocated;

(b)

they make a substantial modification to a high-risk AI system that has already been placed on the market or has already been put into service in such a way that it remains a high-risk AI system pursuant to Article 6;

(c)

they modify the intended purpose of an AI system, including a general-purpose AI system, which has not been classified as high-risk and has already been placed on the market or put into service in such a way that the AI system concerned becomes a high-risk AI system in accordance with Article 6.

2.

Where the circumstances referred to in paragraph 1 occur, the provider that initially placed the AI system on the market or put it into service shall no longer be considered to be a provider of that specific AI system for the purposes of this Regulation.

That initial provider shall closely cooperate with new providers and shall make available the necessary information and provide the reasonably expected technical access and other assistance that are required for the fulfilment of the obligations set out in this Regulation, in particular with regard to compliance with the conformity assessment of high-risk AI systems.

In particular, the obligation laid down in the second subparagraph shall include, where relevant for the purposes specified therein, the following:

(a)

making available of technical documentation sufficient to assess compliance with the requirements laid down in Article 16;

(b)

informing the new providers about known limitations and failure modes; and

(c)

providing the new providers with targeted technical access, including for testing and validation.

This paragraph shall not apply in cases where the initial provider has clearly specified that its AI system is not to be changed into a high-risk AI system and therefore does not fall under the obligation to cooperate with the new providers and hand over the documentation.

3.

In the case of high-risk AI systems that are safety components of products covered by the Union harmonisation legislation listed in Section A of Annex I, the product manufacturer shall be considered to be the provider of the high-risk AI system, and shall be subject to the obligations under Article 16 under either of the following circumstances:

(a)

the high-risk AI system is placed on the market together with the product under the name or trademark of the product manufacturer;

(b)

the high-risk AI system is put into service under the name or trademark of the product manufacturer after the product has been placed on the market.

4.

The provider of a high-risk AI system and the third party that supplies an AI system, AI model, tools, services, components, or processes that are used or integrated in a high-risk AI system shall, by written agreement, specify the necessary information, capabilities, technical access and other assistance based on the generally acknowledged state of the art, in order to enable the provider of the high-risk AI system to fully comply with the obligations set out in this Regulation. This paragraph shall not apply to third parties making accessible to the public tools, services, processes, or components, other than general-purpose AI models, under a free and open-source licence.

The AI Office may develop and recommend voluntary model terms for contracts between providers of high-risk AI systems and third parties that supply tools, services, components or processes that are used for or integrated into high-risk AI systems. When developing those voluntary model terms, the AI Office shall take into account possible contractual requirements applicable in specific sectors or business cases. The voluntary model terms shall be published and be available free of charge in an easily usable electronic format.

5.

Paragraphs 2 and 3 are without prejudice to the need to observe and protect intellectual property rights, confidential business information and trade secrets in accordance with Union and national law.

AI Act · 26

Obligations of deployers of high-risk AI systems

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_26

Article 26

Obligations of deployers of high-risk AI systems

1.

Deployers of high-risk AI systems shall take appropriate technical and organisational measures to ensure they use such systems in accordance with the instructions for use accompanying the systems, pursuant to paragraphs 3 and 6.

2.

Deployers shall assign human oversight to natural persons who have the necessary competence, training and authority, as well as the necessary support.

3.

The obligations set out in paragraphs 1 and 2, are without prejudice to other deployer obligations under Union or national law and to the deployer's freedom to organise its own resources and activities for the purpose of implementing the human oversight measures indicated by the provider.

4.

Without prejudice to paragraphs 1 and 2, to the extent the deployer exercises control over the input data, that deployer shall ensure that input data is relevant and sufficiently representative in view of the intended purpose of the high-risk AI system.

5.

Deployers shall monitor the operation of the high-risk AI system on the basis of the instructions for use and, where relevant, inform providers in accordance with Article 72. Where deployers have reason to consider that the use of the high-risk AI system in accordance with the instructions may result in that AI system presenting a risk within the meaning of Article 79(1), they shall, without undue delay, inform the provider or distributor and the relevant market surveillance authority, and shall suspend the use of that system. Where deployers have identified a serious incident, they shall also immediately inform first the provider, and then the importer or distributor and the relevant market surveillance authorities of that incident. If the deployer is not able to reach the provider, Article 73 shall apply mutatis mutandis . This obligation shall not cover sensitive operational data of deployers of AI systems which are law enforcement authorities.

For deployers that are financial institutions subject to requirements regarding their internal governance, arrangements or processes under Union financial services law, the monitoring obligation set out in the first subparagraph shall be deemed to be fulfilled by complying with the rules on internal governance arrangements, processes and mechanisms pursuant to the relevant financial service law.

6.

Deployers of high-risk AI systems shall keep the logs automatically generated by that high-risk AI system to the extent such logs are under their control, for a period appropriate to the intended purpose of the high-risk AI system, of at least six months, unless provided otherwise in applicable Union or national law, in particular in Union law on the protection of personal data.

Deployers that are financial institutions subject to requirements regarding their internal governance, arrangements or processes under Union financial services law shall maintain the logs as part of the documentation kept pursuant to the relevant Union financial service law.

7.

Before putting into service or using a high-risk AI system at the workplace, deployers who are employers shall inform workers' representatives and the affected workers that they will be subject to the use of the high-risk AI system. This information shall be provided, where applicable, in accordance with the rules and procedures laid down in Union and national law and practice on information of workers and their representatives.

8.

Deployers of high-risk AI systems that are public authorities, or Union institutions, bodies, offices or agencies shall comply with the registration obligations referred to in Article 49. When such deployers find that the high-risk AI system that they envisage using has not been registered in the EU database referred to in Article 71, they shall not use that system and shall inform the provider or the distributor.

9.

Where applicable, deployers of high-risk AI systems shall use the information provided under Article 13 of this Regulation to comply with their obligation to carry out a data protection impact assessment under Article 35 of Regulation (EU) 2016/679 or Article 27 of Directive (EU) 2016/680.

10.

Without prejudice to Directive (EU) 2016/680, in the framework of an investigation for the targeted search of a person suspected or convicted of having committed a criminal offence, the deployer of a high-risk AI system for post-remote biometric identification shall request an authorisation, ex ante , or without undue delay and no later than 48 hours, by a judicial authority or an administrative authority whose decision is binding and subject to judicial review, for the use of that system, except when it is used for the initial identification of a potential suspect based on objective and verifiable facts directly linked to the offence. Each use shall be limited to what is strictly necessary for the investigation of a specific criminal offence.

If the authorisation requested pursuant to the first subparagraph is rejected, the use of the post-remote biometric identification system linked to that requested authorisation shall be stopped with immediate effect and the personal data linked to the use of the high-risk AI system for which the authorisation was requested shall be deleted.

In no case shall such high-risk AI system for post-remote biometric identification be used for law enforcement purposes in an untargeted way, without any link to a criminal offence, a criminal proceeding, a genuine and present or genuine and foreseeable threat of a criminal offence, or the search for a specific missing person. It shall be ensured that no decision that produces an adverse legal effect on a person may be taken by the law enforcement authorities based solely on the output of such post-remote biometric identification systems.

This paragraph is without prejudice to Article 9 of Regulation (EU) 2016/679 and Article 10 of Directive (EU) 2016/680 for the processing of biometric data.

Regardless of the purpose or deployer, each use of such high-risk AI systems shall be documented in the relevant police file and shall be made available to the relevant market surveillance authority and the national data protection authority upon request, excluding the disclosure of sensitive operational data related to law enforcement. This subparagraph shall be without prejudice to the powers conferred by Directive (EU) 2016/680 on supervisory authorities.

Deployers shall submit annual reports to the relevant market surveillance and national data protection authorities on their use of post-remote biometric identification systems, excluding the disclosure of sensitive operational data related to law enforcement. The reports may be aggregated to cover more than one deployment.

Member States may introduce, in accordance with Union law, more restrictive laws on the use of post-remote biometric identification systems.

11.

Without prejudice to Article 50 of this Regulation, deployers of high-risk AI systems referred to in Annex III that make decisions or assist in making decisions related to natural persons shall inform the natural persons that they are subject to the use of the high-risk AI system. For high-risk AI systems used for law enforcement purposes Article 13 of Directive (EU) 2016/680 shall apply.

12.

Deployers shall cooperate with the relevant competent authorities in any action those authorities take in relation to the high-risk AI system in order to implement this Regulation.

AI Act · 27

Fundamental rights impact assessment for high-risk AI systems

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_27

Article 27

Fundamental rights impact assessment for high-risk AI systems

1.

Prior to deploying a high-risk AI system referred to in Article 6(2), with the exception of high-risk AI systems intended to be used in the area listed in point 2 of Annex III, deployers that are bodies governed by public law, or are private entities providing public services, and deployers of high-risk AI systems referred to in points 5 (b) and (c) of Annex III, shall perform an assessment of the impact on fundamental rights that the use of such system may produce. For that purpose, deployers shall perform an assessment consisting of:

(a)

a description of the deployer's processes in which the high-risk AI system will be used in line with its intended purpose;

(b)

a description of the period of time within which, and the frequency with which, each high-risk AI system is intended to be used;

(c)

the categories of natural persons and groups likely to be affected by its use in the specific context;

(d)

the specific risks of harm likely to have an impact on the categories of natural persons or groups of persons identified pursuant to point (c) of this paragraph, taking into account the information given by the provider pursuant to Article 13;

(e)

a description of the implementation of human oversight measures, according to the instructions for use;

(f)

the measures to be taken in the case of the materialisation of those risks, including the arrangements for internal governance and complaint mechanisms.

2.

The obligation laid down in paragraph 1 applies to the first use of the high-risk AI system. The deployer may, in similar cases, rely on previously conducted fundamental rights impact assessments or existing impact assessments carried out by provider. If, during the use of the high-risk AI system, the deployer considers that any of the elements listed in paragraph 1 has changed or is no longer up to date, the deployer shall take the necessary steps to update the information.

3.

Once the assessment referred to in paragraph 1 of this Article has been performed, the deployer shall notify the market surveillance authority of its results, submitting the filled-out template referred to in paragraph 5 of this Article as part of the notification. In the case referred to in Article 46(1), deployers may be exempt from that obligation to notify.

4.

If any of the obligations laid down in this Article is already met through the data protection impact assessment conducted pursuant to Article 35 of Regulation (EU) 2016/679 or Article 27 of Directive (EU) 2016/680, the deployer may, when conducting the fundamental rights impact assessment referred to in paragraph 1 of this Article, include cross-references to the relevant sections of that data protection impact assessment or include relevant parts thereof in the fundamental rights impact assessment.

5.

The AI Office shall develop a template for a questionnaire, including through an automated tool, to facilitate deployers in complying with their obligations under this Article in a simplified manner. This template shall, where relevant, give deployers the possibility to include cross-references to the relevant sections of the data protection impact assessment or

include relevant parts thereof in the fundamental rights impact assessment pursuant to paragraph 4.

AI Act · 40

Harmonised standards and standardisation deliverables

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_40

Article 40

Harmonised standards and standardisation deliverables

1.

High-risk AI systems or general-purpose AI models which are in conformity with harmonised standards or parts thereof the references of which have been published in the Official Journal of the European Union in accordance with Regulation (EU) No 1025/2012 shall be presumed to be in conformity with the requirements set out in Section 2 of this Chapter or, as applicable, with the obligations set out in of Chapter V, Sections 2 and 3, of this Regulation, to the extent that those standards cover those requirements or obligations.

2.

In accordance with Article 10 of Regulation (EU) No 1025/2012, the Commission shall issue, without undue delay, standardisation requests covering all requirements set out in Section 2 of this Chapter and, as applicable, standardisation requests covering obligations set out in Chapter V, Sections 2 and 3, of this Regulation. The standardisation request shall also ask for deliverables on reporting and documentation processes to improve AI systems' resource performance, such as reducing the high-risk AI system's consumption of energy and of other resources during its lifecycle, and on the energy-efficient development of general-purpose AI models. When preparing a standardisation request, the Commission shall consult the Board and relevant stakeholders, including the advisory forum.

When issuing a standardisation request to European standardisation organisations, the Commission shall specify that standards have to be clear, consistent, including with the standards developed in the various sectors for products covered by the existing Union harmonisation legislation listed in Annex I, and aiming to ensure that high-risk AI systems or general-purpose AI models placed on the market or put into service in the Union meet the relevant requirements or obligations laid down in this Regulation.

The Commission shall request the European standardisation organisations to provide evidence of their best efforts to fulfil the objectives referred to in the first and the second subparagraph of this paragraph in accordance with Article 24 of Regulation (EU) No 1025/2012.

The Commission shall request, in accordance with Regulation (EU) No 1025/2012 of the European Parliament and of the Council (

1

) and without undue delay, the European standardisation organisations to develop standardisation deliverables, including, as appropriate, harmonised standards, to facilitate the joint compliance and presumption of conformity with the requirements or obligations set out in Chapter III, Sections 2 and 3 of this Regulation, and the relevant requirements and obligations laid down in the Union harmonisation legislation listed in Annex I to this Regulation.

3.

The participants in the standardisation process shall seek to promote investment and innovation in AI, including through increasing legal certainty, as well as the competitiveness and growth of the Union market, to contribute to strengthening global cooperation on standardisation and taking into account existing international standards in the field of AI that are consistent with Union values, fundamental rights and interests, and to enhance multi-stakeholder governance ensuring a balanced representation of interests and the effective participation of all relevant stakeholders in accordance with Articles 5, 6, and 7 of Regulation (EU) No 1025/2012.

AI Act · 43

Conformity assessment

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_43

Article 43

Conformity assessment

1.

For high-risk AI systems listed in point 1 of Annex III, where, in demonstrating the compliance of a high-risk AI system with the requirements set out in Section 2, the provider has applied harmonised standards referred to in Article 40, or, where applicable, common specifications referred to in Article 41, the provider shall opt for one of the following conformity assessment procedures based on:

(a)

the internal control referred to in Annex VI; or

(b)

the assessment of the quality management system and the assessment of the technical documentation, with the involvement of a notified body, referred to in Annex VII.

In demonstrating the compliance of a high-risk AI system with the requirements set out in Section 2, the provider shall follow the conformity assessment procedure set out in Annex VII where:

(a)

harmonised standards referred to in Article 40 do not exist, and common specifications referred to in Article 41 are not available;

(b)

the provider has not applied, or has applied only part of, the harmonised standard;

(c)

the common specifications referred to in point (a) exist, but the provider has not applied them;

(d)

one or more of the harmonised standards referred to in point (a) has been published with a restriction, and only on the part of the standard that was restricted.

For the purposes of the conformity assessment procedure referred to in Annex VII, the provider may choose any of the notified bodies. However, where the high-risk AI system is intended to be put into service by law enforcement, immigration or asylum authorities or by Union institutions, bodies, offices or agencies, the market surveillance authority referred to in Article 74(8) or (9), as applicable, shall act as a notified body.

2.

For high-risk AI systems referred to in points 2 to 8 of Annex III, providers shall follow the conformity assessment procedure based on internal control as referred to in Annex VI, which does not provide for the involvement of a notified body.

3.

For high-risk AI systems covered by the Union harmonisation legislation listed in Section A of Annex I, the provider of the system shall follow the relevant conformity assessment procedure as required in accordance with the relevant Union harmonisation legislation. The requirements set out in Section 2 of this Chapter shall apply to those high-risk AI systems and shall be part of that assessment. Assessment of the quality management system set out in Article 17 shall also be undertaken, and points 3, 4.3, 4.4. and 4.5, the fifth paragraph of point 4.6 and point 5 of Annex VII shall apply.

For the purposes of that conformity assessment, notified bodies which have been notified under the Union harmonisation legislation listed in Section A of Annex I shall have the power to assess the conformity of high-risk AI systems with the requirements set out in Section 2 of this Chapter, provided that the compliance of those notified bodies with the requirements laid down in Article 31(4), (5), (10) and (11) has been assessed in the context of the notification procedure in

accordance with the relevant Union harmonisation legislation, which is evidenced through the assessment as part of the existing notification. Without prejudice to Article 28, such notified bodies which have been notified under the Union harmonisation legislation in Section A of Annex I, shall apply for designation in accordance with Section 4 of this Chapter by 28 January 2028.

Where Union harmonisation legislation listed in Section A of Annex I provides the product manufacturer with an option to rely on a conformity assessment that does not involve a third-party, provided that that manufacturer has applied harmonised standards to ensure compliance with all the relevant requirements, that manufacturer may use that option only if it has also applied harmonised standards or, where applicable, common specifications referred to in Article 41, covering all requirements set out in Section 2 of this Chapter. The classification of a product as a high-risk AI system in accordance with Article 6(1) does not affect the choice of the conformity assessment procedure provided to the manufacturers of products covered by Union harmonisation legislation listed in Section A of Annex I, including, where applicable, an option to rely on harmonised standards. The manufacturers of such products are not required to choose a conformity assessment procedure involving third-party conformity assessment only because the product includes a high-risk AI system as a safety component, if this is not required by the Union harmonisation legislation listed in Section A of Annex I.

Where a high-risk AI system is both covered by the Union harmonisation legislation listed in Section A of Annex I and it falls within one of the categories listed in Annex III, the provider of that system shall follow the relevant conformity assessment procedure as required pursuant to the relevant Union harmonisation legislation listed in Section A of Annex I.

4.

High-risk AI systems that have already been subject to a conformity assessment procedure shall undergo a new conformity assessment procedure in the event of a substantial modification, regardless of whether the modified system is intended to be further distributed or continues to be used by the current deployer.

For high-risk AI systems that continue to learn after being placed on the market or put into service, changes to the high-risk AI system and its performance that have been pre-determined by the provider at the moment of the initial conformity assessment and are part of the information contained in the technical documentation referred to in point 2(f) of Annex IV, shall not constitute a substantial modification.

5.

The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend Annexes VI and VII by updating them in light of technical progress.

6.

The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend paragraphs 1 and 2 of this Article in order to subject high-risk AI systems referred to in points 2 to 8 of Annex III to the conformity assessment procedure referred to in Annex VII or parts thereof. The Commission shall adopt such delegated acts taking into account the effectiveness of the conformity assessment procedure based on internal control referred to in Annex VI in preventing or minimising the risks to health and safety and protection of fundamental rights posed by such systems, as well as the availability of adequate capacities and resources among notified bodies.

AI Act · 47

EU declaration of conformity

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_47

Article 47

EU declaration of conformity

1.

The provider shall draw up a written machine readable, physical or electronically signed EU declaration of conformity for each high-risk AI system, and keep it at the disposal of the national competent authorities for 10 years after the high-risk AI system has been placed on the market or put into service. The EU declaration of conformity shall identify the high-risk AI system for which it has been drawn up. A copy of the EU declaration of conformity shall be submitted to the relevant national competent authorities upon request.

2.

The EU declaration of conformity shall state that the high-risk AI system concerned meets the requirements set out in Section 2. The EU declaration of conformity shall contain the information set out in Annex V, and shall be translated into a language that can be easily understood by the national competent authorities of the Member States in which the high-risk AI system is placed on the market or made available.

3.

Where high-risk AI systems are subject to other Union harmonisation legislation which also requires an EU declaration of conformity, a single EU declaration of conformity shall be drawn up in respect of all Union law applicable to the high-risk AI system. The declaration shall contain all the information required to identify the Union harmonisation legislation to which the declaration relates.

4.

By drawing up the EU declaration of conformity, the provider shall assume responsibility for compliance with the requirements set out in Section 2. The provider shall keep the EU declaration of conformity up-to-date as appropriate.

5.

The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend Annex V by updating the content of the EU declaration of conformity set out in that Annex, in order to introduce elements that become necessary in light of technical progress.

AI Act · 48

CE marking

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_48

Article 48

CE marking

1.

The CE marking shall be subject to the general principles set out in Article 30 of Regulation (EC) No 765/2008.

2.

For high-risk AI systems provided digitally, a digital CE marking shall be used, only if it can easily be accessed via the interface from which that system is accessed or via an easily accessible machine-readable code or other electronic means.

3.

The CE marking shall be affixed visibly, legibly and indelibly for high-risk AI systems. Where that is not possible or not warranted on account of the nature of the high-risk AI system, it shall be affixed to the packaging or to the accompanying documentation, as appropriate.

4.

Where applicable, the CE marking shall be followed by the identification number of the notified body responsible for the conformity assessment procedures set out in Article 43. The identification number of the notified body shall be affixed by the body itself or, under its instructions, by the provider or by the provider’s authorised representative. The identification number shall also be indicated in any promotional material which mentions that the high-risk AI system fulfils the requirements for CE marking.

5.

Where high-risk AI systems are subject to other Union law which also provides for the affixing of the CE marking, the CE marking shall indicate that the high-risk AI system also fulfil the requirements of that other law.

AI Act · 49

Registration

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_49

Article 49

Registration

1.

Before placing on the market or putting into service a high-risk AI system listed in Annex III, with the exception of high-risk AI systems referred to in point 2 of Annex III, the provider or, where applicable, the authorised representative shall register themselves and their system in the EU database referred to in Article 71.

2.

Before placing on the market or putting into service an AI system for which the provider has concluded that it is not high-risk according to Article 6(3), that provider or, where applicable, the authorised representative shall register themselves and that system in the EU database referred to in Article 71.

3.

Before putting into service or using a high-risk AI system listed in Annex III, with the exception of high-risk AI systems listed in point 2 of Annex III, deployers that are public authorities, Union institutions, bodies, offices or agencies or persons acting on their behalf shall register themselves, select the system and register its use in the EU database referred to in Article 71.

4.

For high-risk AI systems referred to in points 1, 6 and 7 of Annex III, in the areas of law enforcement, migration, asylum and border control management, the registration referred to in paragraphs 1, 2 and 3 of this Article shall be in a secure non-public section of the EU database referred to in Article 71 and shall include only the following information, as applicable, referred to in:

(a)

Section A, points 1 to 10, of Annex VIII, with the exception of points 6, 8 and 9;

(b)

Section B, points 1 to 5, and points 8 and 9 of Annex VIII;

(c)

Section C, points 1 to 3, of Annex VIII;

(d)

points 1, 2, 3 and 5, of Annex IX.

Only the Commission and national authorities referred to in Article 74(8) shall have access to the respective restricted sections of the EU database listed in the first subparagraph of this paragraph.

5.

High-risk AI systems referred to in point 2 of Annex III shall be registered at national level.

AI Act · 50

Transparency obligations for providers and deployers of certain AI systems

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_50

Article 50

Transparency obligations for providers and deployers of certain AI systems

1.

Providers shall ensure that AI systems intended to interact directly with natural persons are designed and developed in such a way that the natural persons concerned are informed that they are interacting with an AI system, unless this is obvious from the point of view of a natural person who is reasonably well-informed, observant and circumspect, taking into account the circumstances and the context of use. This obligation shall not apply to AI systems authorised by law to detect, prevent, investigate or prosecute criminal offences, subject to appropriate safeguards for the rights and freedoms of third parties, unless those systems are available for the public to report a criminal offence.

2.

Providers of AI systems, including general-purpose AI systems, generating synthetic audio, image, video or text content, shall ensure that the outputs of the AI system are marked in a machine-readable format and detectable as artificially generated or manipulated. Providers shall ensure their technical solutions are effective, interoperable, robust and reliable as far as this is technically feasible, taking into account the specificities and limitations of various types of content, the costs of implementation and the generally acknowledged state of the art, as may be reflected in relevant technical standards. This obligation shall not apply to the extent the AI systems perform an assistive function for standard editing or do not substantially alter the input data provided by the deployer or the semantics thereof, or where authorised by law to detect, prevent, investigate or prosecute criminal offences.

3.

Deployers of an emotion recognition system or a biometric categorisation system shall inform the natural persons exposed thereto of the operation of the system, and shall process the personal data in accordance with Regulations (EU) 2016/679 and (EU) 2018/1725 and Directive (EU) 2016/680, as applicable. This obligation shall not apply to AI systems used for biometric categorisation and emotion recognition, which are permitted by law to detect, prevent or investigate criminal offences, subject to appropriate safeguards for the rights and freedoms of third parties, and in accordance with Union law.

4.

Deployers of an AI system that generates or manipulates image, audio or video content constituting a deep fake, shall disclose that the content has been artificially generated or manipulated. This obligation shall not apply where the use is authorised by law to detect, prevent, investigate or prosecute criminal offence. Where the content forms part of an evidently artistic, creative, satirical, fictional or analogous work or programme, the transparency obligations set out in this paragraph are limited to disclosure of the existence of such generated or manipulated content in an appropriate manner that does not hamper the display or enjoyment of the work.

Deployers of an AI system that generates or manipulates text which is published with the purpose of informing the public on matters of public interest shall disclose that the text has been artificially generated or manipulated. This obligation shall not apply where the use is authorised by law to detect, prevent, investigate or prosecute criminal offences or where the AI-generated content has undergone a process of human review or editorial control and where a natural or legal person holds editorial responsibility for the publication of the content.

5.

The information referred to in paragraphs 1 to 4 shall be provided to the natural persons concerned in a clear and distinguishable manner at the latest at the time of the first interaction or exposure. The information shall conform to the applicable accessibility requirements.

6.

Paragraphs 1 to 4 shall not affect the requirements and obligations set out in Chapter III, and shall be without prejudice to other transparency obligations laid down in Union or national law for deployers of AI systems.

7.

The Commission shall encourage and facilitate the drawing up of codes of practice at Union level to facilitate the effective implementation of the obligations regarding the detection, marking and labelling of artificially generated or manipulated content. The Commission, taking utmost account of the opinion of the Board, shall assess whether adherence to those codes of practice is adequate to ensure compliance with the obligations laid down in paragraphs 2 and 4 of this Article, in accordance with the procedure laid down in Article 56(6). If it deems the code of practice to be inadequate, the Commission may adopt an implementing act specifying common rules for the implementation of those obligations in accordance with the examination procedure laid down in Article 98(2).

AI Act · 51

Classification of general-purpose AI models as general-purpose AI models with systemic risk

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_51

Article 51

Classification of general-purpose AI models as general-purpose AI models with systemic risk

1.

A general-purpose AI model shall be classified as a general-purpose AI model with systemic risk if it meets any of the following conditions:

(a)

it has high impact capabilities evaluated on the basis of appropriate technical tools and methodologies, including indicators and benchmarks;

(b)

based on a decision of the Commission, ex officio or following a qualified alert from the scientific panel, it has capabilities or an impact equivalent to those set out in point (a) having regard to the criteria set out in Annex XIII.

2.

A general-purpose AI model shall be presumed to have high impact capabilities pursuant to paragraph 1, point (a), when the cumulative amount of computation used for its training measured in floating point operations is greater than 10 25 .

3.

The Commission shall adopt delegated acts in accordance with Article 97 to amend the thresholds listed in paragraphs 1 and 2 of this Article, as well as to supplement benchmarks and indicators in light of evolving technological developments, such as algorithmic improvements or increased hardware efficiency, when necessary, for these thresholds to reflect the state of the art.

AI Act · 53

Obligations for providers of general-purpose AI models

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_53

Article 53

Obligations for providers of general-purpose AI models

1.

Providers of general-purpose AI models shall:

(a)

draw up and keep up-to-date the technical documentation of the model, including its training and testing process and the results of its evaluation, which shall contain, at a minimum, the information set out in Annex XI for the purpose of providing it, upon request, to the AI Office and the national competent authorities;

(b)

draw up, keep up-to-date and make available information and documentation to providers of AI systems who intend to integrate the general-purpose AI model into their AI systems. Without prejudice to the need to observe and protect intellectual property rights and confidential business information or trade secrets in accordance with Union and national law, the information and documentation shall:

(i)

enable providers of AI systems to have a good understanding of the capabilities and limitations of the general-purpose AI model and to comply with their obligations pursuant to this Regulation; and

(ii)

contain, at a minimum, the elements set out in Annex XII;

(c)

put in place a policy to comply with Union law on copyright and related rights, and in particular to identify and comply with, including through state-of-the-art technologies, a reservation of rights expressed pursuant to Article 4(3) of Directive (EU) 2019/790;

(d)

draw up and make publicly available a sufficiently detailed summary about the content used for training of the general-purpose AI model, according to a template provided by the AI Office.

2.

The obligations set out in paragraph 1, points (a) and (b), shall not apply to providers of AI models that are released under a free and open-source licence that allows for the access, usage, modification, and distribution of the model, and whose parameters, including the weights, the information on the model architecture, and the information on model usage, are made publicly available. This exception shall not apply to general-purpose AI models with systemic risks.

3.

Providers of general-purpose AI models shall cooperate as necessary with the Commission and the national competent authorities in the exercise of their competences and powers pursuant to this Regulation.

4.

Providers of general-purpose AI models may rely on codes of practice within the meaning of Article 56 to demonstrate compliance with the obligations set out in paragraph 1 of this Article, until a harmonised standard is published. Compliance with European harmonised standards grants providers the presumption of conformity to the extent that those standards cover those obligations. Providers of general-purpose AI models who do not adhere to an approved code of practice or do not comply with a European harmonised standard shall demonstrate alternative adequate means of compliance for assessment by the Commission.

5.

For the purpose of facilitating compliance with Annex XI, in particular points 2 (d) and (e) thereof, the Commission is empowered to adopt delegated acts in accordance with Article 97 to detail measurement and calculation methodologies with a view to allowing for comparable and verifiable documentation.

6.

The Commission is empowered to adopt delegated acts in accordance with Article 97(2) to amend Annexes XI and XII in light of evolving technological developments.

7.

Any information or documentation obtained pursuant to this Article, including trade secrets, shall be treated in accordance with the confidentiality obligations set out in Article 78.

AI Act · 55

Obligations of providers of general-purpose AI models with systemic risk

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_55

Article 55

Obligations of providers of general-purpose AI models with systemic risk

1.

In addition to the obligations listed in Articles 53 and 54, providers of general-purpose AI models with systemic risk shall:

(a)

perform model evaluation in accordance with standardised protocols and tools reflecting the state of the art, including conducting and documenting adversarial testing of the model with a view to identifying and mitigating systemic risks;

(b)

assess and mitigate possible systemic risks at Union level, including their sources, that may stem from the development, the placing on the market, or the use of general-purpose AI models with systemic risk;

(c)

keep track of, document, and report, without undue delay, to the AI Office and, as appropriate, to national competent authorities, relevant information about serious incidents and possible corrective measures to address them;

(d)

ensure an adequate level of cybersecurity protection for the general-purpose AI model with systemic risk and the physical infrastructure of the model.

2.

Providers of general-purpose AI models with systemic risk may rely on codes of practice within the meaning of Article 56 to demonstrate compliance with the obligations set out in paragraph 1 of this Article, until a harmonised standard is published. Compliance with European harmonised standards grants providers the presumption of conformity to the extent that those standards cover those obligations. Providers of general-purpose AI models with systemic risks who do not adhere to an approved code of practice or do not comply with a European harmonised standard shall demonstrate alternative adequate means of compliance for assessment by the Commission.

3.

Any information or documentation obtained pursuant to this Article, including trade secrets, shall be treated in accordance with the confidentiality obligations set out in Article 78.

AI Act · 72

Post-market monitoring by providers and post-market monitoring plan for high-risk AI systems

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_72

Article 72

Post-market monitoring by providers and post-market monitoring plan for high-risk AI systems

1.

Providers shall establish and document a post-market monitoring system in a manner that is proportionate to the nature of the AI technologies and the risks of the high-risk AI system.

2.

The post-market monitoring system shall actively and systematically collect, document and analyse relevant data which may be provided by deployers or which may be collected through other sources on the performance of high-risk AI systems throughout their lifetime, and which allow the provider to evaluate the continuous compliance of AI systems with the requirements set out in Chapter III, Section 2. Where relevant, post-market monitoring shall include an analysis of the interaction with other AI systems. This obligation shall not cover sensitive operational data of deployers which are law-enforcement authorities.

3.

The post-market monitoring system shall be based on a post-market monitoring plan. The post-market monitoring plan shall be part of the technical documentation referred to in Annex IV. The Commission, taking utmost account of the opinion of the Board, shall adopt guidance, including a template, on the post-market monitoring plan by 2 September 2027.

4.

For high-risk AI systems covered by the Union harmonisation legislation listed in Section A of Annex I, where a post-market monitoring system and plan are already established under that legislation, in order to ensure consistency, avoid duplications and minimise additional burdens, providers shall have a choice of integrating, as appropriate, the necessary elements described in paragraphs 1, 2 and 3 using the template referred in paragraph 3 into systems and plans already existing under that legislation, provided that it achieves an equivalent level of protection.

The first subparagraph of this paragraph shall also apply to high-risk AI systems referred to in point 5 of Annex III placed on the market or put into service by financial institutions that are subject to requirements under Union financial services law regarding their internal governance, arrangements or processes.

AI Act · 73

Reporting of serious incidents

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_73

Article 73

Reporting of serious incidents

1.

Providers of high-risk AI systems placed on the Union market shall report any serious incident to the market surveillance authorities of the Member States where that incident occurred.

2.

The report referred to in paragraph 1 shall be made immediately after the provider has established a causal link between the AI system and the serious incident or the reasonable likelihood of such a link, and, in any event, not later than 15 days after the provider or, where applicable, the deployer, becomes aware of the serious incident.

The period for the reporting referred to in the first subparagraph shall take account of the severity of the serious incident.

3.

Notwithstanding paragraph 2 of this Article, in the event of a widespread infringement or a serious incident as defined in Article 3, point (49)(b), the report referred to in paragraph 1 of this Article shall be provided immediately, and not later than two days after the provider or, where applicable, the deployer becomes aware of that incident.

4.

Notwithstanding paragraph 2, in the event of the death of a person, the report shall be provided immediately after the provider or the deployer has established, or as soon as it suspects, a causal relationship between the high-risk AI system and the serious incident, but not later than 10 days after the date on which the provider or, where applicable, the deployer becomes aware of the serious incident.

5.

Where necessary to ensure timely reporting, the provider or, where applicable, the deployer, may submit an initial report that is incomplete, followed by a complete report.

6.

Following the reporting of a serious incident pursuant to paragraph 1, the provider shall, without delay, perform the necessary investigations in relation to the serious incident and the AI system concerned. This shall include a risk assessment of the incident, and corrective action.

The provider shall cooperate with the competent authorities, and where relevant with the notified body concerned, during the investigations referred to in the first subparagraph, and shall not perform any investigation which involves altering the AI system concerned in a way which may affect any subsequent evaluation of the causes of the incident, prior to informing the competent authorities of such action.

7.

Upon receiving a notification related to a serious incident referred to in Article 3, point (49)(c), the relevant market surveillance authority shall inform the national public authorities or bodies referred to in Article 77(1). The Commission shall develop dedicated guidance to facilitate compliance with the obligations set out in paragraph 1 of this Article. That guidance shall be issued by 2 August 2025, and shall be assessed regularly.

8.

The market surveillance authority shall take appropriate measures, as provided for in Article 19 of Regulation (EU) 2019/1020, within seven days from the date it received the notification referred to in paragraph 1 of this Article, and shall follow the notification procedures as provided in that Regulation.

9.

For high-risk AI systems referred to in Annex III that are placed on the market or put into service by providers that are subject to Union legislative instruments laying down reporting obligations equivalent to those set out in this Regulation, the notification of serious incidents shall be limited to those referred to in Article 3, point (49)(c).

10.

For high-risk AI systems which are safety components of devices, or are themselves devices, covered by Regulations (EU) 2017/745 and (EU) 2017/746, the notification of serious incidents shall be limited to those referred to in Article 3, point (49)(c) of this Regulation, and shall be made to the national competent authority chosen for that purpose by the Member States where the incident occurred.

11.

National competent authorities shall immediately notify the Commission of any serious incident, whether or not they have taken action on it, in accordance with Article 20 of Regulation (EU) 2019/1020.

AI Act · 85

Right to lodge a complaint with a market surveillance authority

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_85

Article 85

Right to lodge a complaint with a market surveillance authority

Without prejudice to other administrative or judicial remedies, any natural or legal person having grounds to consider that there has been an infringement of the provisions of this Regulation may submit complaints to the relevant market surveillance authority.

In accordance with Regulation (EU) 2019/1020, such complaints shall be taken into account for the purpose of conducting market surveillance activities, and shall be handled in line with the dedicated procedures established therefor by the market surveillance authorities.

AI Act · 86

Right to explanation of individual decision-making

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_86

Article 86

Right to explanation of individual decision-making

1.

Any affected person subject to a decision which is taken by the deployer on the basis of the output from a high-risk AI system listed in Annex III, with the exception of systems listed under point 2 thereof, and which produces legal effects or similarly significantly affects that person in a way that they consider to have an adverse impact on their health, safety or fundamental rights shall have the right to obtain from the deployer clear and meaningful explanations of the role of the AI system in the decision-making procedure and the main elements of the decision taken.

2.

Paragraph 1 shall not apply to the use of AI systems for which exceptions from, or restrictions to, the obligation under that paragraph follow from Union or national law in compliance with Union law.

3.

This Article shall apply only to the extent that the right referred to in paragraph 1 is not otherwise provided for under Union law.

AI Act · 99

Penalties

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_99

Article 99

Penalties

1.

In accordance with the terms and conditions laid down in this Regulation, Member States shall lay down the rules on penalties and other enforcement measures, which may also include administrative fines, warnings and non-monetary measures, applicable to any infringement of this Regulation by operators, and shall take all measures necessary to ensure that they are properly and effectively implemented, thereby taking into account the guidelines issued by the Commission pursuant to Article 96. The penalties provided for shall be effective, proportionate and dissuasive. The Member States shall take into account the interests of SMEs, including start-ups, and SMCs, and their economic viability when imposing penalties.

2.

The Member States shall, without delay and at the latest by the date of entry into application, notify the Commission of the rules on penalties and of other enforcement measures referred to in paragraph 1, and shall notify it, without delay, of any subsequent amendment to them.

3.

Non-compliance with the prohibition of the AI practices referred to in Article 5 shall be subject to administrative fines of up to EUR 35 000 000 or, if the offender is an undertaking, up to 7 % of its total worldwide annual turnover for the preceding financial year, whichever is higher.

4.

Non-compliance with any of the following provisions related to operators or notified bodies, other than those laid down in Articles 5, shall be subject to administrative fines of up to EUR 15 000 000 or, if the offender is an undertaking, up to 3 % of its total worldwide annual turnover for the preceding financial year, whichever is higher:

(a)

obligations of providers pursuant to Article 16;

(b)

obligations of authorised representatives pursuant to Article 22;

(c)

obligations of importers pursuant to Article 23;

(d)

obligations of distributors pursuant to Article 24;

(da)

obligations of providers and operators pursuant to Article 25(2) and (4);

(e)

obligations of deployers pursuant to Article 26;

(f)

requirements and obligations of notified bodies pursuant to Article 31, Article 33(1), (3) and (4) or Article 34;

(g)

transparency obligations for providers and deployers pursuant to Article 50.

5.

The supply of incorrect, incomplete or misleading information to notified bodies or national competent authorities in reply to a request shall be subject to administrative fines of up to EUR 7 500 000 or, if the offender is an undertaking, up to 1 % of its total worldwide annual turnover for the preceding financial year, whichever is higher.

6.

In the case of SMEs, including start-ups, each fine referred to in this Article shall be up to the percentages or amount referred to in paragraphs 3, 4 and 5, whichever thereof is lower.

6a.

In the case of SMCs, each fine referred to in paragraphs 4 and 5 shall be up to the percentages or amount referred therein, whichever is lower.

7.

When deciding whether to impose an administrative fine and when deciding on the amount of the administrative fine in each individual case, all relevant circumstances of the specific situation shall be taken into account and, as appropriate, regard shall be given to the following:

(a)

the nature, gravity and duration of the infringement and of its consequences, taking into account the purpose of the AI system, as well as, where appropriate, the number of affected persons and the level of damage suffered by them;

(b)

whether administrative fines have already been applied by other market surveillance authorities to the same operator for the same infringement;

(c)

whether administrative fines have already been applied by other authorities to the same operator for infringements of other Union or national law, when such infringements result from the same activity or omission constituting a relevant infringement of this Regulation;

(d)

the size, the annual turnover and market share of the operator committing the infringement;

(e)

any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits gained, or losses avoided, directly or indirectly, from the infringement;

(f)

the degree of cooperation with the national competent authorities, in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

(g)

the degree of responsibility of the operator taking into account the technical and organisational measures implemented by it;

(h)

the manner in which the infringement became known to the national competent authorities, in particular whether, and if so to what extent, the operator notified the infringement;

(i)

the intentional or negligent character of the infringement;

(j)

any action taken by the operator to mitigate the harm suffered by the affected persons.

8.

Each Member State shall lay down rules on to what extent administrative fines may be imposed on public authorities and bodies established in that Member State.

9.

Depending on the legal system of the Member States, the rules on administrative fines may be applied in such a manner that the fines are imposed by competent national courts or by other bodies, as applicable in those Member States. The application of such rules in those Member States shall have an equivalent effect.

10.

The exercise of powers under this Article shall be subject to appropriate procedural safeguards in accordance with Union and national law, including effective judicial remedies and due process.

11.

Member States shall, on an annual basis, report to the Commission about the administrative fines they have issued during that year, in accordance with this Article, and about any related litigation or judicial proceedings.

AI Act · 111

AI systems already placed on the market or put into service and general-purpose AI models already placed on the marked

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_111

Article 111

AI systems already placed on the market or put into service and general-purpose AI models already placed on the marked

1.

Without prejudice to the application of Article 5 as referred to in Article 113(3), point (a), AI systems which are components of the large-scale IT systems established by the legal acts listed in Annex X that have been placed on the market or put into service before 2 August 2027 shall be brought into compliance with this Regulation by 31 December 2030.

The requirements laid down in this Regulation shall be taken into account in the evaluation of each large-scale IT system established by the legal acts listed in Annex X to be undertaken as provided for in those legal acts and where those legal acts are replaced or amended.

2.

Without prejudice to the application of Article 5 as referred to in Article 113, third paragraph, point (a), this Regulation shall apply to operators of high-risk AI systems, other than the systems referred to in paragraph 1 of this Article, that have been placed on the market or put into service before the date of application of Chapter III referred to in Article 113, only if, as from that date, those systems are subject to significant changes in their designs. In any case, the providers and deployers of high-risk AI systems intended to be used by public authorities shall take the necessary steps to comply with the requirements and obligations laid down in this Regulation by 2 August 2030.

3.

Providers of general-purpose AI models that have been placed on the market before 2 August 2025 shall take the necessary steps in order to comply with the obligations laid down in this Regulation by 2 August 2027.

4.

Providers of AI systems, including general-purpose AI systems, generating synthetic audio, image, video or text content, that have been placed on the market before 2 August 2026 shall take the necessary steps in order to comply with Article 50(2) by 2 December 2026.

AI Act · 113

Entry into force and application

2024/1689, consolidated 27 July 2026 · English

https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_113

Article 113

Entry into force and application

This Regulation shall enter into force on the twentieth day following that of its publication in the Official Journal of the European Union .

It shall apply from 2 August 2026.

However:

(a)

Chapters I and II shall apply from 2 February 2025, with the exception of Article 5(1), first subparagraph, points (ba) and (bb), and Article 5(1a) and (1b) which shall apply from 2 December 2026;

(b)

Chapter III Section 4, Chapter V, Chapter VII and Chapter XII and Article 78 shall apply from 2 August 2025, with the exception of Article 101;

(c)

Chapter III, Sections 1, 2, and 3, with the exception of Article 6(5), shall apply from:

(i)

2 December 2027 as regards AI systems classified as high-risk pursuant to Article 6(2) and Annex III; and

(ii)

2 August 2028 as regards AI systems classified as high-risk pursuant to Article 6(1) and Annex I;

(d)

Articles 102 to 110 shall apply from 27 July 2026.

GDPR · 2

Material scope

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_2

Article 2

Material scope

1. This Regulation applies to the processing of personal data wholly or partly by automated means and to the processing other than by automated means of personal data which form part of a filing system or are intended to form part of a filing system.

2. This Regulation does not apply to the processing of personal data:

(a)

in the course of an activity which falls outside the scope of Union law;

(b)

by the Member States when carrying out activities which fall within the scope of Chapter 2 of Title V of the TEU;

(c)

by a natural person in the course of a purely personal or household activity;

(d)

by competent authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security.

3. For the processing of personal data by the Union institutions, bodies, offices and agencies, Regulation (EC) No 45/2001 applies. Regulation (EC) No 45/2001 and other Union legal acts applicable to such processing of personal data shall be adapted to the principles and rules of this Regulation in accordance with Article 98.

4. This Regulation shall be without prejudice to the application of Directive 2000/31/EC, in particular of the liability rules of intermediary service providers in Articles 12 to 15 of that Directive.

GDPR · 3

Territorial scope

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_3

Article 3

Territorial scope

1. This Regulation applies to the processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union, regardless of whether the processing takes place in the Union or not.

2. This Regulation applies to the processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union, where the processing activities are related to:

(a)

the offering of goods or services, irrespective of whether a payment of the data subject is required, to such data subjects in the Union; or

(b)

the monitoring of their behaviour as far as their behaviour takes place within the Union.

3. This Regulation applies to the processing of personal data by a controller not established in the Union, but in a place where Member State law applies by virtue of public international law.

GDPR · 4

Definitions

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_4

Article 4

Definitions

For the purposes of this Regulation:

(1)

‘personal data’ means any information relating to an identified or identifiable natural person (‘data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person;

(2)

‘processing’ means any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction;

(3)

‘restriction of processing’ means the marking of stored personal data with the aim of limiting their processing in the future;

(4)

‘profiling’ means any form of automated processing of personal data consisting of the use of personal data to evaluate certain personal aspects relating to a natural person, in particular to analyse or predict aspects concerning that natural person's performance at work, economic situation, health, personal preferences, interests, reliability, behaviour, location or movements;

(5)

‘pseudonymisation’ means the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person;

(6)

‘filing system’ means any structured set of personal data which are accessible according to specific criteria, whether centralised, decentralised or dispersed on a functional or geographical basis;

(7)

‘controller’ means the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law;

(8)

‘processor’ means a natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller;

(9)

‘recipient’ means a natural or legal person, public authority, agency or another body, to which the personal data are disclosed, whether a third party or not. However, public authorities which may receive personal data in the framework of a particular inquiry in accordance with Union or Member State law shall not be regarded as recipients; the processing of those data by those public authorities shall be in compliance with the applicable data protection rules according to the purposes of the processing;

(10)

‘third party’ means a natural or legal person, public authority, agency or body other than the data subject, controller, processor and persons who, under the direct authority of the controller or processor, are authorised to process personal data;

(11)

‘consent’ of the data subject means any freely given, specific, informed and unambiguous indication of the data subject's wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal data relating to him or her;

(12)

‘personal data breach’ means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed;

(13)

‘genetic data’ means personal data relating to the inherited or acquired genetic characteristics of a natural person which give unique information about the physiology or the health of that natural person and which result, in particular, from an analysis of a biological sample from the natural person in question;

(14)

‘biometric data’ means personal data resulting from specific technical processing relating to the physical, physiological or behavioural characteristics of a natural person, which allow or confirm the unique identification of that natural person, such as facial images or dactyloscopic data;

(15)

‘data concerning health’ means personal data related to the physical or mental health of a natural person, including the provision of health care services, which reveal information about his or her health status;

(16)

‘main establishment’ means:

(a)

as regards a controller with establishments in more than one Member State, the place of its central administration in the Union, unless the decisions on the purposes and means of the processing of personal data are taken in another establishment of the controller in the Union and the latter establishment has the power to have such decisions implemented, in which case the establishment having taken such decisions is to be considered to be the main establishment;

(b)

as regards a processor with establishments in more than one Member State, the place of its central administration in the Union, or, if the processor has no central administration in the Union, the establishment of the processor in the Union where the main processing activities in the context of the activities of an establishment of the processor take place to the extent that the processor is subject to specific obligations under this Regulation;

(17)

‘representative’ means a natural or legal person established in the Union who, designated by the controller or processor in writing pursuant to Article 27, represents the controller or processor with regard to their respective obligations under this Regulation;

(18)

‘enterprise’ means a natural or legal person engaged in an economic activity, irrespective of its legal form, including partnerships or associations regularly engaged in an economic activity;

(19)

‘group of undertakings’ means a controlling undertaking and its controlled undertakings;

(20)

‘binding corporate rules’ means personal data protection policies which are adhered to by a controller or processor established on the territory of a Member State for transfers or a set of transfers of personal data to a controller or processor in one or more third countries within a group of undertakings, or group of enterprises engaged in a joint economic activity;

(21)

‘supervisory authority’ means an independent public authority which is established by a Member State pursuant to Article 51;

(22)

‘supervisory authority concerned’ means a supervisory authority which is concerned by the processing of personal data because:

(a)

the controller or processor is established on the territory of the Member State of that supervisory authority;

(b)

data subjects residing in the Member State of that supervisory authority are substantially affected or likely to be substantially affected by the processing; or

(c)

a complaint has been lodged with that supervisory authority;

(23)

‘cross-border processing’ means either:

(a)

processing of personal data which takes place in the context of the activities of establishments in more than one Member State of a controller or processor in the Union where the controller or processor is established in more than one Member State; or

(b)

processing of personal data which takes place in the context of the activities of a single establishment of a controller or processor in the Union but which substantially affects or is likely to substantially affect data subjects in more than one Member State.

(24)

‘relevant and reasoned objection’ means an objection to a draft decision as to whether there is an infringement of this Regulation, or whether envisaged action in relation to the controller or processor complies with this Regulation, which clearly demonstrates the significance of the risks posed by the draft decision as regards the fundamental rights and freedoms of data subjects and, where applicable, the free flow of personal data within the Union;

(25)

‘information society service’ means a service as defined in point (b) of Article 1(1) of Directive (EU) 2015/1535 of the European Parliament and of the Council (19) ;

(26)

‘international organisation’ means an organisation and its subordinate bodies governed by public international law, or any other body which is set up by, or on the basis of, an agreement between two or more countries.

GDPR · 5

Principles relating to processing of personal data

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_5

Article 5

Principles relating to processing of personal data

1. Personal data shall be:

(a)

processed lawfully, fairly and in a transparent manner in relation to the data subject (‘lawfulness, fairness and transparency’);

(b)

collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes; further processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes shall, in accordance with Article 89(1), not be considered to be incompatible with the initial purposes (‘purpose limitation’);

(c)

adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed (‘data minimisation’);

(d)

accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay (‘accuracy’);

(e)

kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed; personal data may be stored for longer periods insofar as the personal data will be processed solely for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) subject to implementation of the appropriate technical and organisational measures required by this Regulation in order to safeguard the rights and freedoms of the data subject (‘storage limitation’);

(f)

processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures (‘integrity and confidentiality’).

2. The controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 (‘accountability’).

GDPR · 6

Lawfulness of processing

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_6

Article 6

Lawfulness of processing

1. Processing shall be lawful only if and to the extent that at least one of the following applies:

(a)

the data subject has given consent to the processing of his or her personal data for one or more specific purposes;

(b)

processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;

(c)

processing is necessary for compliance with a legal obligation to which the controller is subject;

(d)

processing is necessary in order to protect the vital interests of the data subject or of another natural person;

(e)

processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;

(f)

processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child.

Point (f) of the first subparagraph shall not apply to processing carried out by public authorities in the performance of their tasks.

2. Member States may maintain or introduce more specific provisions to adapt the application of the rules of this Regulation with regard to processing for compliance with points (c) and (e) of paragraph 1 by determining more precisely specific requirements for the processing and other measures to ensure lawful and fair processing including for other specific processing situations as provided for in Chapter IX.

3. The basis for the processing referred to in point (c) and (e) of paragraph 1 shall be laid down by:

(a)

Union law; or

(b)

Member State law to which the controller is subject.

The purpose of the processing shall be determined in that legal basis or, as regards the processing referred to in point (e) of paragraph 1, shall be necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller. That legal basis may contain specific provisions to adapt the application of rules of this Regulation, inter alia: the general conditions governing the lawfulness of processing by the controller; the types of data which are subject to the processing; the data subjects concerned; the entities to, and the purposes for which, the personal data may be disclosed; the purpose limitation; storage periods; and processing operations and processing procedures, including measures to ensure lawful and fair processing such as those for other specific processing situations as provided for in Chapter IX. The Union or the Member State law shall meet an objective of public interest and be proportionate to the legitimate aim pursued.

4. Where the processing for a purpose other than that for which the personal data have been collected is not based on the data subject's consent or on a Union or Member State law which constitutes a necessary and proportionate measure in a democratic society to safeguard the objectives referred to in Article 23(1), the controller shall, in order to ascertain whether

processing for another purpose is compatible with the purpose for which the personal data are initially collected, take into account, inter alia:

(a)

any link between the purposes for which the personal data have been collected and the purposes of the intended further processing;

(b)

the context in which the personal data have been collected, in particular regarding the relationship between data subjects and the controller;

(c)

the nature of the personal data, in particular whether special categories of personal data are processed, pursuant to Article 9, or whether personal data related to criminal convictions and offences are processed, pursuant to Article 10;

(d)

the possible consequences of the intended further processing for data subjects;

(e)

the existence of appropriate safeguards, which may include encryption or pseudonymisation.

GDPR · 7

Conditions for consent

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_7

Article 7

Conditions for consent

1. Where processing is based on consent, the controller shall be able to demonstrate that the data subject has consented to processing of his or her personal data.

2. If the data subject's consent is given in the context of a written declaration which also concerns other matters, the request for consent shall be presented in a manner which is clearly distinguishable from the other matters, in an intelligible and easily accessible form, using clear and plain language. Any part of such a declaration which constitutes an infringement of this Regulation shall not be binding.

3. The data subject shall have the right to withdraw his or her consent at any time. The withdrawal of consent shall not affect the lawfulness of processing based on consent before its withdrawal. Prior to giving consent, the data subject shall be informed thereof. It shall be as easy to withdraw as to give consent.

4. When assessing whether consent is freely given, utmost account shall be taken of whether, inter alia , the performance of a contract, including the provision of a service, is conditional on consent to the processing of personal data that is not necessary for the performance of that contract.

GDPR · 9

Processing of special categories of personal data

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_9

Article 9

Processing of special categories of personal data

1. Processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation shall be prohibited.

2. Paragraph 1 shall not apply if one of the following applies:

(a)

the data subject has given explicit consent to the processing of those personal data for one or more specified purposes, except where Union or Member State law provide that the prohibition referred to in paragraph 1 may not be lifted by the data subject;

(b)

processing is necessary for the purposes of carrying out the obligations and exercising specific rights of the controller or of the data subject in the field of employment and social security and social protection law in so far as it is authorised by Union or Member State law or a collective agreement pursuant to Member State law providing for appropriate safeguards for the fundamental rights and the interests of the data subject;

(c)

processing is necessary to protect the vital interests of the data subject or of another natural person where the data subject is physically or legally incapable of giving consent;

(d)

processing is carried out in the course of its legitimate activities with appropriate safeguards by a foundation, association or any other not-for-profit body with a political, philosophical, religious or trade union aim and on condition that the processing relates solely to the members or to former members of the body or to persons who have regular contact with it in connection with its purposes and that the personal data are not disclosed outside that body without the consent of the data subjects;

(e)

processing relates to personal data which are manifestly made public by the data subject;

(f)

processing is necessary for the establishment, exercise or defence of legal claims or whenever courts are acting in their judicial capacity;

(g)

processing is necessary for reasons of substantial public interest, on the basis of Union or Member State law which shall be proportionate to the aim pursued, respect the essence of the right to data protection and provide for suitable and specific measures to safeguard the fundamental rights and the interests of the data subject;

(h)

processing is necessary for the purposes of preventive or occupational medicine, for the assessment of the working capacity of the employee, medical diagnosis, the provision of health or social care or treatment or the management of health or social care systems and services on the basis of Union or Member State law or pursuant to contract with a health professional and subject to the conditions and safeguards referred to in paragraph 3;

(i)

processing is necessary for reasons of public interest in the area of public health, such as protecting against serious cross-border threats to health or ensuring high standards of quality and safety of health care and of medicinal products or medical devices, on the basis of Union or Member State law which provides for suitable and specific measures to safeguard the rights and freedoms of the data subject, in particular professional secrecy;

(j)

processing is necessary for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) based on Union or Member State law which shall be proportionate to the aim pursued, respect the essence of the right to data protection and provide for suitable and specific measures to safeguard the fundamental rights and the interests of the data subject.

3. Personal data referred to in paragraph 1 may be processed for the purposes referred to in point (h) of paragraph 2 when those data are processed by or under the responsibility of a professional subject to the obligation of professional secrecy under Union or Member State law or rules established by national competent bodies or by another person also subject to an obligation of secrecy under Union or Member State law or rules established by national competent bodies.

4. Member States may maintain or introduce further conditions, including limitations, with regard to the processing of genetic data, biometric data or data concerning health.

GDPR · 12

Transparent information, communication and modalities for the exercise of the rights of the data subject

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_12

Article 12

Transparent information, communication and modalities for the exercise of the rights of the data subject

1. The controller shall take appropriate measures to provide any information referred to in Articles 13 and 14 and any communication under Articles 15 to 22 and 34 relating to processing to the data subject in a concise, transparent, intelligible and easily accessible form, using clear and plain language, in particular for any information addressed specifically to a child. The information shall be provided in writing, or by other means, including, where appropriate, by electronic means. When requested by the data subject, the information may be provided orally, provided that the identity of the data subject is proven by other means.

2. The controller shall facilitate the exercise of data subject rights under Articles 15 to 22. In the cases referred to in Article 11(2), the controller shall not refuse to act on the request of the data subject for exercising his or her rights under Articles 15 to 22, unless the controller demonstrates that it is not in a position to identify the data subject.

3. The controller shall provide information on action taken on a request under Articles 15 to 22 to the data subject without undue delay and in any event within one month of receipt of the request. That period may be extended by two further months where necessary, taking into account the complexity and number of the requests. The controller shall inform the data subject of any such extension within one month of receipt of the request, together with the reasons for the delay. Where the data subject makes the request by electronic form means, the information shall be provided by electronic means where possible, unless otherwise requested by the data subject.

4. If the controller does not take action on the request of the data subject, the controller shall inform the data subject without delay and at the latest within one month of receipt of the request of the reasons for not taking action and on the possibility of lodging a complaint with a supervisory authority and seeking a judicial remedy.

5. Information provided under Articles 13 and 14 and any communication and any actions taken under Articles 15 to 22 and 34 shall be provided free of charge. Where requests from a data subject are manifestly unfounded or excessive, in particular because of their repetitive character, the controller may either:

(a)

charge a reasonable fee taking into account the administrative costs of providing the information or communication or taking the action requested; or

(b)

refuse to act on the request.

The controller shall bear the burden of demonstrating the manifestly unfounded or excessive character of the request.

6. Without prejudice to Article 11, where the controller has reasonable doubts concerning the identity of the natural person making the request referred to in Articles 15 to 21, the controller may request the provision of additional information necessary to confirm the identity of the data subject.

7. The information to be provided to data subjects pursuant to Articles 13 and 14 may be provided in combination with standardised icons in order to give in an easily visible, intelligible and clearly legible manner a meaningful overview of the intended processing. Where the icons are presented electronically they shall be machine-readable.

8. The Commission shall be empowered to adopt delegated acts in accordance with Article 92 for the purpose of determining the information to be presented by the icons and the procedures for providing standardised icons.

GDPR · 13

Information to be provided where personal data are collected from the data subject

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_13

Article 13

Information to be provided where personal data are collected from the data subject

1. Where personal data relating to a data subject are collected from the data subject, the controller shall, at the time when personal data are obtained, provide the data subject with all of the following information:

(a)

the identity and the contact details of the controller and, where applicable, of the controller's representative;

(b)

the contact details of the data protection officer, where applicable;

(c)

the purposes of the processing for which the personal data are intended as well as the legal basis for the processing;

(d)

where the processing is based on point (f) of Article 6(1), the legitimate interests pursued by the controller or by a third party;

(e)

the recipients or categories of recipients of the personal data, if any;

(f)

where applicable, the fact that the controller intends to transfer personal data to a third country or international organisation and the existence or absence of an adequacy decision by the Commission, or in the case of transfers referred to in Article 46 or 47, or the second subparagraph of Article 49(1), reference to the appropriate or suitable safeguards and the means by which to obtain a copy of them or where they have been made available.

2. In addition to the information referred to in paragraph 1, the controller shall, at the time when personal data are obtained, provide the data subject with the following further information necessary to ensure fair and transparent processing:

(a)

the period for which the personal data will be stored, or if that is not possible, the criteria used to determine that period;

(b)

the existence of the right to request from the controller access to and rectification or erasure of personal data or restriction of processing concerning the data subject or to object to processing as well as the right to data portability;

(c)

where the processing is based on point (a) of Article 6(1) or point (a) of Article 9(2), the existence of the right to withdraw consent at any time, without affecting the lawfulness of processing based on consent before its withdrawal;

(d)

the right to lodge a complaint with a supervisory authority;

(e)

whether the provision of personal data is a statutory or contractual requirement, or a requirement necessary to enter into a contract, as well as whether the data subject is obliged to provide the personal data and of the possible consequences of failure to provide such data;

(f)

the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.

3. Where the controller intends to further process the personal data for a purpose other than that for which the personal data were collected, the controller shall provide the data subject prior to that further processing with information on that other purpose and with any relevant further information as referred to in paragraph 2.

4. Paragraphs 1, 2 and 3 shall not apply where and insofar as the data subject already has the information.

GDPR · 14

Information to be provided where personal data have not been obtained from the data subject

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_14

Article 14

Information to be provided where personal data have not been obtained from the data subject

1. Where personal data have not been obtained from the data subject, the controller shall provide the data subject with the following information:

(a)

the identity and the contact details of the controller and, where applicable, of the controller's representative;

(b)

the contact details of the data protection officer, where applicable;

(c)

the purposes of the processing for which the personal data are intended as well as the legal basis for the processing;

(d)

the categories of personal data concerned;

(e)

the recipients or categories of recipients of the personal data, if any;

(f)

where applicable, that the controller intends to transfer personal data to a recipient in a third country or international organisation and the existence or absence of an adequacy decision by the Commission, or in the case of transfers referred to in Article 46 or 47, or the second subparagraph of Article 49(1), reference to the appropriate or suitable safeguards and the means to obtain a copy of them or where they have been made available.

2. In addition to the information referred to in paragraph 1, the controller shall provide the data subject with the following information necessary to ensure fair and transparent processing in respect of the data subject:

(a)

the period for which the personal data will be stored, or if that is not possible, the criteria used to determine that period;

(b)

where the processing is based on point (f) of Article 6(1), the legitimate interests pursued by the controller or by a third party;

(c)

the existence of the right to request from the controller access to and rectification or erasure of personal data or restriction of processing concerning the data subject and to object to processing as well as the right to data portability;

(d)

where processing is based on point (a) of Article 6(1) or point (a) of Article 9(2), the existence of the right to withdraw consent at any time, without affecting the lawfulness of processing based on consent before its withdrawal;

(e)

the right to lodge a complaint with a supervisory authority;

(f)

from which source the personal data originate, and if applicable, whether it came from publicly accessible sources;

(g)

the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.

3. The controller shall provide the information referred to in paragraphs 1 and 2:

(a)

within a reasonable period after obtaining the personal data, but at the latest within one month, having regard to the specific circumstances in which the personal data are processed;

(b)

if the personal data are to be used for communication with the data subject, at the latest at the time of the first communication to that data subject; or

(c)

if a disclosure to another recipient is envisaged, at the latest when the personal data are first disclosed.

4. Where the controller intends to further process the personal data for a purpose other than that for which the personal data were obtained, the controller shall provide the data subject prior to that further processing with information on that other purpose and with any relevant further information as referred to in paragraph 2.

5. Paragraphs 1 to 4 shall not apply where and insofar as:

(a)

the data subject already has the information;

(b)

the provision of such information proves impossible or would involve a disproportionate effort, in particular for processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes, subject to the conditions and safeguards referred to in Article 89(1) or in so far as the obligation referred to in paragraph 1 of this Article is likely to render impossible or seriously impair the achievement of the objectives of that processing. In such cases the controller shall take appropriate measures to protect the data subject's rights and freedoms and legitimate interests, including making the information publicly available;

(c)

obtaining or disclosure is expressly laid down by Union or Member State law to which the controller is subject and which provides appropriate measures to protect the data subject's legitimate interests; or

(d)

where the personal data must remain confidential subject to an obligation of professional secrecy regulated by Union or Member State law, including a statutory obligation of secrecy.

GDPR · 15

Right of access by the data subject

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_15

Article 15

Right of access by the data subject

1. The data subject shall have the right to obtain from the controller confirmation as to whether or not personal data concerning him or her are being processed, and, where that is the case, access to the personal data and the following information:

(a)

the purposes of the processing;

(b)

the categories of personal data concerned;

(c)

the recipients or categories of recipient to whom the personal data have been or will be disclosed, in particular recipients in third countries or international organisations;

(d)

where possible, the envisaged period for which the personal data will be stored, or, if not possible, the criteria used to determine that period;

(e)

the existence of the right to request from the controller rectification or erasure of personal data or restriction of processing of personal data concerning the data subject or to object to such processing;

(f)

the right to lodge a complaint with a supervisory authority;

(g)

where the personal data are not collected from the data subject, any available information as to their source;

(h)

the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.

2. Where personal data are transferred to a third country or to an international organisation, the data subject shall have the right to be informed of the appropriate safeguards pursuant to Article 46 relating to the transfer.

3. The controller shall provide a copy of the personal data undergoing processing. For any further copies requested by the data subject, the controller may charge a reasonable fee based on administrative costs. Where the data subject makes the request by electronic means, and unless otherwise requested by the data subject, the information shall be provided in a commonly used electronic form.

4. The right to obtain a copy referred to in paragraph 3 shall not adversely affect the rights and freedoms of others.

GDPR · 16

Right to rectification

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_16

Article 16

Right to rectification

The data subject shall have the right to obtain from the controller without undue delay the rectification of inaccurate personal data concerning him or her. Taking into account the purposes of the processing, the data subject shall have the right to have incomplete personal data completed, including by means of providing a supplementary statement.

GDPR · 17

Right to erasure (‘right to be forgotten’)

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_17

Article 17

Right to erasure (‘right to be forgotten’)

1. The data subject shall have the right to obtain from the controller the erasure of personal data concerning him or her without undue delay and the controller shall have the obligation to erase personal data without undue delay where one of the following grounds applies:

(a)

the personal data are no longer necessary in relation to the purposes for which they were collected or otherwise processed;

(b)

the data subject withdraws consent on which the processing is based according to point (a) of Article 6(1), or point (a) of Article 9(2), and where there is no other legal ground for the processing;

(c)

the data subject objects to the processing pursuant to Article 21(1) and there are no overriding legitimate grounds for the processing, or the data subject objects to the processing pursuant to Article 21(2);

(d)

the personal data have been unlawfully processed;

(e)

the personal data have to be erased for compliance with a legal obligation in Union or Member State law to which the controller is subject;

(f)

the personal data have been collected in relation to the offer of information society services referred to in Article 8(1).

2. Where the controller has made the personal data public and is obliged pursuant to paragraph 1 to erase the personal data, the controller, taking account of available technology and the cost of implementation, shall take reasonable steps, including technical measures, to inform controllers which are processing the personal data that the data subject has requested the erasure by such controllers of any links to, or copy or replication of, those personal data.

3. Paragraphs 1 and 2 shall not apply to the extent that processing is necessary:

(a)

for exercising the right of freedom of expression and information;

(b)

for compliance with a legal obligation which requires processing by Union or Member State law to which the controller is subject or for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;

(c)

for reasons of public interest in the area of public health in accordance with points (h) and (i) of Article 9(2) as well as Article 9(3);

(d)

for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) in so far as the right referred to in paragraph 1 is likely to render impossible or seriously impair the achievement of the objectives of that processing; or

(e)

for the establishment, exercise or defence of legal claims.

GDPR · 18

Right to restriction of processing

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_18

Article 18

Right to restriction of processing

1. The data subject shall have the right to obtain from the controller restriction of processing where one of the following applies:

(a)

the accuracy of the personal data is contested by the data subject, for a period enabling the controller to verify the accuracy of the personal data;

(b)

the processing is unlawful and the data subject opposes the erasure of the personal data and requests the restriction of their use instead;

(c)

the controller no longer needs the personal data for the purposes of the processing, but they are required by the data subject for the establishment, exercise or defence of legal claims;

(d)

the data subject has objected to processing pursuant to Article 21(1) pending the verification whether the legitimate grounds of the controller override those of the data subject.

2. Where processing has been restricted under paragraph 1, such personal data shall, with the exception of storage, only be processed with the data subject's consent or for the establishment, exercise or defence of legal claims or for the protection of the rights of another natural or legal person or for reasons of important public interest of the Union or of a Member State.

3. A data subject who has obtained restriction of processing pursuant to paragraph 1 shall be informed by the controller before the restriction of processing is lifted.

GDPR · 21

Right to object

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_21

Article 21

Right to object

1. The data subject shall have the right to object, on grounds relating to his or her particular situation, at any time to processing of personal data concerning him or her which is based on point (e) or (f) of Article 6(1), including profiling based on those provisions. The controller shall no longer process the personal data unless the controller demonstrates compelling legitimate grounds for the processing which override the interests, rights and freedoms of the data subject or for the establishment, exercise or defence of legal claims.

2. Where personal data are processed for direct marketing purposes, the data subject shall have the right to object at any time to processing of personal data concerning him or her for such marketing, which includes profiling to the extent that it is related to such direct marketing.

3. Where the data subject objects to processing for direct marketing purposes, the personal data shall no longer be processed for such purposes.

4. At the latest at the time of the first communication with the data subject, the right referred to in paragraphs 1 and 2 shall be explicitly brought to the attention of the data subject and shall be presented clearly and separately from any other information.

5. In the context of the use of information society services, and notwithstanding Directive 2002/58/EC, the data subject may exercise his or her right to object by automated means using technical specifications.

6. Where personal data are processed for scientific or historical research purposes or statistical purposes pursuant to Article 89(1), the data subject, on grounds relating to his or her particular situation, shall have the right to object to processing of personal data concerning him or her, unless the processing is necessary for the performance of a task carried out for reasons of public interest.

GDPR · 22

Automated individual decision-making, including profiling

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

Article 22

Automated individual decision-making, including profiling

1. The data subject shall have the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning him or her or similarly significantly affects him or her.

2. Paragraph 1 shall not apply if the decision:

(a)

is necessary for entering into, or performance of, a contract between the data subject and a data controller;

(b)

is authorised by Union or Member State law to which the controller is subject and which also lays down suitable measures to safeguard the data subject's rights and freedoms and legitimate interests; or

(c)

is based on the data subject's explicit consent.

3. In the cases referred to in points (a) and (c) of paragraph 2, the data controller shall implement suitable measures to safeguard the data subject's rights and freedoms and legitimate interests, at least the right to obtain human intervention on the part of the controller, to express his or her point of view and to contest the decision.

4. Decisions referred to in paragraph 2 shall not be based on special categories of personal data referred to in Article 9(1), unless point (a) or (g) of Article 9(2) applies and suitable measures to safeguard the data subject's rights and freedoms and legitimate interests are in place.

GDPR · 24

Responsibility of the controller

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_24

Article 24

Responsibility of the controller

1. Taking into account the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller shall implement appropriate technical and organisational measures to ensure and to be able to demonstrate that processing is performed in accordance with this Regulation. Those measures shall be reviewed and updated where necessary.

2. Where proportionate in relation to processing activities, the measures referred to in paragraph 1 shall include the implementation of appropriate data protection policies by the controller.

3. Adherence to approved codes of conduct as referred to in Article 40 or approved certification mechanisms as referred to in Article 42 may be used as an element by which to demonstrate compliance with the obligations of the controller.

GDPR · 25

Data protection by design and by default

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_25

Article 25

Data protection by design and by default

1. Taking into account the state of the art, the cost of implementation and the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for rights and freedoms of natural persons posed by the processing, the controller shall, both at the time of the determination of the means for processing and at the time of the processing itself, implement appropriate technical and organisational measures, such as pseudonymisation, which are designed to implement data-protection principles, such as data minimisation, in an effective manner and to integrate the necessary safeguards into the processing in order to meet the requirements of this Regulation and protect the rights of data subjects.

2. The controller shall implement appropriate technical and organisational measures for ensuring that, by default, only personal data which are necessary for each specific purpose of the processing are processed. That obligation applies to the amount of personal data collected, the extent of their processing, the period of their storage and their accessibility. In particular, such measures shall ensure that by default personal data are not made accessible without the individual's intervention to an indefinite number of natural persons.

3. An approved certification mechanism pursuant to Article 42 may be used as an element to demonstrate compliance with the requirements set out in paragraphs 1 and 2 of this Article.

GDPR · 28

Processor

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_28

Article 28

Processor

1. Where processing is to be carried out on behalf of a controller, the controller shall use only processors providing sufficient guarantees to implement appropriate technical and organisational measures in such a manner that processing will meet the requirements of this Regulation and ensure the protection of the rights of the data subject.

2. The processor shall not engage another processor without prior specific or general written authorisation of the controller. In the case of general written authorisation, the processor shall inform the controller of any intended changes concerning the addition or replacement of other processors, thereby giving the controller the opportunity to object to such changes.

3. Processing by a processor shall be governed by a contract or other legal act under Union or Member State law, that is binding on the processor with regard to the controller and that sets out the subject-matter and duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects and the obligations and rights of the controller. That contract or other legal act shall stipulate, in particular, that the processor:

(a)

processes the personal data only on documented instructions from the controller, including with regard to transfers of personal data to a third country or an international organisation, unless required to do so by Union or Member State law to which the processor is subject; in such a case, the processor shall inform the controller of that legal requirement before processing, unless that law prohibits such information on important grounds of public interest;

(b)

ensures that persons authorised to process the personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;

(c)

takes all measures required pursuant to Article 32;

(d)

respects the conditions referred to in paragraphs 2 and 4 for engaging another processor;

(e)

taking into account the nature of the processing, assists the controller by appropriate technical and organisational measures, insofar as this is possible, for the fulfilment of the controller's obligation to respond to requests for exercising the data subject's rights laid down in Chapter III;

(f)

assists the controller in ensuring compliance with the obligations pursuant to Articles 32 to 36 taking into account the nature of processing and the information available to the processor;

(g)

at the choice of the controller, deletes or returns all the personal data to the controller after the end of the provision of services relating to processing, and deletes existing copies unless Union or Member State law requires storage of the personal data;

(h)

makes available to the controller all information necessary to demonstrate compliance with the obligations laid down in this Article and allow for and contribute to audits, including inspections, conducted by the controller or another auditor mandated by the controller.

With regard to point (h) of the first subparagraph, the processor shall immediately inform the controller if, in its opinion, an instruction infringes this Regulation or other Union or Member State data protection provisions.

4. Where a processor engages another processor for carrying out specific processing activities on behalf of the controller, the same data protection obligations as set out in the contract or other legal act between the controller and the processor as referred to in paragraph 3 shall be imposed on that other processor by way of a contract or other legal act under Union or Member State law, in particular providing sufficient guarantees to implement appropriate technical and organisational measures in such a manner that the processing will meet the requirements of this Regulation. Where that other processor fails to fulfil its data protection obligations, the initial processor shall remain fully liable to the controller for the performance of that other processor's obligations.

5. Adherence of a processor to an approved code of conduct as referred to in Article 40 or an approved certification mechanism as referred to in Article 42 may be used as an element by which to demonstrate sufficient guarantees as referred to in paragraphs 1 and 4 of this Article.

6. Without prejudice to an individual contract between the controller and the processor, the contract or the other legal act referred to in paragraphs 3 and 4 of this Article may be based, in whole or in part, on standard contractual clauses referred to in paragraphs 7 and 8 of this Article, including when they are part of a certification granted to the controller or processor pursuant to Articles 42 and 43.

7. The Commission may lay down standard contractual clauses for the matters referred to in paragraph 3 and 4 of this Article and in accordance with the examination procedure referred to in Article 93(2).

8. A supervisory authority may adopt standard contractual clauses for the matters referred to in paragraph 3 and 4 of this Article and in accordance with the consistency mechanism referred to in Article 63.

9. The contract or the other legal act referred to in paragraphs 3 and 4 shall be in writing, including in electronic form.

10. Without prejudice to Articles 82, 83 and 84, if a processor infringes this Regulation by determining the purposes and means of processing, the processor shall be considered to be a controller in respect of that processing.

GDPR · 30

Records of processing activities

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_30

Article 30

Records of processing activities

1. Each controller and, where applicable, the controller's representative, shall maintain a record of processing activities under its responsibility. That record shall contain all of the following information:

(a)

the name and contact details of the controller and, where applicable, the joint controller, the controller's representative and the data protection officer;

(b)

the purposes of the processing;

(c)

a description of the categories of data subjects and of the categories of personal data;

(d)

the categories of recipients to whom the personal data have been or will be disclosed including recipients in third countries or international organisations;

(e)

where applicable, transfers of personal data to a third country or an international organisation, including the identification of that third country or international organisation and, in the case of transfers referred to in the second subparagraph of Article 49(1), the documentation of suitable safeguards;

(f)

where possible, the envisaged time limits for erasure of the different categories of data;

(g)

where possible, a general description of the technical and organisational security measures referred to in Article 32(1).

2. Each processor and, where applicable, the processor's representative shall maintain a record of all categories of processing activities carried out on behalf of a controller, containing:

(a)

the name and contact details of the processor or processors and of each controller on behalf of which the processor is acting, and, where applicable, of the controller's or the processor's representative, and the data protection officer;

(b)

the categories of processing carried out on behalf of each controller;

(c)

where applicable, transfers of personal data to a third country or an international organisation, including the identification of that third country or international organisation and, in the case of transfers referred to in the second subparagraph of Article 49(1), the documentation of suitable safeguards;

(d)

where possible, a general description of the technical and organisational security measures referred to in Article 32(1).

3. The records referred to in paragraphs 1 and 2 shall be in writing, including in electronic form.

4. The controller or the processor and, where applicable, the controller's or the processor's representative, shall make the record available to the supervisory authority on request.

5. The obligations referred to in paragraphs 1 and 2 shall not apply to an enterprise or an organisation employing fewer than 250 persons unless the processing it carries out is likely to result in a risk to the rights and freedoms of data subjects, the processing is not occasional, or the processing includes special categories of data as referred to in Article 9(1) or personal data relating to criminal convictions and offences referred to in Article 10.

GDPR · 32

Security of processing

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_32

Article 32

Security of processing

1. Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as appropriate:

(a)

the pseudonymisation and encryption of personal data;

(b)

the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services;

(c)

the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident;

(d)

a process for regularly testing, assessing and evaluating the effectiveness of technical and organisational measures for ensuring the security of the processing.

2. In assessing the appropriate level of security account shall be taken in particular of the risks that are presented by processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data transmitted, stored or otherwise processed.

3. Adherence to an approved code of conduct as referred to in Article 40 or an approved certification mechanism as referred to in Article 42 may be used as an element by which to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and processor shall take steps to ensure that any natural person acting under the authority of the controller or the processor who has access to personal data does not process them except on instructions from the controller, unless he or she is required to do so by Union or Member State law.

GDPR · 33

Notification of a personal data breach to the supervisory authority

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_33

Article 33

Notification of a personal data breach to the supervisory authority

1. In the case of a personal data breach, the controller shall without undue delay and, where feasible, not later than 72 hours after having become aware of it, notify the personal data breach to the supervisory authority competent in accordance with Article 55, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. Where the notification to the supervisory authority is not made within 72 hours, it shall be accompanied by reasons for the delay.

2. The processor shall notify the controller without undue delay after becoming aware of a personal data breach.

3. The notification referred to in paragraph 1 shall at least:

(a)

describe the nature of the personal data breach including where possible, the categories and approximate number of data subjects concerned and the categories and approximate number of personal data records concerned;

(b)

communicate the name and contact details of the data protection officer or other contact point where more information can be obtained;

(c)

describe the likely consequences of the personal data breach;

(d)

describe the measures taken or proposed to be taken by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

4. Where, and in so far as, it is not possible to provide the information at the same time, the information may be provided in phases without undue further delay.

5. The controller shall document any personal data breaches, comprising the facts relating to the personal data breach, its effects and the remedial action taken. That documentation shall enable the supervisory authority to verify compliance with this Article.

GDPR · 34

Communication of a personal data breach to the data subject

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_34

Article 34

Communication of a personal data breach to the data subject

1. When the personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall communicate the personal data breach to the data subject without undue delay.

2. The communication to the data subject referred to in paragraph 1 of this Article shall describe in clear and plain language the nature of the personal data breach and contain at least the information and measures referred to in points (b), (c) and (d) of Article 33(3).

3. The communication to the data subject referred to in paragraph 1 shall not be required if any of the following conditions are met:

(a)

the controller has implemented appropriate technical and organisational protection measures, and those measures were applied to the personal data affected by the personal data breach, in particular those that render the personal data unintelligible to any person who is not authorised to access it, such as encryption;

(b)

the controller has taken subsequent measures which ensure that the high risk to the rights and freedoms of data subjects referred to in paragraph 1 is no longer likely to materialise;

(c)

it would involve disproportionate effort. In such a case, there shall instead be a public communication or similar measure whereby the data subjects are informed in an equally effective manner.

4. If the controller has not already communicated the personal data breach to the data subject, the supervisory authority, having considered the likelihood of the personal data breach resulting in a high risk, may require it to do so or may decide that any of the conditions referred to in paragraph 3 are met.

GDPR · 35

Data protection impact assessment

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_35

Article 35

Data protection impact assessment

1. Where a type of processing in particular using new technologies, and taking into account the nature, scope, context and purposes of the processing, is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall, prior to the processing, carry out an assessment of the impact of the envisaged processing operations on the protection of personal data. A single assessment may address a set of similar processing operations that present similar high risks.

2. The controller shall seek the advice of the data protection officer, where designated, when carrying out a data protection impact assessment.

3. A data protection impact assessment referred to in paragraph 1 shall in particular be required in the case of:

(a)

a systematic and extensive evaluation of personal aspects relating to natural persons which is based on automated processing, including profiling, and on which decisions are based that produce legal effects concerning the natural person or similarly significantly affect the natural person;

(b)

processing on a large scale of special categories of data referred to in Article 9(1), or of personal data relating to criminal convictions and offences referred to in Article 10; or

(c)

a systematic monitoring of a publicly accessible area on a large scale.

4. The supervisory authority shall establish and make public a list of the kind of processing operations which are subject to the requirement for a data protection impact assessment pursuant to paragraph 1. The supervisory authority shall communicate those lists to the Board referred to in Article 68.

5. The supervisory authority may also establish and make public a list of the kind of processing operations for which no data protection impact assessment is required. The supervisory authority shall communicate those lists to the Board.

6. Prior to the adoption of the lists referred to in paragraphs 4 and 5, the competent supervisory authority shall apply the consistency mechanism referred to in Article 63 where such lists involve processing activities which are related to the offering of goods or services to data subjects or to the monitoring of their behaviour in several Member States, or may substantially affect the free movement of personal data within the Union.

7. The assessment shall contain at least:

(a)

a systematic description of the envisaged processing operations and the purposes of the processing, including, where applicable, the legitimate interest pursued by the controller;

(b)

an assessment of the necessity and proportionality of the processing operations in relation to the purposes;

(c)

an assessment of the risks to the rights and freedoms of data subjects referred to in paragraph 1; and

(d)

the measures envisaged to address the risks, including safeguards, security measures and mechanisms to ensure the protection of personal data and to demonstrate compliance with this Regulation taking into account the rights and legitimate interests of data subjects and other persons concerned.

8. Compliance with approved codes of conduct referred to in Article 40 by the relevant controllers or processors shall be taken into due account in assessing the impact of the processing operations performed by such controllers or processors,

in particular for the purposes of a data protection impact assessment.

9. Where appropriate, the controller shall seek the views of data subjects or their representatives on the intended processing, without prejudice to the protection of commercial or public interests or the security of processing operations.

10. Where processing pursuant to point (c) or (e) of Article 6(1) has a legal basis in Union law or in the law of the Member State to which the controller is subject, that law regulates the specific processing operation or set of operations in question, and a data protection impact assessment has already been carried out as part of a general impact assessment in the context of the adoption of that legal basis, paragraphs 1 to 7 shall not apply unless Member States deem it to be necessary to carry out such an assessment prior to processing activities.

11. Where necessary, the controller shall carry out a review to assess if processing is performed in accordance with the data protection impact assessment at least when there is a change of the risk represented by processing operations.

GDPR · 36

Prior consultation

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_36

Article 36

Prior consultation

1. The controller shall consult the supervisory authority prior to processing where a data protection impact assessment under Article 35 indicates that the processing would result in a high risk in the absence of measures taken by the controller to mitigate the risk.

2. Where the supervisory authority is of the opinion that the intended processing referred to in paragraph 1 would infringe this Regulation, in particular where the controller has insufficiently identified or mitigated the risk, the supervisory authority shall, within period of up to eight weeks of receipt of the request for consultation, provide written advice to the controller and, where applicable to the processor, and may use any of its powers referred to in Article 58. That period may be extended by six weeks, taking into account the complexity of the intended processing. The supervisory authority shall inform the controller and, where applicable, the processor, of any such extension within one month of receipt of the request for consultation together with the reasons for the delay. Those periods may be suspended until the supervisory authority has obtained information it has requested for the purposes of the consultation.

3. When consulting the supervisory authority pursuant to paragraph 1, the controller shall provide the supervisory authority with:

(a)

where applicable, the respective responsibilities of the controller, joint controllers and processors involved in the processing, in particular for processing within a group of undertakings;

(b)

the purposes and means of the intended processing;

(c)

the measures and safeguards provided to protect the rights and freedoms of data subjects pursuant to this Regulation;

(d)

where applicable, the contact details of the data protection officer;

(e)

the data protection impact assessment provided for in Article 35; and

(f)

any other information requested by the supervisory authority.

4. Member States shall consult the supervisory authority during the preparation of a proposal for a legislative measure to be adopted by a national parliament, or of a regulatory measure based on such a legislative measure, which relates to processing.

5. Notwithstanding paragraph 1, Member State law may require controllers to consult with, and obtain prior authorisation from, the supervisory authority in relation to processing by a controller for the performance of a task carried out by the controller in the public interest, including processing in relation to social protection and public health.

GDPR · 37

Designation of the data protection officer

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_37

Article 37

Designation of the data protection officer

1. The controller and the processor shall designate a data protection officer in any case where:

(a)

the processing is carried out by a public authority or body, except for courts acting in their judicial capacity;

(b)

the core activities of the controller or the processor consist of processing operations which, by virtue of their nature, their scope and/or their purposes, require regular and systematic monitoring of data subjects on a large scale; or

(c)

the core activities of the controller or the processor consist of processing on a large scale of special categories of data pursuant to Article 9 and personal data relating to criminal convictions and offences referred to in Article 10.

2. A group of undertakings may appoint a single data protection officer provided that a data protection officer is easily accessible from each establishment.

3. Where the controller or the processor is a public authority or body, a single data protection officer may be designated for several such authorities or bodies, taking account of their organisational structure and size.

4. In cases other than those referred to in paragraph 1, the controller or processor or associations and other bodies representing categories of controllers or processors may or, where required by Union or Member State law shall, designate a data protection officer. The data protection officer may act for such associations and other bodies representing controllers or processors.

5. The data protection officer shall be designated on the basis of professional qualities and, in particular, expert knowledge of data protection law and practices and the ability to fulfil the tasks referred to in Article 39.

6. The data protection officer may be a staff member of the controller or processor, or fulfil the tasks on the basis of a service contract.

7. The controller or the processor shall publish the contact details of the data protection officer and communicate them to the supervisory authority.

GDPR · 38

Position of the data protection officer

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_38

Article 38

Position of the data protection officer

1. The controller and the processor shall ensure that the data protection officer is involved, properly and in a timely manner, in all issues which relate to the protection of personal data.

2. The controller and processor shall support the data protection officer in performing the tasks referred to in Article 39 by providing resources necessary to carry out those tasks and access to personal data and processing operations, and to maintain his or her expert knowledge.

3. The controller and processor shall ensure that the data protection officer does not receive any instructions regarding the exercise of those tasks. He or she shall not be dismissed or penalised by the controller or the processor for performing his tasks. The data protection officer shall directly report to the highest management level of the controller or the processor.

4. Data subjects may contact the data protection officer with regard to all issues related to processing of their personal data and to the exercise of their rights under this Regulation.

5. The data protection officer shall be bound by secrecy or confidentiality concerning the performance of his or her tasks, in accordance with Union or Member State law.

6. The data protection officer may fulfil other tasks and duties. The controller or processor shall ensure that any such tasks and duties do not result in a conflict of interests.

GDPR · 39

Tasks of the data protection officer

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_39

Article 39

Tasks of the data protection officer

1. The data protection officer shall have at least the following tasks:

(a)

to inform and advise the controller or the processor and the employees who carry out processing of their obligations pursuant to this Regulation and to other Union or Member State data protection provisions;

(b)

to monitor compliance with this Regulation, with other Union or Member State data protection provisions and with the policies of the controller or processor in relation to the protection of personal data, including the assignment of responsibilities, awareness-raising and training of staff involved in processing operations, and the related audits;

(c)

to provide advice where requested as regards the data protection impact assessment and monitor its performance pursuant to Article 35;

(d)

to cooperate with the supervisory authority;

(e)

to act as the contact point for the supervisory authority on issues relating to processing, including the prior consultation referred to in Article 36, and to consult, where appropriate, with regard to any other matter.

2. The data protection officer shall in the performance of his or her tasks have due regard to the risk associated with processing operations, taking into account the nature, scope, context and purposes of processing.

GDPR · 44

General principle for transfers

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_44

Article 44

General principle for transfers

Any transfer of personal data which are undergoing processing or are intended for processing after transfer to a third country or to an international organisation shall take place only if, subject to the other provisions of this Regulation, the conditions laid down in this Chapter are complied with by the controller and processor, including for onward transfers of personal data from the third country or an international organisation to another third country or to another international organisation. All provisions in this Chapter shall be applied in order to ensure that the level of protection of natural persons guaranteed by this Regulation is not undermined.

GDPR · 45

Transfers on the basis of an adequacy decision

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_45

Article 45

Transfers on the basis of an adequacy decision

1. A transfer of personal data to a third country or an international organisation may take place where the Commission has decided that the third country, a territory or one or more specified sectors within that third country, or the international organisation in question ensures an adequate level of protection. Such a transfer shall not require any specific authorisation.

2. When assessing the adequacy of the level of protection, the Commission shall, in particular, take account of the following elements:

(a)

the rule of law, respect for human rights and fundamental freedoms, relevant legislation, both general and sectoral, including concerning public security, defence, national security and criminal law and the access of public authorities to personal data, as well as the implementation of such legislation, data protection rules, professional rules and security measures, including rules for the onward transfer of personal data to another third country or international organisation which are complied with in that country or international organisation, case-law, as well as effective and enforceable data subject rights and effective administrative and judicial redress for the data subjects whose personal data are being transferred;

(b)

the existence and effective functioning of one or more independent supervisory authorities in the third country or to which an international organisation is subject, with responsibility for ensuring and enforcing compliance with the data protection rules, including adequate enforcement powers, for assisting and advising the data subjects in exercising their rights and for cooperation with the supervisory authorities of the Member States; and

(c)

the international commitments the third country or international organisation concerned has entered into, or other obligations arising from legally binding conventions or instruments as well as from its participation in multilateral or regional systems, in particular in relation to the protection of personal data.

3. The Commission, after assessing the adequacy of the level of protection, may decide, by means of implementing act, that a third country, a territory or one or more specified sectors within a third country, or an international organisation ensures an adequate level of protection within the meaning of paragraph 2 of this Article. The implementing act shall provide for a mechanism for a periodic review, at least every four years, which shall take into account all relevant developments in the third country or international organisation. The implementing act shall specify its territorial and sectoral application and, where applicable, identify the supervisory authority or authorities referred to in point (b) of paragraph 2 of this Article. The implementing act shall be adopted in accordance with the examination procedure referred to in Article 93(2).

4. The Commission shall, on an ongoing basis, monitor developments in third countries and international organisations that could affect the functioning of decisions adopted pursuant to paragraph 3 of this Article and decisions adopted on the basis of Article 25(6) of Directive 95/46/EC.

5. The Commission shall, where available information reveals, in particular following the review referred to in paragraph 3 of this Article, that a third country, a territory or one or more specified sectors within a third country, or an international organisation no longer ensures an adequate level of protection within the meaning of paragraph 2 of this Article, to the extent necessary, repeal, amend or suspend the decision referred to in paragraph 3 of this Article by means of implementing acts without retro-active effect. Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 93(2).

On duly justified imperative grounds of urgency, the Commission shall adopt immediately applicable implementing acts in accordance with the procedure referred to in Article 93(3).

6. The Commission shall enter into consultations with the third country or international organisation with a view to remedying the situation giving rise to the decision made pursuant to paragraph 5.

7. A decision pursuant to paragraph 5 of this Article is without prejudice to transfers of personal data to the third country, a territory or one or more specified sectors within that third country, or the international organisation in question pursuant to Articles 46 to 49.

8. The Commission shall publish in the Official Journal of the European Union and on its website a list of the third countries, territories and specified sectors within a third country and international organisations for which it has decided that an adequate level of protection is or is no longer ensured.

9. Decisions adopted by the Commission on the basis of Article 25(6) of Directive 95/46/EC shall remain in force until amended, replaced or repealed by a Commission Decision adopted in accordance with paragraph 3 or 5 of this Article.

GDPR · 46

Transfers subject to appropriate safeguards

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_46

Article 46

Transfers subject to appropriate safeguards

1. In the absence of a decision pursuant to Article 45(3), a controller or processor may transfer personal data to a third country or an international organisation only if the controller or processor has provided appropriate safeguards, and on condition that enforceable data subject rights and effective legal remedies for data subjects are available.

2. The appropriate safeguards referred to in paragraph 1 may be provided for, without requiring any specific authorisation from a supervisory authority, by:

(a)

a legally binding and enforceable instrument between public authorities or bodies;

(b)

binding corporate rules in accordance with Article 47;

(c)

standard data protection clauses adopted by the Commission in accordance with the examination procedure referred to in Article 93(2);

(d)

standard data protection clauses adopted by a supervisory authority and approved by the Commission pursuant to the examination procedure referred to in Article 93(2);

(e)

an approved code of conduct pursuant to Article 40 together with binding and enforceable commitments of the controller or processor in the third country to apply the appropriate safeguards, including as regards data subjects' rights; or

(f)

an approved certification mechanism pursuant to Article 42 together with binding and enforceable commitments of the controller or processor in the third country to apply the appropriate safeguards, including as regards data subjects' rights.

3. Subject to the authorisation from the competent supervisory authority, the appropriate safeguards referred to in paragraph 1 may also be provided for, in particular, by:

(a)

contractual clauses between the controller or processor and the controller, processor or the recipient of the personal data in the third country or international organisation; or

(b)

provisions to be inserted into administrative arrangements between public authorities or bodies which include enforceable and effective data subject rights.

4. The supervisory authority shall apply the consistency mechanism referred to in Article 63 in the cases referred to in paragraph 3 of this Article.

5. Authorisations by a Member State or supervisory authority on the basis of Article 26(2) of Directive 95/46/EC shall remain valid until amended, replaced or repealed, if necessary, by that supervisory authority. Decisions adopted by the Commission on the basis of Article 26(4) of Directive 95/46/EC shall remain in force until amended, replaced or repealed, if necessary, by a Commission Decision adopted in accordance with paragraph 2 of this Article.

GDPR · 48

Transfers or disclosures not authorised by Union law

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_48

Article 48

Transfers or disclosures not authorised by Union law

Any judgment of a court or tribunal and any decision of an administrative authority of a third country requiring a controller or processor to transfer or disclose personal data may only be recognised or enforceable in any manner if based on an international agreement, such as a mutual legal assistance treaty, in force between the requesting third country and the Union or a Member State, without prejudice to other grounds for transfer pursuant to this Chapter.

GDPR · 49

Derogations for specific situations

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_49

Article 49

Derogations for specific situations

1. In the absence of an adequacy decision pursuant to Article 45(3), or of appropriate safeguards pursuant to Article 46, including binding corporate rules, a transfer or a set of transfers of personal data to a third country or an international organisation shall take place only on one of the following conditions:

(a)

the data subject has explicitly consented to the proposed transfer, after having been informed of the possible risks of such transfers for the data subject due to the absence of an adequacy decision and appropriate safeguards;

(b)

the transfer is necessary for the performance of a contract between the data subject and the controller or the implementation of pre-contractual measures taken at the data subject's request;

(c)

the transfer is necessary for the conclusion or performance of a contract concluded in the interest of the data subject between the controller and another natural or legal person;

(d)

the transfer is necessary for important reasons of public interest;

(e)

the transfer is necessary for the establishment, exercise or defence of legal claims;

(f)

the transfer is necessary in order to protect the vital interests of the data subject or of other persons, where the data subject is physically or legally incapable of giving consent;

(g)

the transfer is made from a register which according to Union or Member State law is intended to provide information to the public and which is open to consultation either by the public in general or by any person who can demonstrate a legitimate interest, but only to the extent that the conditions laid down by Union or Member State law for consultation are fulfilled in the particular case.

Where a transfer could not be based on a provision in Article 45 or 46, including the provisions on binding corporate rules, and none of the derogations for a specific situation referred to in the first subparagraph of this paragraph is applicable, a transfer to a third country or an international organisation may take place only if the transfer is not repetitive, concerns only a limited number of data subjects, is necessary for the purposes of compelling legitimate interests pursued by the controller which are not overridden by the interests or rights and freedoms of the data subject, and the controller has assessed all the circumstances surrounding the data transfer and has on the basis of that assessment provided suitable safeguards with regard to the protection of personal data. The controller shall inform the supervisory authority of the transfer. The controller shall, in addition to providing the information referred to in Articles 13 and 14, inform the data subject of the transfer and on the compelling legitimate interests pursued.

2. A transfer pursuant to point (g) of the first subparagraph of paragraph 1 shall not involve the entirety of the personal data or entire categories of the personal data contained in the register. Where the register is intended for consultation by persons having a legitimate interest, the transfer shall be made only at the request of those persons or if they are to be the recipients.

3. Points (a), (b) and (c) of the first subparagraph of paragraph 1 and the second subparagraph thereof shall not apply to activities carried out by public authorities in the exercise of their public powers.

4. The public interest referred to in point (d) of the first subparagraph of paragraph 1 shall be recognised in Union law or in the law of the Member State to which the controller is subject.

5. In the absence of an adequacy decision, Union or Member State law may, for important reasons of public interest, expressly set limits to the transfer of specific categories of personal data to a third country or an international organisation. Member States shall notify such provisions to the Commission.

6. The controller or processor shall document the assessment as well as the suitable safeguards referred to in the second subparagraph of paragraph 1 of this Article in the records referred to in Article 30.

GDPR · 77

Right to lodge a complaint with a supervisory authority

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_77

Article 77

Right to lodge a complaint with a supervisory authority

1. Without prejudice to any other administrative or judicial remedy, every data subject shall have the right to lodge a complaint with a supervisory authority, in particular in the Member State of his or her habitual residence, place of work or place of the alleged infringement if the data subject considers that the processing of personal data relating to him or her infringes this Regulation.

2. The supervisory authority with which the complaint has been lodged shall inform the complainant on the progress and the outcome of the complaint including the possibility of a judicial remedy pursuant to Article 78.

GDPR · 79

Right to an effective judicial remedy against a controller or processor

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_79

Article 79

Right to an effective judicial remedy against a controller or processor

1. Without prejudice to any available administrative or non-judicial remedy, including the right to lodge a complaint with a supervisory authority pursuant to Article 77, each data subject shall have the right to an effective judicial remedy where he or she considers that his or her rights under this Regulation have been infringed as a result of the processing of his or her personal data in non-compliance with this Regulation.

2. Proceedings against a controller or a processor shall be brought before the courts of the Member State where the controller or processor has an establishment. Alternatively, such proceedings may be brought before the courts of the Member State where the data subject has his or her habitual residence, unless the controller or processor is a public authority of a Member State acting in the exercise of its public powers.

GDPR · 82

Right to compensation and liability

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_82

Article 82

Right to compensation and liability

1. Any person who has suffered material or non-material damage as a result of an infringement of this Regulation shall have the right to receive compensation from the controller or processor for the damage suffered.

2. Any controller involved in processing shall be liable for the damage caused by processing which infringes this Regulation. A processor shall be liable for the damage caused by processing only where it has not complied with obligations of this Regulation specifically directed to processors or where it has acted outside or contrary to lawful instructions of the controller.

3. A controller or processor shall be exempt from liability under paragraph 2 if it proves that it is not in any way responsible for the event giving rise to the damage.

4. Where more than one controller or processor, or both a controller and a processor, are involved in the same processing and where they are, under paragraphs 2 and 3, responsible for any damage caused by processing, each controller or processor shall be held liable for the entire damage in order to ensure effective compensation of the data subject.

5. Where a controller or processor has, in accordance with paragraph 4, paid full compensation for the damage suffered, that controller or processor shall be entitled to claim back from the other controllers or processors involved in the same processing that part of the compensation corresponding to their part of responsibility for the damage, in accordance with the conditions set out in paragraph 2.

6. Court proceedings for exercising the right to receive compensation shall be brought before the courts competent under the law of the Member State referred to in Article 79(2).

GDPR · 83

General conditions for imposing administrative fines

2016/679, official published text · English

https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_83

Article 83

General conditions for imposing administrative fines

1. Each supervisory authority shall ensure that the imposition of administrative fines pursuant to this Article in respect of infringements of this Regulation referred to in paragraphs 4, 5 and 6 shall in each individual case be effective, proportionate and dissuasive.

2. Administrative fines shall, depending on the circumstances of each individual case, be imposed in addition to, or instead of, measures referred to in points (a) to (h) and (j) of Article 58(2). When deciding whether to impose an administrative fine and deciding on the amount of the administrative fine in each individual case due regard shall be given to the following:

(a)

the nature, gravity and duration of the infringement taking into account the nature scope or purpose of the processing concerned as well as the number of data subjects affected and the level of damage suffered by them;

(b)

the intentional or negligent character of the infringement;

(c)

any action taken by the controller or processor to mitigate the damage suffered by data subjects;

(d)

the degree of responsibility of the controller or processor taking into account technical and organisational measures implemented by them pursuant to Articles 25 and 32;

(e)

any relevant previous infringements by the controller or processor;

(f)

the degree of cooperation with the supervisory authority, in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

(g)

the categories of personal data affected by the infringement;

(h)

the manner in which the infringement became known to the supervisory authority, in particular whether, and if so to what extent, the controller or processor notified the infringement;

(i)

where measures referred to in Article 58(2) have previously been ordered against the controller or processor concerned with regard to the same subject-matter, compliance with those measures;

(j)

adherence to approved codes of conduct pursuant to Article 40 or approved certification mechanisms pursuant to Article 42; and

(k)

any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits gained, or losses avoided, directly or indirectly, from the infringement.

3. If a controller or processor intentionally or negligently, for the same or linked processing operations, infringes several provisions of this Regulation, the total amount of the administrative fine shall not exceed the amount specified for the gravest infringement.

4. Infringements of the following provisions shall, in accordance with paragraph 2, be subject to administrative fines up to 10 000 000 EUR, or in the case of an undertaking, up to 2 % of the total worldwide annual turnover of the preceding financial year, whichever is higher:

(a)

the obligations of the controller and the processor pursuant to Articles 8, 11, 25 to 39 and 42 and 43;

(b)

the obligations of the certification body pursuant to Articles 42 and 43;

(c)

the obligations of the monitoring body pursuant to Article 41(4).

5. Infringements of the following provisions shall, in accordance with paragraph 2, be subject to administrative fines up to 20 000 000 EUR, or in the case of an undertaking, up to 4 % of the total worldwide annual turnover of the preceding financial year, whichever is higher:

(a)

the basic principles for processing, including conditions for consent, pursuant to Articles 5, 6, 7 and 9;

(b)

the data subjects' rights pursuant to Articles 12 to 22;

(c)

the transfers of personal data to a recipient in a third country or an international organisation pursuant to Articles 44 to 49;

(d)

any obligations pursuant to Member State law adopted under Chapter IX;

(e)

non-compliance with an order or a temporary or definitive limitation on processing or the suspension of data flows by the supervisory authority pursuant to Article 58(2) or failure to provide access in violation of Article 58(1).

6. Non-compliance with an order by the supervisory authority as referred to in Article 58(2) shall, in accordance with paragraph 2 of this Article, be subject to administrative fines up to 20 000 000 EUR, or in the case of an undertaking, up to 4 % of the total worldwide annual turnover of the preceding financial year, whichever is higher.

7. Without prejudice to the corrective powers of supervisory authorities pursuant to Article 58(2), each Member State may lay down the rules on whether and to what extent administrative fines may be imposed on public authorities and bodies established in that Member State.

8. The exercise by the supervisory authority of its powers under this Article shall be subject to appropriate procedural safeguards in accordance with Union and Member State law, including effective judicial remedy and due process.

9. Where the legal system of the Member State does not provide for administrative fines, this Article may be applied in such a manner that the fine is initiated by the competent supervisory authority and imposed by competent national courts, while ensuring that those legal remedies are effective and have an equivalent effect to the administrative fines imposed by supervisory authorities. In any event, the fines imposed shall be effective, proportionate and dissuasive. Those Member States shall notify to the Commission the provisions of their laws which they adopt pursuant to this paragraph by 25 May 2018 and, without delay, any subsequent amendment law or amendment affecting them.

Consumer credit · 2

Scope

2023/2225, official published text · English

https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_2

Article 2

Scope

1. This Directive applies to credit agreements.

2. This Directive does not apply to the following:

(a)

credit agreements which are secured either by a mortgage, or by another comparable security commonly used in a Member State on immovable property or secured by a right related to immovable property;

(b)

credit agreements the purpose of which is to acquire or retain property rights in land or in an existing or projected building, including premises used for trade, business or a profession;

(c)

credit agreements involving a total amount of credit of more than EUR 100 000;

(d)

credit agreements where the credit is granted by employers to their employees as a secondary activity either free of interest or offered at annual percentage rates of charge which are lower than those prevailing on the market and which are not offered to the general public;

(e)

credit agreements which are concluded with investment firms as defined in Article 4(1), point (1), of Directive 2014/65/EU of the European Parliament and of the Council (25) or with credit institutions as defined in Article 4(1), point (1), of Regulation (EU) No 575/2013 for the purposes of allowing an investor to carry out a transaction relating to one or more of the financial instruments listed in Section C of Annex I to Directive 2014/65/EU, where the investment firm or credit institution granting the credit is involved in that transaction;

(f)

credit agreements which are the outcome of a settlement reached in court or before another statutory authority;

(g)

hiring or leasing agreements where an obligation or an option to purchase the object of the agreement is not laid down either in the agreement itself or in any separate agreement;

(h)

deferred payments whereby:

(i)

a supplier of goods or a provider of services, without a third party offering credit, gives the consumer time to pay for the goods or services supplied by that supplier or provider;

(ii)

the purchase price is to be paid free of interest and without any other charges and with only limited charges payable by the consumer for late payments imposed in accordance with national law; and

(iii)

the payment is to be entirely executed within 50 days of the delivery of the good or service.

In the case of deferred payments offered by suppliers of goods or providers of services which are not micro, small or medium-sized enterprises as defined in Recommendation 2003/361/EC where such suppliers or providers offer information society services within the meaning of Article 1(1), point (b), of Directive (EU) 2015/1535 of the European

Parliament and of the Council (26) consisting of the conclusion of distance contracts with consumers for the sale of goods or supply of services within the meaning of Article 2, point 7 of Directive 2011/83/EU, this exclusion from the scope of this Directive shall apply only where the following conditions are fulfilled:

(i)

a third party is neither offering nor purchasing credit;

(ii)

the payment is to be entirely executed within 14 days of the delivery of the goods or services; and

(iii)

the purchase price is to be paid free of interest and without any other charges and with only limited charges payable by the consumer for late payments imposed in accordance with national law;

(i)

credit agreements which relate to the deferred payment, free of charge, of an existing debt;

(j)

credit agreements where the consumer is requested to deposit an item as security in the creditor's safe-keeping and the liability of the consumer is strictly limited to that deposited item;

(k)

credit agreements which relate to loans granted to a restricted public under a statutory provision with a general interest purpose, and at lower borrowing rates than those prevailing on the market or free of interest or on other terms which are more favourable to the consumer than those prevailing on the market;

(l)

credit agreements existing on 20 November 2026; however, Articles 23 and 24, Article 25(1), second sentence, Article 25(2) and Articles 28 and 39 shall apply to all open-end credit agreements existing on 20 November 2026.

3. Notwithstanding paragraph 2, point (c), this Directive applies to credit agreements involving a total amount of credit of more than EUR 100 000 which are not secured either by a mortgage, or by another comparable security commonly used in a Member State on immovable property or by a right related to immovable property, where the purpose of those credit agreements is the renovation of a residential immovable property.

4. In the case of credit agreements in the form of overrunning, only the following Articles shall apply:

(a)

Articles 1, 2, 3, 17, 19, 25, 31, 35, 36 and 39 to 50; and

(b)

Article 18, unless otherwise determined by Member States.

5. Member States may exempt from the application of this Directive credit agreements in the form of deferred debit cards:

(a)

which are provided by a credit or payment institution;

(b)

under the terms of which the credit has to be repaid within 40 days; and

(c)

which are free of interest and with only limited charges for the provision of the payment service.

6. Member States may determine that only Articles 1, 2, 3, 7, 8, 11, 19 and 20, Article 21(1), first subparagraph, points (a) to (h) and (l), Article 21(3) and Articles 23, 25 and 28 to 50 apply to credit agreements which are concluded by an organisation whose membership is restricted to persons residing or employed in a particular location or to employees and retired employees of a particular employer, or to persons meeting other qualifications laid down under national law as the basis for the existence of a common bond between the members and which fulfils all of the following conditions:

(a)

it is established for the mutual benefit of its members;

(b)

it does not make profits for any other person than its members;

(c)

it fulfils a social purpose required by national law;

(d)

it receives and manages the savings of, and provides sources of credit to, its members only;

(e)

it provides credit on the basis of an annual percentage rate of charge which is lower than that prevailing on the market or which is subject to a ceiling laid down by national law.

Member States may exempt from the application of this Directive credit agreements concluded by an organisation referred to in the first subparagraph where the total value of all existing credit agreements entered into by that organisation is insignificant in relation to the total value of all existing credit agreements in the Member State in which the organisation is based and the total value of all existing credit agreements entered into by all such organisations in that Member State is less than 1 % of the total value of all existing credit agreements entered into in that Member State.

Member States shall each year review whether the conditions for the application of any such exemption as referred to in the second subparagraph are still fulfilled and shall take action to withdraw the exemption where they consider that they are no longer met.

7. Member States may determine that only Articles 1, 2, 3, 7, 8, 11, 19 and 20, Article 21(1), first subparagraph, points (a) to (h), (l) and (r), Article 21(3) and Articles 23, 25, 28 to 38 and 40 to 50 shall apply to credit agreements between the creditor and the consumer in respect of deferred payment or of repayment methods, where the consumer is already in default or is likely to default on the initial credit agreement and where the following conditions are fulfilled:

(a)

the arrangement is likely to avert the possibility of legal proceedings concerning the default of the consumer;

(b)

the consumer would not, by entering into the arrangement, be subject to terms less favourable than those laid down in the initial credit agreement.

8. Member States may determine that Article 8(3), points (d), (e) and (f), Article 10(5), Article 11(4) and Article 21(3) do not apply to one or more of the following credit agreements:

(a)

credit agreements involving a total amount of credit of less than EUR 200;

(b)

credit agreements where credit is granted free of interest and without any other charges;

(c)

credit agreements under the terms of which credit has to be repaid within three months and only insignificant charges are payable.

Consumer credit · 3

Definitions

2023/2225, official published text · English

https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_3

Article 3

Definitions

For the purposes of this Directive, the following definitions apply:

(1)

‘consumer’ means a natural person who acts for purposes which are outside his or her trade, business or profession;

(2)

‘creditor’ means a natural or legal person who grants or promises to grant credit in the course of that person’s trade, business or profession;

(3)

‘credit agreement’ means an agreement whereby a creditor grants or promises to grant to a consumer credit in the form of a deferred payment, loan or other similar financial accommodation, except for agreements for the provision on a continuing basis of services or for the supply of goods of the same kind, where the consumer pays for such services or goods for the duration of their provision by means of instalments;

(4)

‘ancillary service’ means a service offered to the consumer in conjunction with the credit agreement;

(5)

‘total cost of the credit to the consumer’ means all the costs, including interest, commissions, taxes and any other kind of fees which the consumer is required to pay in connection with the credit agreement and which are known to the creditor, except for notarial costs; costs in respect of ancillary services relating to the credit agreement, in particular insurance premiums, are also included in the total cost of the credit to the consumer where, in addition, the conclusion of a contract regarding such ancillary services is compulsory in order to obtain the credit or to obtain it on the terms and conditions marketed;

(6)

‘total amount payable by the consumer’ means the sum of the total amount of credit and the total cost of the credit to the consumer;

(7)

‘annual percentage rate of charge’ or ‘APR’ means the total cost of the credit to the consumer, expressed as an annual percentage of the total amount of credit and calculated as set out in Article 30;

(8)

‘borrowing rate’ means the interest rate expressed as a fixed or variable percentage applied on an annual basis to the amount of credit drawn down;

(9)

‘fixed borrowing rate’ means the borrowing rate that the creditor and the consumer agree on in the credit agreement for the entire duration of the credit agreement, or several borrowing rates that the creditor and the consumer agree on in the credit agreement for partial periods for which the borrowing rates are determined exclusively by a fixed specific percentage; if not all borrowing rates are determined in the credit agreement, the borrowing rate shall be deemed to be fixed only for the partial periods for which the borrowing rates are determined exclusively by a fixed specific percentage agreed on the conclusion of the credit agreement;

(10)

‘total amount of credit’ means the ceiling or the total sums made available under a credit agreement;

(11)

‘durable medium’ means any instrument which enables the consumer to store information addressed personally to him or her in a way accessible for future reference for a period of time adequate for the purposes of the information and which allows the unchanged reproduction of the information stored;

(12)

‘credit intermediary’ means a natural or legal person that is not acting as a creditor or notary and not merely introducing, either directly or indirectly, a consumer to a creditor, and who, in the course of that person’s trade, business or profession, for remuneration, which may take a pecuniary form or any other agreed form of financial consideration:

(a)

presents or offers credit agreements to consumers;

(b)

assists consumers by undertaking preparatory work or other pre-contractual administration in respect of credit agreements other than as referred to in point (a); or

(c)

concludes credit agreements with consumers on behalf of the creditor;

(13)

‘pre-contractual information’ means the information which is provided before the consumer is bound by a credit agreement or, where applicable, by the submission of a binding offer and which the consumer needs in order to be able to compare different credit offers and take an informed decision on whether to conclude the credit agreement;

(14)

‘profiling’ means profiling as defined in Article 4, point (4), of Regulation (EU) 2016/679;

(15)

‘tying practice’ means the offering or the selling of a credit agreement in a package with other distinct financial products or services where the credit agreement is not made available to the consumer separately;

(16)

‘bundling practice’ means the offering or the selling of a credit agreement in a package with other distinct financial products or services where the credit agreement is also made available to the consumer separately but not necessarily on the same terms or conditions as when offered bundled with those other products or services;

(17)

‘advisory services’ means personal recommendations to a consumer in respect of one or more transactions relating to credit agreements and that constitute a separate activity from the granting of a credit and from the credit intermediation activities as set out in point (12);

(18)

‘overdraft facility’ means an explicit credit agreement whereby a creditor makes available to a consumer funds which exceed the current balance in the consumer’s current account;

(19)

‘overrunning’ means a tacitly accepted overdraft whereby a creditor makes available to a consumer funds which exceed the current balance in the consumer’s current account or the agreed overdraft facility;

(20)

‘linked credit agreement’ means a credit agreement where:

(a)

the credit or services in question serve exclusively to finance an agreement for the supply of specific goods or the provision of a specific service; and

(b)

those two agreements form, from an objective point of view, a commercial unit; a commercial unit shall be deemed to exist where the supplier of goods or the provider of services himself or herself finances the credit for the consumer or, if it is financed by a third party, where the creditor uses the services of the supplier of goods or the provider of services in connection with the marketing, conclusion or preparation of the credit agreement, or where the specific goods or the

provision of a specific service are explicitly specified in the credit agreement;

(21)

‘early repayment’ means the full or partial discharge of the consumer’s obligations under a credit agreement, before the date agreed in the credit agreement;

(22)

‘debt advisory services’ means personalised assistance of a technical, legal or psychological nature provided by independent professional operators which are not, in particular, creditors or credit intermediaries as defined in this Directive, or credit purchasers or credit servicers as defined in Article 3, points (6) and (8), of Directive (EU) 2021/2167 of the European Parliament and of the Council (27) , in favour of consumers who experience or might experience difficulties in meeting their financial commitments.

Consumer credit · 6

Non-discrimination

2023/2225, official published text · English

https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_6

Article 6

Non-discrimination

Member States shall ensure that the conditions to be fulfilled for being granted a credit do not discriminate against consumers legally resident in the Union on ground of their nationality or place of residence or on any ground as referred to in Article 21 of the Charter of Fundamental Rights of the European Union, when those consumers request, conclude or hold a credit agreement within the Union.

The first paragraph shall be without prejudice to the possibility of offering different conditions of access to a credit where those different conditions are duly justified by objective criteria.

Consumer credit · 18

Obligation to assess the creditworthiness of the consumer

2023/2225, official published text · English

https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_18

Article 18

Obligation to assess the creditworthiness of the consumer

1. Member States shall require that, before concluding a credit agreement, the creditor carry out a thorough assessment of the consumer's creditworthiness. That assessment shall be carried out in the interest of the consumer, to prevent irresponsible lending practices and over-indebtedness, and shall take appropriate account of factors relevant to verifying the prospect of the consumer meeting his or her obligations under the credit agreement.

2. Member States shall ensure that credit intermediaries accurately submit the necessary information obtained from the consumer to the relevant creditor in accordance with Regulation (EU) 2016/679 to enable the creditworthiness assessment to be carried out.

3. The assessment of creditworthiness shall be carried out on the basis of relevant and accurate information on the consumer's income and expenses and other financial and economic circumstances which is necessary and proportionate to the nature, duration, value and risks of the credit for the consumer. That information may include evidence of income or other sources of repayment, information on financial assets and liabilities, or information on other financial commitments. That information shall not include special categories of data referred to in Article 9(1) of Regulation (EU) 2016/679. The information shall be obtained from relevant internal or external sources, including the consumer and, where necessary, on the basis of a consultation of a database referred to in Article 19 of this Directive. Social networks shall not be considered as an external source for the purpose of this Directive.

The information obtained in accordance with this paragraph shall be appropriately verified, where necessary through reference to independently verifiable documentation.

4. Member States shall require the creditor to establish procedures for the assessment referred to in paragraph 1 and to document and maintain such procedures.

Member States shall also require the creditor to document and maintain the information referred to in paragraph 3.

5. If the credit application is submitted jointly by more than one consumer, the creditor shall perform the creditworthiness assessment on the basis of the joint repayment capacity of the consumers.

6. Member States shall ensure that the creditor only makes the credit available to the consumer where the result of the creditworthiness assessment indicates that the obligations resulting from the credit agreement are likely to be met in the manner required under that agreement, taking into account relevant factors as referred to in paragraph 1.

7. Member States shall ensure that, where a creditor concludes a credit agreement with a consumer, the creditor shall not subsequently cancel or modify the credit agreement to the detriment of the consumer on the grounds that the assessment of creditworthiness was incorrectly conducted. This paragraph shall not apply where it is demonstrated that the consumer knowingly withheld or falsified the information referred to in paragraph 3 provided to the creditor.

8. Where the creditworthiness assessment involves the use of automated processing of personal data, Member States shall ensure that the consumer has the right to request and obtain from the creditor human intervention, consisting of the right to:

(a)

request and obtain from the creditor a clear and comprehensible explanation of the assessment of creditworthiness, including on the logic and risks involved in the automated processing of personal data as well as its significance and effects on the decision;

(b)

express the consumer's own point of view to the creditor; and

(c)

request a review of the assessment of the creditworthiness and the decision on the granting of the credit by the creditor.

Member States shall ensure that the consumer is informed of the right as referred to in the first subparagraph.

9. Member States shall ensure that, where the credit application is rejected, the creditor is required to inform the consumer without delay of the rejection and, where relevant, refer the consumer to easily accessible debt advisory services. Where applicable, the creditor shall be required to inform the consumer of the fact that the assessment of creditworthiness is based on automated processing of data and about the consumer's right to human assessment and the procedure for contesting the decision.

10. Where the parties agree to change the total amount of credit after the conclusion of the credit agreement, Member States shall ensure that the creditor is required to reassess the consumer's creditworthiness on the basis of updated information before any significant increase in the total amount of credit is granted.

11. Member States may require creditors to assess the creditworthiness of consumers on the basis of a consultation of the relevant database. However, the assessment of creditworthiness shall not be based exclusively on the consumer's credit history.

Consumer credit · 19

Databases

2023/2225, official published text · English

https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_19

Article 19

Databases

1. Each Member State shall, in the case of cross-border credit, ensure access for creditors from other Member States to databases used in that Member State for assessing the creditworthiness of consumers. The conditions for access to such databases shall be non-discriminatory.

2. Member States shall ensure that only those creditors who are under the supervision of the national competent authority and who fully comply with Regulation (EU) 2016/679 have access to the databases used for assessing the creditworthiness of consumers.

3. Paragraph 1 shall apply both to public and private databases.

4. The databases referred to in paragraph 1 which contain information on credit agreements for consumers shall hold at least information on consumers' arrears in repayment of credit, the type of credit and the identity of the creditor.

5. Creditors and credit intermediaries shall not process special categories of data as referred to in Article 9(1) of Regulation (EU) 2016/679 and personal data processed from social networks that may be contained in databases referred to in paragraph 1 of this Article.

6. Where the credit application is rejected on the basis of a consultation of a database referred to in paragraph 1, Member States shall require that the creditor informs the consumer without undue delay and free of charge of the result of such consultation and of the details of the database consulted as well as the categories of data taken into account.

7. For the purpose of credit agreements, database providers shall have processes in place to ensure that information contained in their databases is up-to-date and accurate. Member States shall ensure that consumers are informed:

(a)

within 30 days of the registration of any arrears in repayment of credit in a database; and

(b)

of their rights in accordance with Regulation (EU) 2016/679.

8. For the purpose of credit agreements, Member States shall ensure that complaint procedures are in place in order to facilitate consumers' challenges to the content of databases, including information that can be obtained by third parties through those databases.

Consumer credit · 47

Repeal and transitional provisions

2023/2225, official published text · English

https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_47

Article 47

Repeal and transitional provisions

Directive 2008/48/EC is repealed with effect from 20 November 2026.

Notwithstanding the first paragraph, Directive 2008/48/EC shall continue to apply to credit agreements existing on 20 November 2026 until their termination.

However, Articles 23 and 24, Article 25(1), second sentence, Article 25(2) and Articles 28 and 39 of this Directive shall apply to all open-end credit agreements existing on 20 November 2026.

References to the repealed Directive shall be construed as references to this Directive and shall be read in accordance with the correlation table set out in Annex IV.

Consumer credit · 48

Transposition

2023/2225, official published text · English

https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_48

Article 48

Transposition

1. Member States shall adopt and publish, by 20 November 2025, the laws, regulations and administrative provisions necessary to comply with this Directive. They shall immediately communicate the text of those provisions to the Commission.

They shall apply those measures from 20 November 2026.

When Member States adopt those measures, they shall contain a reference to this Directive or be accompanied by such a reference on the occasion of their official publication. Member States shall determine how such reference is to be made.

2. Member States shall communicate to the Commission the text of the main measures of national law which they adopt in the field covered by this Directive.

DORA · 2

Scope

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_2

Article 2

Scope

1. Without prejudice to paragraphs 3 and 4, this Regulation applies to the following entities:

(a)

credit institutions;

(b)

payment institutions, including payment institutions exempted pursuant to Directive (EU) 2015/2366;

(c)

account information service providers;

(d)

electronic money institutions, including electronic money institutions exempted pursuant to Directive 2009/110/EC;

(e)

investment firms;

(f)

crypto-asset service providers as authorised under a Regulation of the European Parliament and of the Council on markets in crypto-assets, and amending Regulations (EU) No 1093/2010 and (EU) No 1095/2010 and Directives 2013/36/EU and (EU) 2019/1937 (‘the Regulation on markets in crypto-assets’) and issuers of asset-referenced tokens;

(g)

central securities depositories;

(h)

central counterparties;

(i)

trading venues;

(j)

trade repositories;

(k)

managers of alternative investment funds;

(l)

management companies;

(m)

data reporting service providers;

(n)

insurance and reinsurance undertakings;

(o)

insurance intermediaries, reinsurance intermediaries and ancillary insurance intermediaries;

(p)

institutions for occupational retirement provision;

(q)

credit rating agencies;

(r)

administrators of critical benchmarks;

(s)

crowdfunding service providers;

(t)

securitisation repositories;

(u)

ICT third-party service providers.

2. For the purposes of this Regulation, entities referred to in paragraph 1, points (a) to (t), shall collectively be referred to as ‘financial entities’.

3. This Regulation does not apply to:

(a)

managers of alternative investment funds as referred to in Article 3(2) of Directive 2011/61/EU;

(b)

insurance and reinsurance undertakings as referred to in Article 4 of Directive 2009/138/EC;

(c)

institutions for occupational retirement provision which operate pension schemes which together do not have more than 15 members in total;

(d)

natural or legal persons exempted pursuant to Articles 2 and 3 of Directive 2014/65/EU;

(e)

insurance intermediaries, reinsurance intermediaries and ancillary insurance intermediaries which are microenterprises or small or medium-sized enterprises;

(f)

post office giro institutions as referred to in Article 2(5), point (3), of Directive 2013/36/EU.

4. Member States may exclude from the scope of this Regulation entities referred to in Article 2(5), points (4) to (23), of Directive 2013/36/EU that are located within their respective territories. Where a Member State makes use of such option, it shall inform the Commission thereof as well as of any subsequent changes thereto. The Commission shall make that information publicly available on its website or other easily accessible means.

DORA · 3

Definitions

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_3

Article 3

Definitions

For the purposes of this Regulation, the following definitions shall apply:

(1)

‘digital operational resilience’ means the ability of a financial entity to build, assure and review its operational integrity and reliability by ensuring, either directly or indirectly through the use of services provided by ICT third-party service providers, the full range of ICT-related capabilities needed to address the security of the network and information systems which a financial entity uses, and which support the continued provision of financial services and their quality, including throughout disruptions;

(2)

‘network and information system’ means a network and information system as defined in Article 6, point 1, of Directive (EU) 2022/2555;

(3)

‘legacy ICT system’ means an ICT system that has reached the end of its lifecycle (end-of-life), that is not suitable for upgrades or fixes, for technological or commercial reasons, or is no longer supported by its supplier or by an ICT third-party service provider, but that is still in use and supports the functions of the financial entity;

(4)

‘security of network and information systems’ means security of network and information systems as defined in Article 6, point 2, of Directive (EU) 2022/2555;

(5)

‘ICT risk’ means any reasonably identifiable circumstance in relation to the use of network and information systems which, if materialised, may compromise the security of the network and information systems, of any technology dependent tool or process, of operations and processes, or of the provision of services by producing adverse effects in the digital or physical environment;

(6)

‘information asset’ means a collection of information, either tangible or intangible, that is worth protecting;

(7)

‘ICT asset’ means a software or hardware asset in the network and information systems used by the financial entity;

(8)

‘ICT-related incident’ means a single event or a series of linked events unplanned by the financial entity that compromises the security of the network and information systems, and have an adverse impact on the availability, authenticity, integrity or confidentiality of data, or on the services provided by the financial entity;

(9)

‘operational or security payment-related incident’ means a single event or a series of linked events unplanned by the financial entities referred to in Article 2(1), points (a) to (d), whether ICT-related or not, that has an adverse impact on the availability, authenticity, integrity or confidentiality of payment-related data, or on the payment-related services provided by the financial entity;

(10)

‘major ICT-related incident’ means an ICT-related incident that has a high adverse impact on the network and information systems that support critical or important functions of the financial entity;

(11)

‘major operational or security payment-related incident’ means an operational or security payment-related incident that has a high adverse impact on the payment-related services provided;

(12)

‘cyber threat’ means ‘cyber threat’ as defined in Article 2, point (8), of Regulation (EU) 2019/881;

(13)

‘significant cyber threat’ means a cyber threat the technical characteristics of which indicate that it could have the potential to result in a major ICT-related incident or a major operational or security payment-related incident;

(14)

‘cyber-attack’ means a malicious ICT-related incident caused by means of an attempt perpetrated by any threat actor to destroy, expose, alter, disable, steal or gain unauthorised access to, or make unauthorised use of, an asset;

(15)

‘threat intelligence’ means information that has been aggregated, transformed, analysed, interpreted or enriched to provide the necessary context for decision-making and to enable relevant and sufficient understanding in order to mitigate the impact of an ICT-related incident or of a cyber threat, including the technical details of a cyber-attack, those responsible for the attack and their modus operandi and motivations;

(16)

‘vulnerability’ means a weakness, susceptibility or flaw of an asset, system, process or control that can be exploited;

(17)

‘threat-led penetration testing (TLPT)’ means a framework that mimics the tactics, techniques and procedures of real-life threat actors perceived as posing a genuine cyber threat, that delivers a controlled, bespoke, intelligence-led (red team) test of the financial entity’s critical live production systems;

(18)

‘ICT third-party risk’ means an ICT risk that may arise for a financial entity in relation to its use of ICT services provided by ICT third-party service providers or by subcontractors of the latter, including through outsourcing arrangements;

(19)

‘ICT third-party service provider’ means an undertaking providing ICT services;

(20)

‘ICT intra-group service provider’ means an undertaking that is part of a financial group and that provides predominantly ICT services to financial entities within the same group or to financial entities belonging to the same institutional protection scheme, including to their parent undertakings, subsidiaries, branches or other entities that are under common ownership or control;

(21)

‘ICT services’ means digital and data services provided through ICT systems to one or more internal or external users on an ongoing basis, including hardware as a service and hardware services which includes the provision of technical support via software or firmware updates by the hardware provider, excluding traditional analogue telephone services;

(22)

‘critical or important function’ means a function, the disruption of which would materially impair the financial performance of a financial entity, or the soundness or continuity of its services and activities, or the discontinued, defective or failed performance of that function would materially impair the continuing compliance of a financial entity with the conditions and obligations of its authorisation, or with its other obligations under applicable financial services law;

(23)

‘critical ICT third-party service provider’ means an ICT third-party service provider designated as critical in accordance with Article 31;

(24)

‘ICT third-party service provider established in a third country’ means an ICT third-party service provider that is a legal person established in a third-country and that has entered into a contractual arrangement with a financial entity for the provision of ICT services;

(25)

‘subsidiary’ means a subsidiary undertaking within the meaning of Article 2, point (10), and Article 22 of Directive 2013/34/EU;

(26)

‘group’ means a group as defined in Article 2, point (11), of Directive 2013/34/EU;

(27)

‘parent undertaking’ means a parent undertaking within the meaning of Article 2, point (9), and Article 22 of Directive 2013/34/EU;

(28)

‘ICT subcontractor established in a third country’ means an ICT subcontractor that is a legal person established in a third-country and that has entered into a contractual arrangement either with an ICT third-party service provider, or with an ICT third-party service provider established in a third country;

(29)

‘ICT concentration risk’ means an exposure to individual or multiple related critical ICT third-party service providers creating a degree of dependency on such providers so that the unavailability, failure or other type of shortfall of such provider may potentially endanger the ability of a financial entity to deliver critical or important functions, or cause it to suffer other types of adverse effects, including large losses, or endanger the financial stability of the Union as a whole;

(30)

‘management body’ means a management body as defined in Article 4(1), point (36), of Directive 2014/65/EU, Article 3(1), point (7), of Directive 2013/36/EU, Article 2(1), point (s), of Directive 2009/65/EC of the European Parliament and of the Council (31) , Article 2(1), point (45), of Regulation (EU) No 909/2014, Article 3(1), point (20), of Regulation (EU) 2016/1011, and in the relevant provision of the Regulation on markets in crypto-assets, or the equivalent persons who effectively run the entity or have key functions in accordance with relevant Union or national law;

(31)

‘credit institution’ means a credit institution as defined in Article 4(1), point (1), of Regulation (EU) No 575/2013 of the European Parliament and of the Council (32) ;

(32)

‘institution exempted pursuant to Directive 2013/36/EU’ means an entity as referred to in Article 2(5), points (4) to (23), of Directive 2013/36/EU;

(33)

‘investment firm’ means an investment firm as defined in Article 4(1), point (1), of Directive 2014/65/EU;

(34)

‘small and non-interconnected investment firm’ means an investment firm that meets the conditions laid out in Article 12(1) of Regulation (EU) 2019/2033 of the European Parliament and of the Council (33) ;

(35)

‘payment institution’ means a payment institution as defined in Article 4, point (4), of Directive (EU) 2015/2366;

(36)

‘payment institution exempted pursuant to Directive (EU) 2015/2366’ means a payment institution exempted pursuant to Article 32(1) of Directive (EU) 2015/2366;

(37)

‘account information service provider’ means an account information service provider as referred to in Article 33(1) of Directive (EU) 2015/2366;

(38)

‘electronic money institution’ means an electronic money institution as defined in Article 2, point (1), of Directive 2009/110/EC of the European Parliament and of the Council;

(39)

‘electronic money institution exempted pursuant to Directive 2009/110/EC’ means an electronic money institution benefitting from a waiver as referred to in Article 9(1) of Directive 2009/110/EC;

(40)

‘central counterparty’ means a central counterparty as defined in Article 2, point (1), of Regulation (EU) No 648/2012;

(41)

‘trade repository’ means a trade repository as defined in Article 2, point (2), of Regulation (EU) No 648/2012;

(42)

‘central securities depository’ means a central securities depository as defined in Article 2(1), point (1), of Regulation (EU) No 909/2014;

(43)

‘trading venue’ means a trading venue as defined in Article 4(1), point (24), of Directive 2014/65/EU;

(44)

‘manager of alternative investment funds’ means a manager of alternative investment funds as defined in Article 4(1), point (b), of Directive 2011/61/EU;

(45)

‘management company’ means a management company as defined in Article 2(1), point (b), of Directive 2009/65/EC;

(46)

‘data reporting service provider’ means a data reporting service provider within the meaning of Regulation (EU) No 600/2014, as referred to in Article 2(1), points (34) to (36) thereof;

(47)

‘insurance undertaking’ means an insurance undertaking as defined in Article 13, point (1), of Directive 2009/138/EC;

(48)

‘reinsurance undertaking’ means a reinsurance undertaking as defined in Article 13, point (4), of Directive 2009/138/EC;

(49)

‘insurance intermediary’ means an insurance intermediary as defined in Article 2(1), point (3), of Directive (EU) 2016/97 of the European Parliament and of the Council (34) ;

(50)

‘ancillary insurance intermediary’ means an ancillary insurance intermediary as defined in Article 2(1), point (4), of Directive (EU) 2016/97;

(51)

‘reinsurance intermediary’ means a reinsurance intermediary as defined in Article 2(1), point (5), of Directive (EU) 2016/97;

(52)

‘institution for occupational retirement provision’ means an institution for occupational retirement provision as defined in Article 6, point (1), of Directive (EU) 2016/2341;

(53)

‘small institution for occupational retirement provision’ means an institution for occupational retirement provision which operates pension schemes which together have less than 100 members in total;

(54)

‘credit rating agency’ means a credit rating agency as defined in Article 3(1), point (b), of Regulation (EC) No 1060/2009;

(55)

‘crypto-asset service provider’ means a crypto-asset service provider as defined in the relevant provision of the Regulation on markets in crypto-assets;

(56)

‘issuer of asset-referenced tokens’ means an issuer of asset-referenced tokens as defined in the relevant provision of the Regulation on markets in crypto-assets;

(57)

‘administrator of critical benchmarks’ means an administrator of ‘critical benchmarks’ as defined in Article 3(1), point (25), of Regulation (EU) 2016/1011;

(58)

‘crowdfunding service provider’ means a crowdfunding service provider as defined in Article 2(1), point (e), of Regulation (EU) 2020/1503 of the European Parliament and of the Council (35) ;

(59)

‘securitisation repository’ means a securitisation repository as defined in Article 2, point (23), of Regulation (EU) 2017/2402 of the European Parliament and of the Council (36) ;

(60)

‘microenterprise’ means a financial entity, other than a trading venue, a central counterparty, a trade repository or a central securities depository, which employs fewer than 10 persons and has an annual turnover and/or annual balance sheet total that does not exceed EUR 2 million;

(61)

‘Lead Overseer’ means the European Supervisory Authority appointed in accordance with Article 31(1), point (b) of this Regulation;

(62)

‘Joint Committee’ means the committee referred to in Article 54 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010;

(63)

‘small enterprise’ means a financial entity that employs 10 or more persons, but fewer than 50 persons, and has an annual turnover and/or annual balance sheet total that exceeds EUR 2 million, but does not exceed EUR 10 million;

(64)

‘medium-sized enterprise’ means a financial entity that is not a small enterprise and employs fewer than 250 persons and has an annual turnover that does not exceed EUR 50 million and/or an annual balance sheet that does not exceed EUR 43 million;

(65)

‘public authority’ means any government or other public administration entity, including national central banks.

DORA · 4

Proportionality principle

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_4

Article 4

Proportionality principle

1. Financial entities shall implement the rules laid down in Chapter II in accordance with the principle of proportionality, taking into account their size and overall risk profile, and the nature, scale and complexity of their services, activities and operations.

2. In addition, the application by financial entities of Chapters III, IV and V, Section I, shall be proportionate to their size and overall risk profile, and to the nature, scale and complexity of their services, activities and operations, as specifically provided for in the relevant rules of those Chapters.

3. The competent authorities shall consider the application of the proportionality principle by financial entities when reviewing the consistency of the ICT risk management framework on the basis of the reports submitted upon the request of competent authorities pursuant to Article 6(5) and Article 16(2).

DORA · 5

Governance and organisation

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_5

Article 5

Governance and organisation

1. Financial entities shall have in place an internal governance and control framework that ensures an effective and prudent management of ICT risk, in accordance with Article 6(4), in order to achieve a high level of digital operational resilience.

2. The management body of the financial entity shall define, approve, oversee and be responsible for the implementation of all arrangements related to the ICT risk management framework referred to in Article 6(1).

For the purposes of the first subparagraph, the management body shall:

(a)

bear the ultimate responsibility for managing the financial entity's ICT risk;

(b)

put in place policies that aim to ensure the maintenance of high standards of availability, authenticity, integrity and confidentiality, of data;

(c)

set clear roles and responsibilities for all ICT-related functions and establish appropriate governance arrangements to ensure effective and timely communication, cooperation and coordination among those functions;

(d)

bear the overall responsibility for setting and approving the digital operational resilience strategy as referred to in Article 6(8), including the determination of the appropriate risk tolerance level of ICT risk of the financial entity, as referred to in Article 6(8), point (b);

(e)

approve, oversee and periodically review the implementation of the financial entity's ICT business continuity policy and ICT response and recovery plans, referred to, respectively, in Article 11(1) and (3), which may be adopted as a dedicated specific policy forming an integral part of the financial entity's overall business continuity policy and response and recovery plan;

(f)

approve and periodically review the financial entity's ICT internal audit plans, ICT audits and material modifications to them;

(g)

allocate and periodically review the appropriate budget to fulfil the financial entity's digital operational resilience needs in respect of all types of resources, including relevant ICT security awareness programmes and digital operational resilience training referred to in Article 13(6), and ICT skills for all staff;

(h)

approve and periodically review the financial entity's policy on arrangements regarding the use of ICT services provided by ICT third-party service providers;

(i)

put in place, at corporate level, reporting channels enabling it to be duly informed of the following:

(i)

arrangements concluded with ICT third-party service providers on the use of ICT services,

(ii)

any relevant planned material changes regarding the ICT third-party service providers,

(iii)

the potential impact of such changes on the critical or important functions subject to those arrangements, including a risk analysis summary to assess the impact of those changes, and at least major ICT-related incidents and their impact, as well as response, recovery and corrective measures.

3. Financial entities, other than microenterprises, shall establish a role in order to monitor the arrangements concluded with ICT third-party service providers on the use of ICT services, or shall designate a member of senior management as responsible for overseeing the related risk exposure and relevant documentation.

4. Members of the management body of the financial entity shall actively keep up to date with sufficient knowledge and skills to understand and assess ICT risk and its impact on the operations of the financial entity, including by following specific training on a regular basis, commensurate to the ICT risk being managed.

DORA · 6

ICT risk management framework

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_6

Article 6

ICT risk management framework

1. Financial entities shall have a sound, comprehensive and well-documented ICT risk management framework as part of their overall risk management system, which enables them to address ICT risk quickly, efficiently and comprehensively and to ensure a high level of digital operational resilience.

2. The ICT risk management framework shall include at least strategies, policies, procedures, ICT protocols and tools that are necessary to duly and adequately protect all information assets and ICT assets, including computer software, hardware, servers, as well as to protect all relevant physical components and infrastructures, such as premises, data centres and sensitive designated areas, to ensure that all information assets and ICT assets are adequately protected from risks including damage and unauthorised access or usage.

3. In accordance with their ICT risk management framework, financial entities shall minimise the impact of ICT risk by deploying appropriate strategies, policies, procedures, ICT protocols and tools. They shall provide complete and updated information on ICT risk and on their ICT risk management framework to the competent authorities upon their request.

4. Financial entities, other than microenterprises, shall assign the responsibility for managing and overseeing ICT risk to a control function and ensure an appropriate level of independence of such control function in order to avoid conflicts of interest. Financial entities shall ensure appropriate segregation and independence of ICT risk management functions, control functions, and internal audit functions, according to the three lines of defence model, or an internal risk management and control model.

5. The ICT risk management framework shall be documented and reviewed at least once a year, or periodically in the case of microenterprises, as well as upon the occurrence of major ICT-related incidents, and following supervisory instructions or conclusions derived from relevant digital operational resilience testing or audit processes. It shall be continuously improved on the basis of lessons derived from implementation and monitoring. A report on the review of the ICT risk management framework shall be submitted to the competent authority upon its request.

6. The ICT risk management framework of financial entities, other than microenterprises, shall be subject to internal audit by auditors on a regular basis in line with the financial entities' audit plan. Those auditors shall possess sufficient knowledge, skills and expertise in ICT risk, as well as appropriate independence. The frequency and focus of ICT audits shall be commensurate to the ICT risk of the financial entity.

7. Based on the conclusions from the internal audit review, financial entities shall establish a formal follow-up process, including rules for the timely verification and remediation of critical ICT audit findings.

8. The ICT risk management framework shall include a digital operational resilience strategy setting out how the framework shall be implemented. To that end, the digital operational resilience strategy shall include methods to address ICT risk and attain specific ICT objectives, by:

(a)

explaining how the ICT risk management framework supports the financial entity's business strategy and objectives;

(b)

establishing the risk tolerance level for ICT risk, in accordance with the risk appetite of the financial entity, and analysing the impact tolerance for ICT disruptions;

(c)

setting out clear information security objectives, including key performance indicators and key risk metrics;

(d)

explaining the ICT reference architecture and any changes needed to reach specific business objectives;

(e)

outlining the different mechanisms put in place to detect ICT-related incidents, prevent their impact and provide protection from it;

(f)

evidencing the current digital operational resilience situation on the basis of the number of major ICT-related incidents reported and the effectiveness of preventive measures;

(g)

implementing digital operational resilience testing, in accordance with Chapter IV of this Regulation;

(h)

outlining a communication strategy in the event of ICT-related incidents the disclosure of which is required in accordance with Article 14.

9. Financial entities may, in the context of the digital operational resilience strategy referred to in paragraph 8, define a holistic ICT multi-vendor strategy, at group or entity level, showing key dependencies on ICT third-party service providers and explaining the rationale behind the procurement mix of ICT third-party service providers.

10. Financial entities may, in accordance with Union and national sectoral law, outsource the tasks of verifying compliance with ICT risk management requirements to intra-group or external undertakings. In case of such outsourcing, the financial entity remains fully responsible for the verification of compliance with the ICT risk management requirements.

DORA · 17

ICT-related incident management process

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_17

Article 17

ICT-related incident management process

1. Financial entities shall define, establish and implement an ICT-related incident management process to detect, manage and notify ICT-related incidents.

2. Financial entities shall record all ICT-related incidents and significant cyber threats. Financial entities shall establish appropriate procedures and processes to ensure a consistent and integrated monitoring, handling and follow-up of ICT-related incidents, to ensure that root causes are identified, documented and addressed in order to prevent the occurrence of such incidents.

3. The ICT-related incident management process referred to in paragraph 1 shall:

(a)

put in place early warning indicators;

(b)

establish procedures to identify, track, log, categorise and classify ICT-related incidents according to their priority and severity and according to the criticality of the services impacted, in accordance with the criteria set out in Article 18(1);

(c)

assign roles and responsibilities that need to be activated for different ICT-related incident types and scenarios;

(d)

set out plans for communication to staff, external stakeholders and media in accordance with Article 14 and for notification to clients, for internal escalation procedures, including ICT-related customer complaints, as well as for the provision of information to financial entities that act as counterparts, as appropriate;

(e)

ensure that at least major ICT-related incidents are reported to relevant senior management and inform the management body of at least major ICT-related incidents, explaining the impact, response and additional controls to be established as a result of such ICT-related incidents;

(f)

establish ICT-related incident response procedures to mitigate impacts and ensure that services become operational and secure in a timely manner.

DORA · 19

Reporting of major ICT-related incidents and voluntary notification of significant cyber threats

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_19

Article 19

Reporting of major ICT-related incidents and voluntary notification of significant cyber threats

1. Financial entities shall report major ICT-related incidents to the relevant competent authority as referred to in Article 46 in accordance with paragraph 4 of this Article.

Where a financial entity is subject to supervision by more than one national competent authority referred to in Article 46, Member States shall designate a single competent authority as the relevant competent authority responsible for carrying out the functions and duties provided for in this Article.

Credit institutions classified as significant, in accordance with Article 6(4) of Regulation (EU) No 1024/2013, shall report major ICT-related incidents to the relevant national competent authority designated in accordance with Article 4 of Directive 2013/36/EU, which shall immediately transmit that report to the ECB.

For the purpose of the first subparagraph, financial entities shall produce, after collecting and analysing all relevant information, the initial notification and reports referred to in paragraph 4 of this Article using the templates referred to in Article 20 and submit them to the competent authority. In the event that a technical impossibility prevents the submission of the initial notification using the template, financial entities shall notify the competent authority about it via alternative means.

The initial notification and reports referred to in paragraph 4 shall include all information necessary for the competent authority to determine the significance of the major ICT-related incident and assess possible cross-border impacts.

Without prejudice to the reporting pursuant to the first subparagraph by the financial entity to the relevant competent authority, Member States may additionally determine that some or all financial entities shall also provide the initial notification and each report referred to in paragraph 4 of this Article using the templates referred to in Article 20 to the competent authorities or the computer security incident response teams (CSIRTs) designated or established in accordance with Directive (EU) 2022/2555.

2. Financial entities may, on a voluntary basis, notify significant cyber threats to the relevant competent authority when they deem the threat to be of relevance to the financial system, service users or clients. The relevant competent authority may provide such information to other relevant authorities referred to in paragraph 6.

Credit institutions classified as significant, in accordance with Article 6(4) of Regulation (EU) No 1024/2013, may, on a voluntary basis, notify significant cyber threats to relevant national competent authority, designated in accordance with Article 4 of Directive 2013/36/EU, which shall immediately transmit the notification to the ECB.

Member States may determine that those financial entities that on a voluntary basis notify in accordance with the first subparagraph may also transmit that notification to the CSIRTs designated or established in accordance with Directive (EU) 2022/2555.

3. Where a major ICT-related incident occurs and has an impact on the financial interests of clients, financial entities shall, without undue delay as soon as they become aware of it, inform their clients about the major ICT-related incident and about the measures that have been taken to mitigate the adverse effects of such incident.

In the case of a significant cyber threat, financial entities shall, where applicable, inform their clients that are potentially affected of any appropriate protection measures which the latter may consider taking.

4. Financial entities shall, within the time limits to be laid down in accordance with Article 20, first paragraph, point (a), point (ii), submit the following to the relevant competent authority:

(a)

an initial notification;

(b)

an intermediate report after the initial notification referred to in point (a), as soon as the status of the original incident has changed significantly or the handling of the major ICT-related incident has changed based on new information available,

followed, as appropriate, by updated notifications every time a relevant status update is available, as well as upon a specific request of the competent authority;

(c)

a final report, when the root cause analysis has been completed, regardless of whether mitigation measures have already been implemented, and when the actual impact figures are available to replace estimates.

5. Financial entities may outsource, in accordance with Union and national sectoral law, the reporting obligations under this Article to a third-party service provider. In case of such outsourcing, the financial entity remains fully responsible for the fulfilment of the incident reporting requirements.

6. Upon receipt of the initial notification and of each report referred to in paragraph 4, the competent authority shall, in a timely manner, provide details of the major ICT-related incident to the following recipients based, as applicable, on their respective competences:

(a)

EBA, ESMA or EIOPA;

(b)

the ECB, in the case of financial entities referred to in Article 2(1), points (a), (b) and (d);

(c)

the competent authorities, single points of contact or CSIRTs designated or established in accordance with Directive (EU) 2022/2555;

(d)

the resolution authorities, as referred to in Article 3 of Directive 2014/59/EU, and the Single Resolution Board (SRB) with respect to entities referred to in Article 7(2) of Regulation (EU) No 806/2014 of the European Parliament and of the Council (37) , and with respect to entities and groups referred to in Article 7(4)(b) and (5) of Regulation (EU) No 806/2014 if such details concern incidents that pose a risk to ensuring critical functions within the meaning of Article 2(1), point (35), of Directive 2014/59/EU; and

(e)

other relevant public authorities under national law.

7. Following receipt of information in accordance with paragraph 6, EBA, ESMA or EIOPA and the ECB, in consultation with ENISA and in cooperation with the relevant competent authority, shall assess whether the major ICT-related incident is relevant for competent authorities in other Member States. Following that assessment, EBA, ESMA or EIOPA shall, as soon as possible, notify relevant competent authorities in other Member States accordingly. The ECB shall notify the members of the European System of Central Banks on issues relevant to the payment system. Based on that notification, the competent authorities shall, where appropriate, take all of the necessary measures to protect the immediate stability of the financial system.

8. The notification to be done by ESMA pursuant to paragraph 7 of this Article shall be without prejudice to the responsibility of the competent authority to urgently transmit the details of the major ICT-related incident to the relevant authority in the host Member State, where a central securities depository has significant cross-border activity in the host Member State, the major ICT-related incident is likely to have severe consequences for the financial markets of the host Member State and where there are cooperation arrangements among competent authorities related to the supervision of financial entities.

DORA · 24

General requirements for the performance of digital operational resilience testing

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_24

Article 24

General requirements for the performance of digital operational resilience testing

1. For the purpose of assessing preparedness for handling ICT-related incidents, of identifying weaknesses, deficiencies and gaps in digital operational resilience, and of promptly implementing corrective measures, financial entities, other than microenterprises, shall, taking into account the criteria set out in Article 4(2), establish, maintain and review a sound and comprehensive digital operational resilience testing programme as an integral part of the ICT risk-management framework referred to in Article 6.

2. The digital operational resilience testing programme shall include a range of assessments, tests, methodologies, practices and tools to be applied in accordance with Articles 25 and 26.

3. When conducting the digital operational resilience testing programme referred to in paragraph 1 of this Article, financial entities, other than microenterprises, shall follow a risk-based approach taking into account the criteria set out in Article 4(2) duly considering the evolving landscape of ICT risk, any specific risks to which the financial entity concerned is or might be exposed, the criticality of information assets and of services provided, as well as any other factor the financial entity deems appropriate.

4. Financial entities, other than microenterprises, shall ensure that tests are undertaken by independent parties, whether internal or external. Where tests are undertaken by an internal tester, financial entities shall dedicate sufficient resources and ensure that conflicts of interest are avoided throughout the design and execution phases of the test.

5. Financial entities, other than microenterprises, shall establish procedures and policies to prioritise, classify and remedy all issues revealed throughout the performance of the tests and shall establish internal validation methodologies to ascertain that all identified weaknesses, deficiencies or gaps are fully addressed.

6. Financial entities, other than microenterprises, shall ensure, at least yearly, that appropriate tests are conducted on all ICT systems and applications supporting critical or important functions.

DORA · 28

General principles

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_28

Article 28

General principles

1. Financial entities shall manage ICT third-party risk as an integral component of ICT risk within their ICT risk management framework as referred to in Article 6(1), and in accordance with the following principles:

(a)

financial entities that have in place contractual arrangements for the use of ICT services to run their business operations shall, at all times, remain fully responsible for compliance with, and the discharge of, all obligations under this Regulation and applicable financial services law;

(b)

financial entities' management of ICT third-party risk shall be implemented in light of the principle of proportionality, taking into account:

(i)

the nature, scale, complexity and importance of ICT-related dependencies,

(ii)

the risks arising from contractual arrangements on the use of ICT services concluded with ICT third-party service providers, taking into account the criticality or importance of the respective service, process or function, and the potential impact on the continuity and availability of financial services and activities, at individual and at group level.

2. As part of their ICT risk management framework, financial entities, other than entities referred to in Article 16(1), first subparagraph, and other than microenterprises, shall adopt, and regularly review, a strategy on ICT third-party risk, taking into account the multi-vendor strategy referred to in Article 6(9), where applicable. The strategy on ICT third-party risk shall include a policy on the use of ICT services supporting critical or important functions provided by ICT third-party service providers and shall apply on an individual basis and, where relevant, on a sub-consolidated and consolidated basis. The management body shall, on the basis of an assessment of the overall risk profile of the financial entity and the scale and complexity of the business services, regularly review the risks identified in respect to contractual arrangements on the use of ICT services supporting critical or important functions.

3. As part of their ICT risk management framework, financial entities shall maintain and update at entity level, and at sub-consolidated and consolidated levels, a register of information in relation to all contractual arrangements on the use of ICT services provided by ICT third-party service providers.

The contractual arrangements referred to in the first subparagraph shall be appropriately documented, distinguishing between those that cover ICT services supporting critical or important functions and those that do not.

Financial entities shall report at least yearly to the competent authorities on the number of new arrangements on the use of ICT services, the categories of ICT third-party service providers, the type of contractual arrangements and the ICT services and functions which are being provided.

Financial entities shall make available to the competent authority, upon its request, the full register of information or, as requested, specified sections thereof, along with any information deemed necessary to enable the effective supervision of the financial entity.

Financial entities shall inform the competent authority in a timely manner about any planned contractual arrangement on the use of ICT services supporting critical or important functions as well as when a function has become critical or important.

4. Before entering into a contractual arrangement on the use of ICT services, financial entities shall:

(a)

assess whether the contractual arrangement covers the use of ICT services supporting a critical or important function;

(b)

assess if supervisory conditions for contracting are met;

(c)

identify and assess all relevant risks in relation to the contractual arrangement, including the possibility that such contractual arrangement may contribute to reinforcing ICT concentration risk as referred to in Article 29;

(d)

undertake all due diligence on prospective ICT third-party service providers and ensure throughout the selection and assessment processes that the ICT third-party service provider is suitable;

(e)

identify and assess conflicts of interest that the contractual arrangement may cause.

5. Financial entities may only enter into contractual arrangements with ICT third-party service providers that comply with appropriate information security standards. When those contractual arrangements concern critical or important functions, financial entities shall, prior to concluding the arrangements, take due consideration of the use, by ICT third-party service providers, of the most up-to-date and highest quality information security standards.

6. In exercising access, inspection and audit rights over the ICT third-party service provider, financial entities shall, on the basis of a risk-based approach, pre-determine the frequency of audits and inspections as well as the areas to be audited through adhering to commonly accepted audit standards in line with any supervisory instruction on the use and incorporation of such audit standards.

Where contractual arrangements concluded with ICT third-party service providers on the use of ICT services entail high technical complexity, the financial entity shall verify that auditors, whether internal or external, or a pool of auditors, possess appropriate skills and knowledge to effectively perform the relevant audits and assessments.

7. Financial entities shall ensure that contractual arrangements on the use of ICT services may be terminated in any of the following circumstances:

(a)

significant breach by the ICT third-party service provider of applicable laws, regulations or contractual terms;

(b)

circumstances identified throughout the monitoring of ICT third-party risk that are deemed capable of altering the performance of the functions provided through the contractual arrangement, including material changes that affect the arrangement or the situation of the ICT third-party service provider;

(c)

ICT third-party service provider’s evidenced weaknesses pertaining to its overall ICT risk management and in particular in the way it ensures the availability, authenticity, integrity and, confidentiality, of data, whether personal or otherwise sensitive data, or non-personal data;

(d)

where the competent authority can no longer effectively supervise the financial entity as a result of the conditions of, or circumstances related to, the respective contractual arrangement.

8. For ICT services supporting critical or important functions, financial entities shall put in place exit strategies. The exit strategies shall take into account risks that may emerge at the level of ICT third-party service providers, in particular a possible failure on their part, a deterioration of the quality of the ICT services provided, any business disruption due to inappropriate or failed provision of ICT services or any material risk arising in relation to the appropriate and continuous deployment of the respective ICT service, or the termination of contractual arrangements with ICT third-party service providers under any of the circumstances listed in paragraph 7.

Financial entities shall ensure that they are able to exit contractual arrangements without:

(a)

disruption to their business activities,

(b)

limiting compliance with regulatory requirements,

(c)

detriment to the continuity and quality of services provided to clients.

Exit plans shall be comprehensive, documented and, in accordance with the criteria set out in Article 4(2), shall be sufficiently tested and reviewed periodically.

Financial entities shall identify alternative solutions and develop transition plans enabling them to remove the contracted ICT services and the relevant data from the ICT third-party service provider and to securely and integrally transfer them to alternative providers or reincorporate them in-house.

Financial entities shall have appropriate contingency measures in place to maintain business continuity in the event of the circumstances referred to in the first subparagraph.

9. The ESAs shall, through the Joint Committee, develop draft implementing technical standards to establish the standard templates for the purposes of the register of information referred to in paragraph 3, including information that is common to all contractual arrangements on the use of ICT services. The ESAs shall submit those draft implementing technical standards to the Commission by 17 January 2024.

Power is conferred on the Commission to adopt the implementing technical standards referred to in the first subparagraph in accordance with Article 15 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

10. The ESAs shall, through the Joint Committee, develop draft regulatory technical standards to further specify the detailed content of the policy referred to in paragraph 2 in relation to the contractual arrangements on the use of ICT services supporting critical or important functions provided by ICT third-party service providers.

When developing those draft regulatory technical standards, the ESAs shall take into account the size and the overall risk profile of the financial entity, and the nature, scale and complexity of its services, activities and operations. The ESAs shall submit those draft regulatory technical standards to the Commission by 17 January 2024.

Power is delegated to the Commission to supplement this Regulation by adopting the regulatory technical standards referred to in the first subparagraph in accordance with Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

DORA · 29

Preliminary assessment of ICT concentration risk at entity level

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_29

Article 29

Preliminary assessment of ICT concentration risk at entity level

1. When performing the identification and assessment of risks referred to in Article 28(4), point (c), financial entities shall also take into account whether the envisaged conclusion of a contractual arrangement in relation to ICT services supporting critical or important functions would lead to any of the following:

(a)

contracting an ICT third-party service provider that is not easily substitutable; or

(b)

having in place multiple contractual arrangements in relation to the provision of ICT services supporting critical or important functions with the same ICT third-party service provider or with closely connected ICT third-party service providers.

Financial entities shall weigh the benefits and costs of alternative solutions, such as the use of different ICT third-party service providers, taking into account if and how envisaged solutions match the business needs and objectives set out in their digital resilience strategy.

2. Where the contractual arrangements on the use of ICT services supporting critical or important functions include the possibility that an ICT third-party service provider further subcontracts ICT services supporting a critical or important function to other ICT third-party service providers, financial entities shall weigh benefits and risks that may arise in connection with such subcontracting, in particular in the case of an ICT subcontractor established in a third-country.

Where contractual arrangements concern ICT services supporting critical or important functions, financial entities shall duly consider the insolvency law provisions that would apply in the event of the ICT third-party service provider's bankruptcy as well as any constraint that may arise in respect to the urgent recovery of the financial entity's data.

Where contractual arrangements on the use of ICT services supporting critical or important functions are concluded with an ICT third-party service provider established in a third country, financial entities shall, in addition to the considerations referred to in the second subparagraph, also consider the compliance with Union data protection rules and the effective enforcement of the law in that third country.

Where the contractual arrangements on the use of ICT services supporting critical or important functions provide for subcontracting, financial entities shall assess whether and how potentially long or complex chains of subcontracting may impact their ability to fully monitor the contracted functions and the ability of the competent authority to effectively supervise the financial entity in that respect.

DORA · 30

Key contractual provisions

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_30

Article 30

Key contractual provisions

1. The rights and obligations of the financial entity and of the ICT third-party service provider shall be clearly allocated and set out in writing. The full contract shall include the service level agreements and be documented in one written document which shall be available to the parties on paper, or in a document with another downloadable, durable and accessible format.

2. The contractual arrangements on the use of ICT services shall include at least the following elements:

(a)

a clear and complete description of all functions and ICT services to be provided by the ICT third-party service provider, indicating whether subcontracting of an ICT service supporting a critical or important function, or material parts thereof, is permitted and, when that is the case, the conditions applying to such subcontracting;

(b)

the locations, namely the regions or countries, where the contracted or subcontracted functions and ICT services are to be provided and where data is to be processed, including the storage location, and the requirement for the ICT third-party service provider to notify the financial entity in advance if it envisages changing such locations;

(c)

provisions on availability, authenticity, integrity and confidentiality in relation to the protection of data, including personal data;

(d)

provisions on ensuring access, recovery and return in an easily accessible format of personal and non-personal data processed by the financial entity in the event of the insolvency, resolution or discontinuation of the business operations of the ICT third-party service provider, or in the event of the termination of the contractual arrangements;

(e)

service level descriptions, including updates and revisions thereof;

(f)

the obligation of the ICT third-party service provider to provide assistance to the financial entity at no additional cost, or at a cost that is determined ex-ante , when an ICT incident that is related to the ICT service provided to the financial entity occurs;

(g)

the obligation of the ICT third-party service provider to fully cooperate with the competent authorities and the resolution authorities of the financial entity, including persons appointed by them;

(h)

termination rights and related minimum notice periods for the termination of the contractual arrangements, in accordance with the expectations of competent authorities and resolution authorities;

(i)

the conditions for the participation of ICT third-party service providers in the financial entities' ICT security awareness programmes and digital operational resilience training in accordance with Article 13(6).

3. The contractual arrangements on the use of ICT services supporting critical or important functions shall include, in addition to the elements referred to in paragraph 2, at least the following:

(a)

full service level descriptions, including updates and revisions thereof with precise quantitative and qualitative performance targets within the agreed service levels to allow effective monitoring by the financial entity of ICT services and enable appropriate corrective actions to be taken, without undue delay, when agreed service levels are not met;

(b)

notice periods and reporting obligations of the ICT third-party service provider to the financial entity, including notification of any development that might have a material impact on the ICT third-party service provider's ability to effectively provide the ICT services supporting critical or important functions in line with agreed service levels;

(c)

requirements for the ICT third-party service provider to implement and test business contingency plans and to have in place ICT security measures, tools and policies that provide an appropriate level of security for the provision of services by the financial entity in line with its regulatory framework;

(d)

the obligation of the ICT third-party service provider to participate and fully cooperate in the financial entity's TLPT as referred to in Articles 26 and 27;

(e)

the right to monitor, on an ongoing basis, the ICT third-party service provider's performance, which entails the following:

(i)

unrestricted rights of access, inspection and audit by the financial entity, or an appointed third party, and by the competent authority, and the right to take copies of relevant documentation on-site if they are critical to the operations of the ICT third-party service provider, the effective exercise of which is not impeded or limited by other contractual arrangements or implementation policies;

(ii)

the right to agree on alternative assurance levels if other clients' rights are affected;

(iii)

the obligation of the ICT third-party service provider to fully cooperate during the onsite inspections and audits performed by the competent authorities, the Lead Overseer, financial entity or an appointed third party; and

(iv)

the obligation to provide details on the scope, procedures to be followed and frequency of such inspections and audits;

(f)

exit strategies, in particular the establishment of a mandatory adequate transition period:

(i)

during which the ICT third-party service provider will continue providing the respective functions, or ICT services, with a view to reducing the risk of disruption at the financial entity or to ensure its effective resolution and restructuring;

(ii)

allowing the financial entity to migrate to another ICT third-party service provider or change to in-house solutions consistent with the complexity of the service provided.

By way of derogation from point (e), the ICT third-party service provider and the financial entity that is a microenterprise may agree that the financial entity's rights of access, inspection and audit can be delegated to an independent third party, appointed by the ICT third-party service provider, and that the financial entity is able to request information and assurance on the ICT third-party service provider's performance from the third party at any time.

4. When negotiating contractual arrangements, financial entities and ICT third-party service providers shall consider the use of standard contractual clauses developed by public authorities for specific services.

5. The ESAs shall, through the Joint Committee, develop draft regulatory technical standards to specify further the elements referred to in paragraph 2, point (a), which a financial entity needs to determine and assess when subcontracting ICT services supporting critical or important functions.

When developing those draft regulatory technical standards, the ESAs shall take into consideration the size and overall risk profile of the financial entity, and the nature, scale and complexity of its services, activities and operations.

The ESAs shall submit those draft regulatory technical standards to the Commission by 17 July 2024.

Power is delegated to the Commission to supplement this Regulation by adopting the regulatory technical standards referred to in the first subparagraph in accordance with Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

DORA · 64

Entry into force and application

2022/2554, official published text · English

https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_64

Article 64

Entry into force and application

This Regulation shall enter into force on the twentieth day following that of its publication in the Official Journal of the European Union .

It shall apply from 17 January 2025.

Copyright · 2

Definitions

2019/790, official published text · English

https://publications.europa.eu/resource/cellar/214471fe-786e-11e9-9f05-01aa75ed71a1.0006.03/DOC_1#art_2

Article 2

Definitions

For the purposes of this Directive, the following definitions apply:

(1)

‘research organisation’ means a university, including its libraries, a research institute or any other entity, the primary goal of which is to conduct scientific research or to carry out educational activities involving also the conduct of scientific research:

(a)

on a not-for-profit basis or by reinvesting all the profits in its scientific research; or

(b)

pursuant to a public interest mission recognised by a Member State;

in such a way that the access to the results generated by such scientific research cannot be enjoyed on a preferential basis by an undertaking that exercises a decisive influence upon such organisation;

(2)

‘text and data mining’ means any automated analytical technique aimed at analysing text and data in digital form in order to generate information which includes but is not limited to patterns, trends and correlations;

(3)

‘cultural heritage institution’ means a publicly accessible library or museum, an archive or a film or audio heritage institution;

(4)

‘press publication’ means a collection composed mainly of literary works of a journalistic nature, but which can also include other works or other subject matter, and which:

(a)

constitutes an individual item within a periodical or regularly updated publication under a single title, such as a newspaper or a general or special interest magazine;

(b)

has the purpose of providing the general public with information related to news or other topics; and

(c)

is published in any media under the initiative, editorial responsibility and control of a service provider.

Periodicals that are published for scientific or academic purposes, such as scientific journals, are not press publications for the purposes of this Directive;

(5)

‘information society service’ means a service within the meaning of point (b) of Article 1(1) of Directive (EU) 2015/1535;

(6)

‘online content-sharing service provider’ means a provider of an information society service of which the main or one of the main purposes is to store and give the public access to a large amount of copyright-protected works or other protected subject matter uploaded by its users, which it organises and promotes for profit-making purposes.

Providers of services, such as not-for-profit online encyclopedias, not-for-profit educational and scientific repositories, open source software-developing and-sharing platforms, providers of electronic communications services as defined in Directive (EU) 2018/1972, online marketplaces, business-to-business cloud services and cloud services that allow users to

upload content for their own use, are not ‘online content-sharing service providers’ within the meaning of this Directive.

Copyright · 3

Text and data mining for the purposes of scientific research

2019/790, official published text · English

https://publications.europa.eu/resource/cellar/214471fe-786e-11e9-9f05-01aa75ed71a1.0006.03/DOC_1#art_3

Article 3

Text and data mining for the purposes of scientific research

1. Member States shall provide for an exception to the rights provided for in Article 5(a) and Article 7(1) of Directive 96/9/EC, Article 2 of Directive 2001/29/EC, and Article 15(1) of this Directive for reproductions and extractions made by research organisations and cultural heritage institutions in order to carry out, for the purposes of scientific research, text and data mining of works or other subject matter to which they have lawful access.

2. Copies of works or other subject matter made in compliance with paragraph 1 shall be stored with an appropriate level of security and may be retained for the purposes of scientific research, including for the verification of research results.

3. Rightholders shall be allowed to apply measures to ensure the security and integrity of the networks and databases where the works or other subject matter are hosted. Such measures shall not go beyond what is necessary to achieve that objective.

4. Member States shall encourage rightholders, research organisations and cultural heritage institutions to define commonly agreed best practices concerning the application of the obligation and of the measures referred to in paragraphs 2 and 3 respectively.

Copyright · 4

Exception or limitation for text and data mining

2019/790, official published text · English

https://publications.europa.eu/resource/cellar/214471fe-786e-11e9-9f05-01aa75ed71a1.0006.03/DOC_1#art_4

Article 4

Exception or limitation for text and data mining

1. Member States shall provide for an exception or limitation to the rights provided for in Article 5(a) and Article 7(1) of Directive 96/9/EC, Article 2 of Directive 2001/29/EC, Article 4(1)(a) and (b) of Directive 2009/24/EC and Article 15(1) of this Directive for reproductions and extractions of lawfully accessible works and other subject matter for the purposes of text and data mining.

2. Reproductions and extractions made pursuant to paragraph 1 may be retained for as long as is necessary for the purposes of text and data mining.

3. The exception or limitation provided for in paragraph 1 shall apply on condition that the use of works and other subject matter referred to in that paragraph has not been expressly reserved by their rightholders in an appropriate manner, such as machine-readable means in the case of content made publicly available online.

4. This Article shall not affect the application of Article 3 of this Directive.

Copyright · 7

Common provisions

2019/790, official published text · English

https://publications.europa.eu/resource/cellar/214471fe-786e-11e9-9f05-01aa75ed71a1.0006.03/DOC_1#art_7

Article 7

Common provisions

1. Any contractual provision contrary to the exceptions provided for in Articles 3, 5 and 6 shall be unenforceable.

2. Article 5(5) of Directive 2001/29/EC shall apply to the exceptions and limitations provided for under this Title. The first, third and fifth subparagraphs of Article 6(4) of Directive 2001/29/EC shall apply to Articles 3 to 6 of this Directive.

AI Act · Annex III

High-risk AI systems referred to in Article 6(2)

Consolidated 27 July 2026 · English

https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3

ANNEX III

High-risk AI systems referred to in Article 6(2)

High-risk AI systems pursuant to Article 6(2) are the AI systems listed in any of the following areas:

1. Biometrics, in so far as their use is permitted under relevant Union or national law:

(a) remote biometric identification systems.

This shall not include AI systems intended to be used for biometric verification the sole purpose of which is to confirm that a specific natural person is the person he or she claims to be;

(b) AI systems intended to be used for biometric categorisation, according to sensitive or protected attributes or characteristics based on the inference of those attributes or characteristics;

(c) AI systems intended to be used for emotion recognition.

2. Critical infrastructure: AI systems intended to be used as safety components in the management and operation of critical digital infrastructure, road traffic, or in the supply of water, gas, heating or electricity.

3. Education and vocational training:

(a) AI systems intended to be used to determine access or admission or to assign natural persons to educational and vocational training institutions at all levels;

(b) AI systems intended to be used to evaluate learning outcomes, including when those outcomes are used to steer the learning process of natural persons in educational and vocational training institutions at all levels;

(c) AI systems intended to be used for the purpose of assessing the appropriate level of education that an individual will receive or will be able to access, in the context of or within educational and vocational training institutions at all levels;

(d) AI systems intended to be used for monitoring and detecting prohibited behaviour of students during tests in the context of or within educational and vocational training institutions at all levels.

4. Employment, workers' management and access to self-employment:

(a) AI systems intended to be used for the recruitment or selection of natural persons, in particular to place targeted job advertisements, to analyse and filter job applications, and to evaluate candidates;

(b) AI systems intended to be used to make decisions affecting terms of work-related relationships, the promotion or termination of work-related contractual relationships, to allocate tasks based on individual behaviour or personal traits or characteristics or to monitor and evaluate the performance and behaviour of persons in such relationships.

5. Access to and enjoyment of essential private services and essential public services and benefits:

(a) AI systems intended to be used by public authorities or on behalf of public authorities to evaluate the eligibility of natural persons for essential public assistance benefits and services, including healthcare services, as well as to grant, reduce, revoke, or reclaim such benefits and services;

(b) AI systems intended to be used to evaluate the creditworthiness of natural persons or establish their credit score, with the exception of AI systems used for the purpose of detecting financial fraud;

(c) AI systems intended to be used for risk assessment and pricing in relation to natural persons in the case of life and health insurance;

(d) AI systems intended to evaluate and classify emergency calls by natural persons or to be used to dispatch, or to establish priority in the dispatching of, emergency first response services, including by police, firefighters and medical aid, as well as of emergency healthcare patient triage systems.

6. Law enforcement, in so far as their use is permitted under relevant Union or national law:

(a) AI systems intended to be used by or on behalf of law enforcement authorities, or by Union institutions, bodies, offices or agencies in support of law enforcement authorities or on their behalf to assess the risk of a natural person becoming the victim of criminal offences;

(b) AI systems intended to be used by or on behalf of law enforcement authorities or by Union institutions, bodies, offices or agencies in support of law enforcement authorities as polygraphs or similar tools;

(c) AI systems intended to be used by or on behalf of law enforcement authorities, or by Union institutions, bodies, offices or agencies, in support of law enforcement authorities to evaluate the reliability of evidence in the course of the investigation or prosecution of criminal offences;

(d) AI systems intended to be used by law enforcement authorities or on their behalf or by Union institutions, bodies, offices or agencies in support of law enforcement authorities for assessing the risk of a natural person offending or re-offending not solely on the basis of the profiling of natural persons as referred to in Article 3(4) of Directive (EU) 2016/680, or to assess personality traits and characteristics or past criminal behaviour of natural persons or groups;

(e) AI systems intended to be used by or on behalf of law enforcement authorities or by Union institutions, bodies, offices or agencies in support of law enforcement authorities for the profiling of natural persons as referred to in Article 3(4) of Directive (EU) 2016/680 in the course of the detection, investigation or prosecution of criminal offences.

7. Migration, asylum and border control management, in so far as their use is permitted under relevant Union or national law:

(a) AI systems intended to be used by or on behalf of competent public authorities or by Union institutions, bodies, offices or agencies as polygraphs or similar tools;

(b) AI systems intended to be used by or on behalf of competent public authorities or by Union institutions, bodies, offices or agencies to assess a risk, including a security risk, a risk of irregular migration, or a health risk, posed by a natural person who intends to enter or who has entered into the territory of a Member State;

(c) AI systems intended to be used by or on behalf of competent public authorities or by Union institutions, bodies, offices or agencies to assist competent public authorities for the examination of applications for asylum, visa or residence permits and for associated complaints with regard to the eligibility of the natural persons applying for a status, including related assessments of the reliability of evidence;

(d) AI systems intended to be used by or on behalf of competent public authorities, or by Union institutions, bodies, offices or agencies, in the context of migration, asylum or border control management, for the purpose of detecting, recognising or identifying natural persons, with the exception of the verification of travel documents.

8. Administration of justice and democratic processes:

(a) AI systems intended to be used by a judicial authority or on their behalf to assist a judicial authority in researching and interpreting facts and the law and in applying the law to a concrete set of facts, or to be used in a similar way in alternative dispute resolution;

(b) AI systems intended to be used for influencing the outcome of an election or referendum or the voting behaviour of natural persons in the exercise of their vote in elections or referenda. This does not include AI systems to the output of which natural persons are not directly exposed, such as tools used to organise, optimise or structure political campaigns from an administrative or logistical point of view.

French labour law · L2312-8

CSE: consultation / workplace technology

Official Code du travail numérique, retrieved 1 November 2026 · French (official wording)

https://code.travail.gouv.fr/code-du-travail/l2312-8

I. - Le comité social et économique a pour mission d'assurer une expression collective des salariés permettant la prise en compte permanente de leurs intérêts dans les décisions relatives à la gestion et à l'évolution économique et financière de l'entreprise, à l'organisation du travail, à la formation professionnelle et aux techniques de production, notamment au regard des conséquences environnementales de ces décisions.

II. - Le comité est informé et consulté sur les questions intéressant l'organisation, la gestion et la marche générale de l'entreprise, notamment sur:

1° Les mesures de nature à affecter le volume ou la structure des effectifs ;

2° La modification de son organisation économique ou juridique ;

3° Les conditions d'emploi, de travail, notamment la durée du travail, et la formation professionnelle ;

4° L'introduction de nouvelles technologies, tout aménagement important modifiant les conditions de santé et de sécurité ou les conditions de travail ;

5° Les mesures prises en vue de faciliter la mise, la remise ou le maintien au travail des accidentés du travail, des invalides de guerre, des invalides civils, des personnes atteintes de maladies chroniques évolutives et des travailleurs handicapés, notamment sur l'aménagement des postes de travail.

III. - Le comité est informé et consulté sur les conséquences environnementales des mesures mentionnées au II du présent article.

IV. - Le comité social et économique mis en place dans les entreprises d'au moins cinquante salariés exerce également les attributions prévues à la section 2.

NOTA

Conformément à l'article 9 I de l'ordonnance n° 2017-1386 du 22 septembre 2017, les présentes dispositions entrent en vigueur à la date d'entrée en vigueur des décrets pris pour leur application, et au plus tard le 1er janvier 2018.

French labour law · L2312-14

CSE: consultation / workplace technology

Official Code du travail numérique, retrieved 1 November 2026 · French (official wording)

https://code.travail.gouv.fr/code-du-travail/l2312-14

Les décisions de l'employeur sont précédées de la consultation du comité social et économique, sauf, en application de l'article

L. 2312-49

, avant le lancement d'une offre publique d'acquisition.

Les projets d'accord collectif, leur révision ou leur dénonciation ne sont pas soumis à la consultation du comité.

Les entreprises ayant conclu un accord relatif à la gestion prévisionnelle des emplois et des compétences ne sont pas soumises, dans ce domaine, à l'obligation de consultation du comité social et économique.

NOTA

Conformément à l'article 9 I de l'ordonnance n° 2017-1386 du 22 septembre 2017, les présentes dispositions entrent en vigueur à la date d'entrée en vigueur des décrets pris pour leur application, et au plus tard le 1er janvier 2018.

French labour law · L2312-38

CSE: consultation / workplace technology

Official Code du travail numérique, retrieved 1 November 2026 · French (official wording)

https://code.travail.gouv.fr/code-du-travail/l2312-38

Le comité social et économique est informé, préalablement à leur utilisation, sur les méthodes ou techniques d'aide au recrutement des candidats à un emploi ainsi que sur toute modification de celles-ci.

Il est aussi informé, préalablement à leur introduction dans l'entreprise, sur les traitements automatisés de gestion du personnel et sur toute modification de ceux-ci.

Le comité est informé et consulté, préalablement à la décision de mise en œuvre dans l'entreprise, sur les moyens ou les techniques permettant un contrôle de l'activité des salariés.

NOTA

Conformément à l'article 9 I de l'ordonnance n° 2017-1386 du 22 septembre 2017, les présentes dispositions entrent en vigueur à la date d'entrée en vigueur des décrets pris pour leur application, et au plus tard le 1er janvier 2018.

French consumer credit · Ordonnance Art. 19

Replacement of Consumer Code Article L312-16

Ordonnance 2025-880 of 3 September 2025; relevant rules apply 20 November 2026 · French (official wording)

https://www.legifrance.gouv.fr/jorf/id/JORFTEXT000052184230

Article 19

L'article L. 312-16 est remplacé par les dispositions suivantes :

« Art. L. 312-16. – I. – Avant de conclure le contrat de crédit, le prêteur procède à une évaluation minutieuse de la solvabilité de l'emprunteur. Cette évaluation tient compte des facteurs pertinents permettant de vérifier la probabilité que l'emprunteur remplisse l'ensemble des obligations stipulées par le contrat de crédit.

« II. – L'évaluation de la solvabilité s'effectue sur la base d'informations pertinentes et exactes relatives aux revenus et charges de l'emprunteur ainsi qu'à d'autres critères économiques et financiers, qui sont nécessaires et proportionnées à la nature, à la durée, au montant du crédit et aux risques qu'il présente pour l'emprunteur.

« III. – Les informations mentionnées au II peuvent comprendre des preuves de revenus ou d'autres types de ressources, des informations sur les actifs et passifs financiers ou des informations sur d'autres engagements financiers. Ces informations peuvent également comprendre l'existence de preuves suffisantes que le ou les crédits seront susceptibles d'apporter à l'emprunteur des revenus futurs, l'existence de sûretés ou d'autres formes de garanties que l'emprunteur pourrait fournir. Ces informations ne comprennent pas les catégories particulières de données visées au I de l'article 6 de la loi no 78-17 du 6 janvier 1978.

« Ces informations sont recueillies par le prêteur auprès de toutes sources internes ou externes pertinentes, y compris auprès de l'emprunteur, et comprennent notamment les informations fournies, le cas échéant, par l'intermédiaire de crédit. Les réseaux sociaux ne sont pas considérés comme une source externe pertinente aux fins du présent article.

« Les informations recueillies font l'objet d'une vérification, si nécessaire en se référant à des documents autres que ceux fournis par l'emprunteur.

« IV. – Le prêteur consulte le fichier prévu à l'article L. 751-1, dans les conditions prévues par l'arrêté mentionné à l'article L. 751-6, sauf dans le cas d'une opération mentionnée au 1 de l'article L. 511-6 ou au 1 du I de l'article L. 511-7 du code monétaire et financier. L'évaluation de la solvabilité ne se fonde pas exclusivement sur cette consultation.

« V. – Si la demande de crédit est présentée conjointement par plusieurs emprunteurs, le prêteur effectue l'évaluation de la solvabilité sur la base de la capacité de remboursement conjointe des emprunteurs.

« VI. – Le prêteur ne peut accorder le crédit à l'emprunteur que si le résultat de l'évaluation de la solvabilité indique que les obligations découlant du contrat de crédit seront vraisemblablement respectées conformément à ce qui est prévu par ce contrat compte tenu des facteurs pertinents mentionnés au I.

« VII. – Le prêteur ne peut ni résilier ni modifier ultérieurement le contrat de crédit conclu avec l'emprunteur au motif qu'il a vérifié la solvabilité de manière incorrecte, sauf dans l'hypothèse où il est avéré que des informations mentionnées au II ont été dissimulées ou falsifiées par l'emprunteur.

« VIII. – S'il y a lieu, le prêteur informe l'emprunteur de ce que l'évaluation de sa solvabilité est fondée sur un traitement automatisé des données à caractère personnel. Dans ce cas, il lui indique la procédure à suivre pour contester la décision de rejet de sa demande de crédit et de son droit à une intervention humaine.

« L'emprunteur a le droit d'obtenir une explication claire et compréhensible de l'évaluation de sa solvabilité, de

la logique et des risques associés au traitement automatisé des données à caractère personnel ainsi que de sa signification et de ses effets sur la décision, d'exprimer son point de vue et de demander un réexamen de l'évaluation de sa solvabilité et de la décision prise par le prêteur sur sa demande de crédit.

« IX. – A l'issue de la vérification de la solvabilité de l'emprunteur, lorsque la demande de crédit est rejetée, le prêteur l'informe dans les meilleurs délais de ce rejet et peut l'orienter, le cas échéant, vers des services de conseil aux personnes endettées facilement accessibles mentionnés à l'article L. 312-35-2.

« Lorsque cette décision est fondée sur le résultat de la consultation du fichier mentionné au IV, le prêteur en informe l'emprunteur. Il lui communique sans délai et sans frais ce résultat ainsi que des informations sur ce fichier et la nature des données prises en considération.

« X. – Le prêteur réévalue la solvabilité de l'emprunteur, sur la base d'informations mises à jour, avant d'accorder une augmentation significative du montant total du crédit. »

French consumer credit · Ordonnance Art. 99

Entry into force and transitional rules

Ordonnance 2025-880 of 3 September 2025; relevant rules apply 20 November 2026 · French (official wording)

https://www.legifrance.gouv.fr/jorf/id/JORFTEXT000052184230

Article 99

I. – La présente ordonnance entre en vigueur le 20 novembre 2026.

II. – Les contrats de crédit en cours au 20 novembre 2026 restent régis par les dispositions du code de la consommation et du code monétaire et financier dans leur rédaction antérieure à l'entrée en vigueur de la présente ordonnance.

III. – Par dérogation au II, les articles 34, 35, 43 à 45, 59 à 61, 64 et 72 s'appliquent à tous les contrats de crédit à durée indéterminée en cours à la date du 20 novembre 2026.

CJEU judgments · C-634/21 • 7 December 2023

SCHUFA

C-634/21 • 7 December 2023 · English

https://publications.europa.eu/resource/cellar/acd82fb9-94e3-11ee-b164-01aa75ed71a1.0010.05/DOC_1

On those grounds, the Court (First Chamber) hereby rules:

Article 22(1) of Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

must be interpreted as meaning that the automated establishment, by a credit information agency, of a probability value based on personal data relating to a person and concerning his or her ability to meet payment commitments in the future constitutes ‘automated individual decision-making’ within the meaning of that provision, where a third party, to which that probability value is transmitted, draws strongly on that probability value to establish, implement or terminate a contractual relationship with that person.

CJEU judgments · C-203/22 • 27 February 2025

Dun Bradstreet

C-203/22 • 27 February 2025 · English

https://publications.europa.eu/resource/cellar/44fa73b1-f4ef-11ef-b7db-01aa75ed71a1.0010.05/DOC_1

On those grounds, the Court (First Chamber) hereby rules:

1.

Article 15(1)(h) of Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

must be interpreted as meaning that, in the case of automated decision-making, including profiling, within the meaning of Article 22(1) of that regulation, the data subject may require the controller, as ‘meaningful information about the logic involved’, to explain, by means of relevant information and in a concise, transparent, intelligible and easily accessible form, the procedure and principles actually applied in order to use, by automated means, the personal data concerning that person with a view to obtaining a specific result, such as a credit profile.

2.

Article 15(1)(h) of Regulation 2016/679

must be interpreted as meaning that, where the controller takes the view that the information to be provided to the data subject in accordance with that provision contains data of third parties protected by that regulation or trade secrets, within the meaning of point 1 of Article 2 of Directive (EU) 2016/943 of the European Parliament and of the Council of 8 June 2016 on the protection of undisclosed know-how and business information (trade secrets) against their unlawful acquisition, use and disclosure, that controller is required to provide the allegedly protected information to the competent supervisory authority or court, which must balance the rights and interests at issue with a view to determining the extent of the data subject’s right of access provided for in Article 15 of that regulation.